

Web Application Report

This report includes important security information about your web application.

安全报告

该报告由 HCL AppScan Standard 创建 10.9.0
扫描开始时间: 2026/4/16 下午12:39:33

目录

介绍

- 常规信息
- 登陆设置

摘要

- 问题类型
- 有漏洞的 URL
- 修订建议
- 安全风险
- 原因
- WASC 威胁分类

按问题类型分组的问题

- SQL 注入 ¹
- 整数溢出 ⁵³
- 查询中的密码参数 ¹
- 缺少必需的CSP指令 ⁵⁸
- 通过 URL 重定向钓鱼 ¹
- CORS 策略根据任意初始头进行设置 ¹
- OAuth 隐式授权类型缺陷 ²
- SRI (Subresource Integrity) 的检查 ¹
- 具有不安全、不正确或缺少 SameSite 属性的 Cookie ⁷
- 加密会话（SSL）Cookie 中缺少 Secure 属性 ⁶
- 发现数据库错误模式 ⁴
- 跨站点请求伪造 ¹⁸
- “X-Content-Type-Options”头缺失或不安全 ¹
- 会话 cookie 中缺少 HttpOnly 属性 ²
- 发现 Web 应用程序源代码泄露模式 ¹
- 发现可高速缓存的 SSL 页面 ³⁴
- 在CSP中未强制执行脚本中的可信类型 ⁵⁸
- 永久 Cookie 包含敏感的会话信息 ²
- 跨帧脚本编制防御缺失或不安全 ¹
- 过度许可的 CORS 访问测试 ¹

修复方法

- SQL 注入
- 整数溢出

- 查询中的密码参数
- 缺少必需的CSP指令
- 通过 URL 重定向钓鱼
- CORS 策略根据任意初始头进行设置
- OAuth 隐式授权类型缺陷
- SRI (Subresource Integrity) 的检查
- 具有不安全、不正确或缺少 SameSite 属性的 Cookie
- 加密会话 (SSL) Cookie 中缺少 Secure 属性
- 发现数据库错误模式
- 跨站点请求伪造
- "X-Content-Type-Options"头缺失或不安全
- 会话 cookie 中缺少 HttpOnly 属性
- 发现 Web 应用程序源代码泄露模式
- 发现可高速缓存的 SSL 页面
- 在CSP中未强制执行脚本中的可信类型
- 永久 Cookie 包含敏感的会话信息
- 跨帧脚本编制防御缺失或不安全
- 过度许可的 CORS 访问测试

介绍

该报告包含由 HCL AppScan Standard 执行的 Web 应用程序安全性扫描的结果。

紧急严重性问题:	1
高严重性问题:	113
中等严重性问题:	40
低严重性问题:	100
报告中包含的严重性问题总数:	254
扫描中发现的严重性问题总数:	409

常规信息

扫描文件名称:	全流程工程管理数字化系统-26-4-16
扫描开始时间:	2026/4/16 下午12:39:33
测试策略:	Default
CVSS 版本:	3.1
测试优化级别:	快

主机	emds.sqemc.com
端口	8443
操作系统:	未知
Web 服务器:	未知
应用程序服务器:	任何

登陆设置

登陆方法:	提示
并发登陆:	已启用
会话中检测:	已启用
会话中模式:	资金计划明细 本月审定金额 截止上月已付金额
跟踪或会话 ID cookie:	* platform_user_token LoginSite _userHash userToken_Core __tracker_user_id__ __fast_sid__
跟踪或会话 ID 参数:	state request_id request_id id clientid agents osarch osver installdate code

```

state
timestamp
templateGuid
__randNum
t
t
t
t
->"templateGuid"
->"componentGuid"
->"method"
->"data"->"appList"[0]->"appCodeList"[0]
->"data"->"appList"[0]->"appCodeList"[1]
->"data"->"appList"[0]->"appCodeList"[9]
->"data"->"appList"[0]->"sites"[0]->"siteCode"
->"data"->"appList"[0]->"sites"[1]->"siteCode"
->"data"->"appList"[0]->"sites"[9]->"siteCode"
sub_nav_code
sub_nav_code
sub_nav_code
sub_nav_code
__mp_metadataId
__mp_controlFunctionPageId
__mp_version
__mp_metadataId
__mp_controlFunctionPageId
__mp_version
->"sortField"
->"viewId"
->"idField"
->"gridViewId"
->"functionCode"
->"metadataId"
->"pageId"
pageId
data->"base"->"d"
data->"base"->"pg"
data->"base"->"pid"
data->"base"->"ps"
data->"base"->"sid"
data->"base"->"av"
sub_nav_code
data->"base"->"u"
data->"base"->"dsw"
data->"base"->"ua"
data->"base"->"tv"
data->"items"[0]->"pid"
data->"items"[0]->"sid"
->"param"->"application"
->"param"->"functionCode"
->"param"->"pageId"
->"metadataId"
->"pageId"
->"YearMonth"
->"options"->"context"->"YearMonth"
->"idField"
->"sortField"
->"metadataId"
->"viewId"
->"gridViewId"
->"functionCode"
->"pageId"
pageId
siteGuid

```

登陆序列:

```

https://emds.sqemc.com:8443/
https://emds.sqemc.com:8443/auth/oauth2/authorize?
redirect_uri=https://emds.sqemc.com:8443/apaas-auth/oauth2/portal?
redirect_uri=%2f&response_type=code&state=807f6107-f051-4bb8-8230-
ef5b5eb580d4&client_id=platform
https://emds.sqemc.com:8443/gzt/oauth2/refreshToken?
request_id=25d18c63-0e26-40b1-879a-
d24a4c7ff67d&redirect_uri=https://emds.sqemc.com:8443/auth/oauth2/auth
orize?redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fapaas-
auth%2Foauth2%2Fportal%3Fredirect_uri%3D%252f&response_type=code&state

```

=807f6107-f051-4bb8-8230-ef5b5eb580d4&client_id=platform
https://emds.sqemc.com:8443/login?request_id=25d18c63-0e26-40b1-879a-d24a4c7ff67d&redirect_uri=https://emds.sqemc.com:8443/auth/oauth2/auth
orize?redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fapaas-
auth%2Foauth2%2Fportal%3Fredirect_uri%3D%252f&response_type=code&state
=807f6107-f051-4bb8-8230-ef5b5eb580d4&client_id=platform
https://config.edge.skype.com/config/v1/Edge/146.0.3856.97?clientid=-
3247009839112135370&agents=EdgeConfig,EdgeFirstRunConfig&osname=win&cl
ient=webview&channel=stable&osarch=x86_64&osver=10.0.22000&devicefamil
y=desktop&deviceform=&uma=1&sessionid=0&userid=&mngd=0&ent=0&installda
te=1776314049&edu=0&vm=0
https://emds.sqemc.com:8443/ajax/Mysoft.PubPlatform.Nav.Handlers.WorkB
enchLoginHandler/BgVideo?id=00000000-0000-0000-0000-000000000000
https://config.edge.skype.com/config/v1/Edge/146.0.3856.97?clientid=-
3247009839112135370&agents=EdgeRuntimeConfig,EdgeDomainActions&osname=
win&client=webview&channel=stable&osarch=x86_64&osver=10.0.22000&devic
efamily=desktop&deviceform=&uma=1&sessionid=0&userid=&mngd=0&ent=0&ins
talldate=1776314049&edu=0&vm=0
https://emds.sqemc.com:8443/ajax/Mysoft.PubPlatform.Nav.Handlers.WorkB
enchLoginHandler/DoLogin
https://emds.sqemc.com:8443/auth/oauth2/callback?
code=2XavvJ7p2XUSpAKNfTqn1u8HxJnOIPBzvA4k7My6XTkMbVZ-
th_fhHaknS6VhADVbY6bpct5QaHO5eupJ9u7nYBRP6gTTvm_FcOeOys3m0HEcfwUt2Dui
5KmButeJGj&state=ba37e90a-e78f-438d-a04e-
d33ca7908e5c&redirect_uri=https://emds.sqemc.com:8443/std/03011401/08d
c5cec-6593-4af6-8de4-8bf200fca00a
https://emds.sqemc.com:8443/std/03011401/08dc5cec-6593-4af6-8de4-
8bf200fca00a
https://emds.sqemc.com:8443/PO/version.json?timestamp=1776314060527
https://emds.sqemc.com:8443/bpm/api/sso/logout
https://emds.sqemc.com:8443/PO/version.json?timestamp=1776314061016
https://emds.sqemc.com:8443/api/03011401/layout/getTemplate
https://emds.sqemc.com:8443/pub/03011407/topNav/getMessageCount?
__randNum=0.6326909540601136
https://emds.sqemc.com:8443/PO/widgets/notice/manifest.json?
t=1776314061179
https://emds.sqemc.com:8443/PO/widgets/functionList/manifest.json?
t=1776314061181
https://emds.sqemc.com:8443/PO/widgets/messageCenter/manifest.json?
t=1776314061184
https://emds.sqemc.com:8443/PO/widgets/news/manifest.json?
t=1776314061185
https://emds.sqemc.com:8443/PO/widgets/notice/i18n/zh-CN.json?v=2.2.10
https://emds.sqemc.com:8443/PO/widgets/functionList/i18n/zh-CN.json?
v=1.0.39
https://emds.sqemc.com:8443/PO/widgets/news/i18n/zh-CN.json?v=2.2.9
https://emds.sqemc.com:8443/PO/widgets/messageCenter/i18n/zh-CN.json?
v=1.5.15
https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Message.AppServices
.MessageAppService/GetTaskWakeCountByUser
https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.Ext
ernalWebResourceAppService/GetResources
https://emds.sqemc.com:8443/api/03011601/widgetApi/proxy
https://emds.sqemc.com:8443/api/03011601/widgetApi/proxy
https://emds.sqemc.com:8443/api/03011601/widgetApi/proxy
https://emds.sqemc.com:8443/api/03011601/widgetApi/proxy
https://emds.sqemc.com:8443/api/03011601/widgetApi/proxy
https://emds.sqemc.com:8443/api/03011601/widgetApi/proxy
https://emds.sqemc.com:8443/api/03011601/widgetApi/proxy
https://emds.sqemc.com:8443/api/03011407/setting/getCustomServiceSetti
ng?siteGuid=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-
0u9sBtwly8kQ81KZOCj1aGXfLivTxfar5YFqwyJRiTLg6jG?env=xc-qhgg-idx&data=
{\"base\":{\"u\":\"27712d2b23f5100-cd5000711b-
fd66202e\",\"dsw\":1536,\"dsh\":864,\"ua\":\"Mozilla/5.0 (Windows NT 10.0;
Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
Safari/537.36 Edg/146.0.0.0\",\"tv\":\"1.0.1-
r27\",\"tl\":\"javascript\",\"at\":\"\",\"d\":\"emds.sqemc.com:8443\",\"pg\":\"/std/03
011401/08dc5cec-6593-4af6-8de4-8bf200fca00a#/custom-
page\",\"pid\":\"27712d2b2436fa0-b99a00...
https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Handlers.Log.Use
rBehaviorHandler/WriteLog
https://emds.sqemc.com:8443/api/42000101/assistant/getAssistants
https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-
0u9sBtwly8kQ81KZOCj1aGXfLivTxfar5YFqwyJRiTLg6jG?env=xc-qhgg-idx&data=

{"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e","dsw":1536,"dsh":864,"ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0","tv":"1.0.1-r27","tl":"javascript","at":"","d":"emds.sqemc.com:8443","pg":"/std/03011401/08dc5cec-6593-4af6-8de4-8bf200fca00a#/custom-page","pid":"27712d2b2436fa0-b99a00...
https://emds.sqemc.com:8443/std/32010650/81a01160-efa5-454f-509a-08da4c3076e6?nav_code=10407&sub_nav_code=10693
https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwyJRiTlg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e","dsw":1536,"dsh":864,"ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0","tv":"1.0.1-r27","tl":"javascript","at":"","items":[{"e":{"page","d":"emds.sqemc.com:8443","pg":"/std/32010650/81a01160-efa5-454f-509a-08da4c3076e6","pid":"27712d2b7d44d...
https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwyJRiTlg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e","dsw":1536,"dsh":864,"ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0","tv":"1.0.1-r27","tl":"javascript","at":"","d":"emds.sqemc.com:8443","pg":"/std/32010650/81a01160-efa5-454f-509a-08da4c3076e6","pid":"27712d2b7d44d40-8ad400c9e5-46352f2f...
https://emds.sqemc.com:8443/std/32010651/aa224626-828f-49ad-3fe4-08dacb8826af?nav_code=10407&sub_nav_code=10694
https://emds.sqemc.com:8443/api/03011407/setting/getCustomServiceSetting?siteGuid=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwyJRiTlg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e","dsw":1536,"dsh":864,"ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0","tv":"1.0.1-r27","tl":"javascript","at":"","items":[{"e":{"page","d":"emds.sqemc.com:8443","pg":"/std/32010651/aa224626-828f-49ad-3fe4-08dacb8826af","pid":"27712d2c4ed6b...
https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/GetHtml?_mp_clientID=appGrid&_mp_metadataId=93c05df8-b76d-4a66-3ff1-08dacb8826af&_mp_controlAppCode=3201&_mp_controlFunctionPageId=014195d2-6659-4c40-3fe3-08dacb8826af&_mp_controlFunctionCode=32010651&_mp_controlBelongFunctionCode=32010651&_mp_parenControlType=&_mp_version=799166468380304038&refFilterHasNoData=true
https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Message.AppServices.MessageAppService/GetTaskWakeCountByUser
https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect?refFilterHasNoData=true
https://emds.sqemc.com:8443/std/32010602/6dlb60f8-a3b5-4021-2340-08da7feb73d1?nav_code=10407&sub_nav_code=10695
https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/LoadData?refFilterHasNoData=true&pageId=014195d2-6659-4c40-3fe3-08dacb8826af
https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwyJRiTlg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e","dsw":1536,"dsh":864,"ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0","tv":"1.0.1-r27","tl":"javascript","at":"","d":"emds.sqemc.com:8443","pg":"/std/32010651/aa224626-828f-49ad-3fe4-08dacb8826af","pid":"27712d2c4ed6bc0-c23c00f529-c733302c...
https://emds.sqemc.com:8443/api/03011407/setting/getCustomServiceSetting?siteGuid=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Handlers.Log.Use rBehaviorHandler/WriteLog?refFilterHasNoData=true
https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwyJRiTlg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e","dsw":1536,"dsh":864,"ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0

Safari/537.36 Edg/146.0.0.0", "tv": "1.0.1-r27", "tl": "javascript", "at": "", "items": [{"e": "page", "d": "emds.sqemc.com:8443", "pg": "/std/32010602/6dlb60f8-a3b5-4021-2340-08da7feb73d1", "pid": "27712d2ca3273... https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwYJRiTLg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e", "dsw":1536, "dsh":864, "ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0", "tv": "1.0.1-r27", "tl": "javascript", "at": "", "d": "emds.sqemc.com:8443", "pg": "/std/32010602/6dlb60f8-a3b5-4021-2340-08da7feb73d1", "pid": "27712d2ca327340-37340091d2-982c3536... https://emds.sqemc.com:8443/std/32010652/08db82a4-ff76-43ff-80cd-70ffe3d0217e?nav_code=10407&sub_nav_code=11386 https://emds.sqemc.com:8443/api/03011407/setting/getCustomServiceSetting?siteGuid=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3 https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Message.AppServices.MessageAppService/GetTaskWakeCountByUser https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTree.GridAjaxHandler/GetHtml?_mp_clientID=appTreeGrid&_mp_metadataId=d60bc42b-af3f-4fc2-2347-08da7feb73d1&_mp_controlAppCode=3201&_mp_controlFunctionPageId=c727ddf6-b74c-47dd-233f-08da7feb73d1&_mp_controlFunctionCode=32010602&_mp_controlBelongFunctionCode=32010602&_mp_parenControlType=&_mp_version=-8926681199718634394&refFilterHasNoData=true https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwYJRiTLg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e", "dsw":1536, "dsh":864, "ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0", "tv": "1.0.1-r27", "tl": "javascript", "at": "", "items": [{"e": "page", "d": "emds.sqemc.com:8443", "pg": "/std/32010652/08db82a4-ff76-43ff-80cd-70ffe3d0217e", "pid": "27712d2d757c6... https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Message.AppServices.MessageAppService/GetTaskWakeCountByUser https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGrid.AjaxHandler/GetHtml?_mp_clientID=appGrid&_mp_metadataId=08db82a4-ff79-471a-84ee-4009a82f5cea&_mp_controlAppCode=3201&_mp_controlFunctionPageId=08db82a4-ff76-43fd-85b7-ce45902cfa34&_mp_controlFunctionCode=32010652&_mp_controlBelongFunctionCode=32010652&_mp_parenControlType=&_mp_version=9028456258546742699&refFilterHasNoData=true https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect?refFilterHasNoData=true https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.Controls.SubControls.FilterAppService/LoadFilter?refFilterHasNoData=true https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGrid.AjaxHandler/LoadData?refFilterHasNoData=true&pageId=08db82a4-ff76-43fd-85b7-ce45902cfa34 https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwYJRiTLg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e", "dsw":1536, "dsh":864, "ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0", "tv": "1.0.1-r27", "tl": "javascript", "at": "", "d": "emds.sqemc.com:8443", "pg": "/std/32010652/08db82a4-ff76-43ff-80cd-70ffe3d0217e", "pid": "27712d2d757c6c0-44ec003795-b7666569... https://emds.sqemc.com:8443/std/32010603/b47482f8-d2d3-4dea-6945-08da7e9dbc01?nav_code=10407&sub_nav_code=10697 https://emds.sqemc.com:8443/api/03011407/setting/getCustomServiceSetting?siteGuid=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3 https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Handlers.Log.Use.rBehaviorHandler/WriteLog?refFilterHasNoData=true https://fast-logstore.mypaas.com/report/UKI255D2g0f9eYbi-0u9sBtwly8kQ81KZ0CjlaGXfLivTxfar5YFqwYJRiTLg6jG?env=xc-qhgg-idc&data={"base":{"u":"27712d2b23f5100-cd5000711b-fd66202e", "dsw":1536, "dsh":864, "ua":"Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 Edg/146.0.0.0", "tv": "1.0.1-r27", "tl": "javascript", "at": "", "items":

[{"e": "page", "d": "emds.sqemc.com:8443", "pg": "/std/32010603/b47482f8-d2d3-4dea-6945-08da7e9dbc01", "pid": "27712d2e21653..."}]
<https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Message.AppServices.MessageAppService/GetTaskWakeCountByUser>
<https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect?refFilterHasNoData=true>
<https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.Controls.SubControls.FilterAppService/LoadFilter?refFilterHasNoData=true>
<https://emds.sqemc.com:8443/api/32010602/MoneyPlan/GetMoneyPlanMakeKnownInfo?refFilterHasNoData=true>
<https://emds.sqemc.com:8443/api/32010651/EmergencyPaymentSubmission/GetSubmissionDic?buGuid=&refFilterHasNoData=true&planMonth=2026-04-0100:00:00>
<https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTree.GridAjaxHandler/LoadData?refFilterHasNoData=true&pageId=9f6a0a70-af99-428e-6944-08da7e9dbc01>
<https://emds.sqemc.com:8443/api/03011407/setting/getCustomServiceSetting?siteGuid=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3>
<https://emds.sqemc.com:8443/api/42000101/assistant/getAssistants>

摘要

问题类型 20

TOC

问题类型	问题的数量
紧 SQL 注入	1
高 整数溢出	53
高 查询中的密码参数	1
高 缺少必需的CSP指令	58
高 通过 URL 重定向钓鱼	1
中 CORS 策略根据任意初始头进行设置	1
中 OAuth 隐式授权类型缺陷	2
中 SRI (Subresource Integrity) 的检查	1
中 具有不安全、不正确或缺少 SameSite 属性的 Cookie	7
中 加密会话（SSL）Cookie 中缺少 Secure 属性	6
中 发现数据库错误模式	4
中 跨站点请求伪造	19
低 “X-Content-Type-Options”头缺失或不安全	1
低 会话 cookie 中缺少 HttpOnly 属性	2
低 发现 Web 应用程序源代码泄露模式	1
低 发现可高速缓存的 SSL 页面	34
低 在CSP中未强制执行脚本中的可信类型	58
低 永久 Cookie 包含敏感的会话信息	2
低 跨帧脚本编制防御缺失或不安全	1
低 过度许可的 CORS 访问测试	1

有漏洞的 URL 67

TOC

URL	问题的数量
紧 https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data	8
高 https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppCardAjaxHandler/LoadData	6
高 https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/GetHtml	8
高 https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/LoadData	9
高 https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml	7
高 https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData	7
高 https://emds.sqemc.com:8443/api/02200201/Provider/enableYcg	4
高 https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetCacheManager	5
高 https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetExportParam	4
高 https://emds.sqemc.com:8443/api/02200307/CgSolutionSimple/GetNodeList	4
高 https://emds.sqemc.com:8443/api/02201204/BaseBidPriceAdjust/IsAdmin	4
高 https://emds.sqemc.com:8443/api/02201601/KhRule/GetKhRuleList	5
高 https://emds.sqemc.com:8443/api/02201601/KhRule/GetUsedProviderTypeInfo	4
高 https://emds.sqemc.com:8443/api/02209901/Common/enableRiskMain	4

高	https://emds.sqemc.com:8443/api/03011407/setting/globalCss	4	
高	https://emds.sqemc.com:8443/api/03011407/setting/page/config	4	
高	https://emds.sqemc.com:8443/api/32010604/MoneyPlanReportGroup/GetMoneyPlanGroupApprovalData	4	
高	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetFianFinancePlanSettings	4	
高	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetMoneyPlanParamValue	5	
高	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect	7	
高	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.Controls.SubControls.FilterAppService/LoadFilter	4	
高	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.SiteRedirectAppService/RedirectFunctionHomePageWithoutToken	4	
高	https://emds.sqemc.com:8443/auth/oauth2/authorize	3	
高	https://emds.sqemc.com:8443/pub/03011407/topNav/getMessageCount	4	
高	https://emds.sqemc.com:8443/Cgztb/ProviderAssess/M02201601/KhRuleForm/KhRuleForm	3	
高	https://emds.sqemc.com:8443/Cgztb/ProviderManage/M02200201/ProviderCompare/ProviderCompareIframe	3	
高	https://emds.sqemc.com:8443/POjs/3rd/login.js	3	
高	https://emds.sqemc.com:8443/PO/version.json	3	
高	https://emds.sqemc.com:8443/PO/widgets/functionList/manifest.json	3	
高	https://emds.sqemc.com:8443/PO/widgets/messageCenter/manifest.json	3	
高	https://emds.sqemc.com:8443/PO/widgets/news/manifest.json	3	
高	https://emds.sqemc.com:8443/PO/widgets/notice/manifest.json	3	
高	https://emds.sqemc.com:8443/PubPlatform/Nav/Common/OutsiteLinkPage	2	
高	https://emds.sqemc.com:8443/PubPlatform/SysSetting/M00002105/bizparam	3	
高	https://emds.sqemc.com:8443/Pubplatform/SysSetting/M00002105/bizparam	3	
高	https://emds.sqemc.com:8443/_frontend/sea-config.js	3	
高	https://emds.sqemc.com:8443/ajax/Mysoft.PubPlatform.Nav.Handlers.WorkBenchLoginHandler/DoLogin	3	
高	https://emds.sqemc.com:8443/api/02200302/CgSolution/GetNodeList	3	
高	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.ThemeSettingsAppService/GetCustomizeThemeBySiteId	3	
高	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/BusinessModelsOP	3	
高	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/CurrentUserExistsDataMaskingRights	3	
高	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IntegrationCategoryManager	3	
高	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IsSyncProviderUser2MyUser	3	
高	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.PublicServices.OrganizationUserImpAppService/GetIntegratedLicenseUserKindTitle	3	
高	https://emds.sqemc.com:8443/gzt/oauth2/refreshToken	3	
高	https://emds.sqemc.com:8443/login	3	
高	https://emds.sqemc.com:8443/static/08dc4e04-a714-4971-86ae-2cd2852308c4/codingpage/08dc5cec-6593-4ad7-84fc-b29a58a47bd8.js	3	
高	https://emds.sqemc.com:8443/static/6807139e-1939-4353-d61e-08da49468f55/uetemplate/71b1e5d2-bd54-4d55-5099-08da4c3076e6.js	3	
高	https://emds.sqemc.com:8443/std/02200103/a43977ee-bc61-e911-9b41-001a7dda7111	3	
高	https://emds.sqemc.com:8443/std/02200105/1426487d-bfe1-ea11-9838-54e1adb0f0f	3	
高	https://emds.sqemc.com:8443/std/02200201/8713a59f-0b9a-e911-aa80-54e1adee7d63	3	
高	https://emds.sqemc.com:8443/std/02200308/08dc4246-562e-49b4-8864-54313a31b750	3	
高	https://emds.sqemc.com:8443/std/02200911/5cf49f23-3d86-ea11-aa7f-54e1ade4a50e	3	
高	https://emds.sqemc.com:8443/std/02201603/08daf383-e025-4769-846d-c6ac16e3e78b	3	
高	https://emds.sqemc.com:8443/std/02201604/08db0d8b-7f4f-4abe-863c-8da6af976f0c	3	
高	https://emds.sqemc.com:8443/std/03011401/08dc5cec-6593-4af6-8de4-8bf200fca00a	3	
高	https://emds.sqemc.com:8443/std/32010604/08dacec8-4ad1-41eb-8a87-fc79865b5b56	3	
高	https://emds.sqemc.com:8443/std/32010604/febfed58-34fc-44ee-5bc8-08dad0e746f6	3	
高	https://emds.sqemc.com:8443/std/32010650/81a01160-efa5-454f-509a-08da4c3076e6	3	
高	https://emds.sqemc.com:8443/std/32010652/08db82a4-ff76-43ff-80cd-70ffe3d0217e	3	
中	https://emds.sqemc.com:8443/	18	

中	https://emds.sqemc.com:8443/dp/bi-visual/app/index/11111111-0000-0000-0000-000000000220	1	
低	https://emds.sqemc.com:8443/dp/api/app_menu/app/get	1	
低	https://emds.sqemc.com:8443/dp/api/app_menu/app/get_relation	1	
低	https://emds.sqemc.com:8443/dp/api/home_page/list	1	
低	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/project/info	1	
低	https://emds.sqemc.com:8443/dp/bi-visual/chartlibs/components.json	2	

修订建议 17

TOC

修复任务		问题的数量	
高	发送敏感信息时，始终使用 SSL 和 POST（主体）参数。	1	
高	查看危险字符注入的可能解决方案	5	
高	禁用基于参数值指向外部站点的重定向	1	
高	配置具有适当值的Content-Security-Policy	116	
高	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常	53	
中	修改“Access-Control-Allow-Origin”头以仅获取允许的站点	2	
中	向所有敏感的 cookie 添加“Secure”属性	6	
中	将每个第三方脚本/链接元素支持添加到 SRI(Subresource Integrity)。	1	
中	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案	7	
中	添加代码交换证明密钥 (PKCE)	2	
中	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce	19	
低	向所有会话 cookie 添加“HttpOnly”属性	2	
低	将服务器配置为使用值为 DENY 或 SAMEORIGIN 的“X-Frame-Options”头	1	
低	将服务器配置为使用值为“nosniff”的“X-Content-Type-Options”头	1	
低	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。	34	
低	避免在永久 cookie 中存储敏感的会话信息	2	
低	除去 web-server 中的源代码文件并应用任何相关补丁	1	

安全风险 12

TOC

风险		问题的数量	
紧	可能会查看、修改或删除数据库条目和表	5	
高	可能会收集敏感的调试信息	53	
高	可能会窃取查询字符串中发送的敏感数据，例如用户名和密码	1	
高	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置	154	
高	可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息	121	
中	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务	4	
中	在第三方服务器被破坏的情况下，站点的内容/行为将更改。	1	
中	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄漏，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。	7	
中	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）	6	
中	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。	19	
低	可能会检索服务器端脚本的源代码，这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息	1	
低	可能会窃取保存在磁盘上作为永久 cookie 的会话信息（cookie）	2	

原因		问题的数量	
紧	未对用户输入正确执行危险字符清理	5	
高	未对入局参数值执行适当的边界检查	53	
高	未执行验证以确保用户输入与预期的数据类型匹配	53	
高	查询字符串中传递了敏感输入字段（例如用户名、密码和信用卡号）	1	
高	Web 应用程序编程或配置不安全	120	
高	Web 应用程序执行指向外部站点的重定向	1	
中	应用程序使用的认证方法不充分	21	
中	SRI(Subresource Integrity) 不受支持	1	
中	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie	7	
中	Web 应用程序通过 SSL 发送不安全的 cookie	6	
低	Web 应用程序设置了缺少 HttpOnly 属性的会话 cookie	2	
低	在生产环境中留下临时文件	1	
低	程序员在 Web 页面上留下调试信息	1	
低	未安装第三方产品的最新补丁或最新修补程序	1	
低	浏览器可能已将敏感信息高速缓存	34	
低	Web 应用程序将敏感的会话信息存储在永久 cookie 中（磁盘上）	2	

WASC 威胁分类

威胁		问题的数量	
	服务器配置错误	7	
	会话期限不足	2	
	跨站点请求伪造	19	
	权限不足	2	
	信息泄露	164	
	远程文件包含	1	
	整数溢出	53	
	SQL 注入	5	
	URL 重定向滥用	1	

按问题类型分组的问题

SQL 注入	
严重性:	紧急
CVSS 分数:	9.4
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL:	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体:	->"chart_params"[1]->"query_vars"[0]->"value_from"->"conditions"[0]->"col_value" (Parameter)
风险:	可能会查看、修改或删除数据库条目和表
原因:	未对用户输入正确执行危险字符清理
固定值:	查看危险字符注入的可能解决方案

推理： 测试结果似乎指示存在脆弱性，因为响应包含 RDBMS 错误。这表明测试设法通过注入危险字符穿透了应用程序并到达 SQL 查询本身。
未经处理的测试响应：

```
...

    }
  },
  "subtotal_row": [
    ]
  },
  "3a000f79-fd5c-595e-7b26-3534f9f8b697": {
    "errmsg": "单图 810da3e9-a6bc-11ec-8acf-117b22c26fdb 间接关联条件无法获取到数据，错误信息 [ SQL执行报错，请检查SQL脚本\nSQL执行异常详情: \nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '``[\\\"公司\\\"]\\\";' ORDER BY `idx` ASC LIMIT 0, 50000' at line 5 ] ",
    "data": [
      ],
      "marklines": [
      ],
      "conditions": [
      ],
      "msg": "单图取数接口异常，异常信息: 单图 810da3e9-a6bc-11ec-8acf-117b22c26fdb 间接关联条件无法获取到数据，错误信息 [ SQL执行报错，请检查SQL脚本\nSQL执行异常详情: \nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '``[\\\"公司\\\"]\\\";' ORDER BY `idx` ASC LIMIT 0, 50000' at line 5 ] ",
      "msg_code": 500,
      "error_code": 10000,
      "pagination": {
      },
      "sql": "",
      "sql_execute_time": "",
      "dataset_versions": {
        "data_version": ""
      }
    ],
    ...
  }
```


问题 1 / 53

TOC

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/auth/oauth2/authorize
实体:	client_id (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Accept-Language: en-US
Cookie: *=1776317276.932.87.724128|f4aafdb70292d200d9aa72f9f2bd29be
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3cbe3
Referer: https://emds.sqemc.com:8443/
Content-Length: 0

HTTP/1.1 500
Date: Thu, 16 Apr 2026 05:33:39 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains

{
  "error": "错误的客户端id或密钥",
  "detail": "",
}
```

问题 2 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData
实体：	->"expandedLevel" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"controlHandler": "",
"pageSize": 0,
"gridViewId": "appTreeGrid_View",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:35:44 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650931294830592]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/pub/03011407/topNav/getMessageCount
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

JcCjrSEar-vb7B6Iic3FgTQWljCeQlxb0l_iXytmXiZvYrTxlU4JeJUiZRoQqrClFUNSR_VjCFVLLelTRlWwaJvdmueJBDruhKJ7gYnH9tkBqi.jOR2Hwax-gGuJVqFRSp_oRm8dlvCloyKky00GBngl7L_BsMrCu-
BziCGi5iQlY9ei_4KHsKxo123F6xkF3JwaK-IARwJzmMDYzwDwdhUFSZYpZL7uynnm7lSxa3m5xKSisWg;_userHash=2021465632;
userToken_Core=CfdJ8J_vUFkn2vtEvcxULLlCFdsuaW_uzULPaLvQQjp6KsrtxW0ZsejjTlBWzyGuWa-RTWxgjbksX_RSjpa4kY-Td-QGP6iFAWA06mRCdLdluvf0d8dcd1cZY-
fGfZz531gRK4R632Js79ab0SoGmsVI-jXpcVR/n036UrmjuXFKHaYo1PSqjucNmhfTDC5Qs7Ip3fv9FkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-i59_LiX8bnhwQ11NAHmmtw5noiDYs3-
o7vMNzNqNAJ41I2v_ws0DvyLeUdv1F-Oy2dc1wBtoOjGiLLp1Pg1cBSHwqcuEeqpzuPAwWtYHaDAKoIMNa0mL90X77_1B...
```

```
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:34:09 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650531065954304]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sgemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml
实体：	_mp_metadataId (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。

未经处理的测试响应：

```
...
zmMDYzwDcdYhUFSZYpZL7uyrnm7l5xa3m5xKSI5Wg; userHash=2021465632; userToken Core=CfDJ8J_vUFkn2vtEvcuILLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejT1BWzyGJwa-RtWxgkdkbX_RSjp4kY-Td-
QGP6iFAWA0GmRcdLdluv9d4kcd1c2Y-fGfZz531gRK4R632Js79abOSoSmsVIjXpcVR7n0360tmjwXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkm-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7nMNzNgmAJ4lI2v_wsODnyLeUDv1F-Oy2dclwBtoOjGiIUplPg1oBShWgcuEegbozuPpwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb53dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:34:32 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650628185063424]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml
实体：	_mp_controlAppCode (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmVMDYzwDwdYhUFSZYpZL7uynrM7lsxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcuILLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejjT1BWzyGuIwa-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWA0GmRcIdluVx0dKcd1c2Y-fGFZz531gRK4R632Js79abOsoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4lI2v_wsODvYLeUDv1F-Oy2dc1wBtoOjGiLUplPg1oBShWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:34:35 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650640214327296]到 [异常日志]搜索异常详情。",
}
...
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml
实体：	_mp_controlFunctionPageld (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmVMDYzwDwdYhUFSZYpZL7uynrM7lsxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcuILLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejjT1BWzyGuIwa-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWA0GmRcIdluVx0dKcd1c2Y-fGFZz531gRK4R632Js79abOsoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4lI2v_wsODvYLeUDv1F-Oy2dc1wBtoOjGiLUplPg1oBShWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
```

```
Date: Thu, 16 Apr 2026 05:34:35 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650641799774208]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml
实体：	_mp_controlBelongFunctionCode (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uyrnm7lxxa3m5xKSIsWg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLvOQQjp6KsrtxW0ZsejJTlBWzyGuWa-RTWxgkbksX_RSjp4kY-Td-
QGP6iFAWAOGmRCdLdluvKxK9kd1lc2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7h036UdmjwXFKHaYo1PSqjucNMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqqBjLHoxSicB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmA741I2v_wsODvryLeUDv1F-Oy2dclwBtoOjGiILJplPgloBSHWqcuEqgbzuPAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:34:37 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650651178237952]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjax-Handler/LoadData
实体：	pageId (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"conditionType": "load",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"paginationType": "default"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:35:59 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650995773865984]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjax-Handler/LoadData
实体：	->"pageIndex" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"conditionType": "load",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
```

```
"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"paginationType": "default"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:36:00 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650997048934400]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sgemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/LoadData
实体:	->"pageSize" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"conditionType": "load",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"paginationType": "default"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:36:02 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044651008574881792]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出

严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData
实体:	->"pageSize" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...  
"controlHandler": "",  
"pageSize": 999999999999999999,  
"gridViewId": "appTreeGrid_View",  
"functionCode": "32010602",  
"realFunctionCode": "",  
"realPageId": "",  
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73dl"  
}  
  
HTTP/1.1 500 Internal Server Error  
Date: Thu, 16 Apr 2026 05:35:48 GMT  
Content-Type: application/json; charset=utf-8  
Transfer-Encoding: chunked  
Connection: keep-alive  
Strict-Transport-Security: max-age=31536000; includeSubDomains  
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443  
  
{  
  "message": "系统发生异常,请使用错误编号 [2044650949867208704]到[异常日志]搜索异常详情。",  
...}
```

整数溢出

严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData
实体:	->"functionCode" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...  
"controlHandler": "",  
"pageSize": 0,  
"gridViewId": "appTreeGrid_View",  
"functionCode": "99999999999999999999"
```

```
"realFunctionCode": "",
"realPageId": "",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:35:49 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650950852870145]到 [异常日志]搜索异常详情。",
  ...
}
```

问题 13 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetFianFinancePlanSettings
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynnM7lsxa3m5xKSIswg; userHash=2021465632; userToken Core=CfDJ8J vUFkn2vtEvcouLLlCfdswaW uzULPaIvoQQjp6KsrtxwQZsejjTlBWzyGuWa-RTWxgkbksX_RSjp4KY-Td-
QGP6iFAWAQ6nRcdlduv6x6kcdlc2Y-fGfZz53lgRk4R632Js79abOSoSmsVIjXpcvR7n036UzmjwXFKHaYo1PSgjudMhftDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWkLaPAJSPAq4aUoTqgBjLHoxSioB72N8nk4-
i59_LiX8bnhwQl1lNAHmtw5noiDys3-o7vMNzNgmAJ4l1I2v wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUjP1Pg1oBShWqcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:35:15 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650811140603904]到 [异常日志]搜索异常详情。",
  ...
}
```

问题 14 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData
实体：	pageId (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"controlHandler": "",
"pageSize": 0,
"gridViewId": "appTreeGrid_View",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:35:16 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650812889628672]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData
实体：	->"pageIndex" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"controlHandler": "",
"pageSize": 0,
"gridViewId": "appTreeGrid_View",
"functionCode": "32010602",
```

```
"realFunctionCode": "",
"realPageId": "",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:35:16 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044650814575738880]到 [异常日志]搜索异常详情。",
  ...
}
```

问题 16 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/32010604/MoneyPlanReportGroup/GetMoneyPlanGroupApprovalData
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynnM7lxa3m5xKSIswg; userHash=2021465632; userToken Core=CfDJ8J vUFkn2vtEvcouLLlCfdswaW uzULPaIvoQQjp6KsrtxWQZsejjTlBWzyGuWa-RTWxgkbksX_RSjp4KY-Td-
QGP6iFAWAQ6nRcdlduv6x6kcdlc2Y-fGfZz531gRk4R632Js79ab0SoSmsVIjXpcvR7n036UzmjwXFKHaYo1PSGjudMhfTDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWkLaPAJSPAq4aUoTggBjLHoxSioB72N8nk4-
i59_LiX8bnhwQl1lNAHmtw5noiDys3-o7vMNzNgmAJ4l1I2v wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUjLPg1oBShWgcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:37:19 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044651330328330240]到 [异常日志]搜索异常详情。",
  ...
}
```

问题 17 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetMoneyPlanParamValue
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lxxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuiLLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejJT1BWzyGuWia-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWAOGmRcdLduvKodKcd1c2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4lI2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUj1Pg1oBShWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:38:25 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044651606288367616]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetMoneyPlanParamValue
实体：	buGuid (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lxxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuiLLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejJT1BWzyGuWia-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWAOGmRcdLduvKodKcd1c2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4lI2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUj1Pg1oBShWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
```

```
"message": "系统发生异常,请使用错误编号 [2044651607156588544]到[异常日志]搜索异常详情。",
...
```

严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/LoadData
实体:	->"functionCode" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

```

..
"conditionType": "load",
"functionCode": "999999999999999999999999",
"realFunctionCode": "",
"realPageId": "",
"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"paginationType": "default"
}

```

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:36:19 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044651080175845376]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/03011407/setting/page/config
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
NSR_VjCFVlLe1TRlWwaJvdmueJBDruhKU7gYNh9tkBgijOR2Hwax-gGuJVqFRSp_oRm8dLvClOYkcy00GBngl7L_BsMnOu-BZiCGi5iQLY9ei_4KHsKxo123RwxF3JwaK-
IARwJzmMDYzwDwdYhUFSZYpZL7uynnM7lsxa3m5xKSiSwg; LoginTenant=qhgg; LoginSite=fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3; userHash=2021465632;
userToken_Core=CfDJ8J_vUfkn2vtEvcxuLLlCfDsuaW_uzULPaLVoQQjp6KertxW0ZsejjTlBWzyGuWa-RTWxgkbksX_RSjp4kY-Td-QGP6ifAWAO6mRCdLdluvKdKdLc2Y-
fGfZz531gRk4R632Js79abQSoGmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjucNMhfTdc5Qs7Ip3fv9fkiUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAg4aUoTqgBjLHoxSiob72N8nkM-i59_LiX8bnhwQ1lNAHmtw5noiDYs3-
o7vMnZNgmAJ4LI2v_wsODvyLeUDv1F-Oy2dc1wBtoOjGiUJp1Pg1oBSHwqcuEeqbzPawWtYHaDAKoIMNaOmL90X77_1B...
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:45:43 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

<!DOCTYPE html>
<html>
...
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppCardAjaxHandler/LoadData
实体：	->"options"->"pageIndex" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
}
},
"functionCode": "02201603",
"pageId": "08daf383-e025-474d-88d8-6479941a63c6",
"realFunctionCode": "",
"realPageId": ""
}
```

```
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:45:58 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653507541204992]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL：	https://emds.sqemc.com:8443/api/02209901/Common/enableRiskMain
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。

未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uyrnm7l1sxa3m5xKSI5Wg;_userHash=2021465632;userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLVoQQjp6KsrtxW0ZsejjT1BWzyGuWa-RTWxgjdkX_RSjp4kY-Td-
QGP6iFAWAOGmRCdldluV4o4kcdlc2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSgjuclMhfTDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQllNAHmtw5noiDYs3-o7vMNzNgmAJ41I2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUjplPg1oBShWqcuEegbzPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:42:41 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044652680747417600]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200201/Provider/enableYcg
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMMDYzwDwdYhUFSZYpZL7uynrM7lsxa3m5xKSI5Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxulLLCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejJT1BWzyGuIwa-RTWxgjdksX_RSjp4kY-Td-
QGP6iFAWA0GmRcdLduvK6dKcd1c2Y-fGFZz531gRK4R632Js79abOsoSmsVIjXpcvR7n036UrtMjuXFKHaYo1PSgjudMhftDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWkLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4lI2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUj1Pg1oBShWqcuEeqbzpuPAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:42:42 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044652683536629760]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppCardAjaxHandler/LoadData
实体：	->"options"->"pageSize" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
}
},
"functionCode": "02201603",
"pageId": "08daf383-e025-474d-88d8-6479941a63c6",
"realFunctionCode": "",
"realPageId": ""
}
```

```
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:46:01 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653519742435328]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppCardAjaxHandler/LoadData
实体:	->"options"->"functionCode" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。

未经处理的测试响应：

```
...

}
},
"functionCode": "18446744073709551617",
"pageId": "08daf383-e025-474d-88d8-6479941a63c6",
"realFunctionCode": "",
"realPageId": ""
}
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:46:05 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653536104415232]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjax-Handler/GetHtml
实体：	_mp_controlFunctionPageld (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lxxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxulLLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejJT1BWzyGuWa-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWAOGmRcdLduvKdKcdlc2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4l1I2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUplPg1oBShWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:46:31 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653645361840128]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjax-Handler/GetHtml
实体：	_mp_controlAppCode (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lxxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxulLLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejJT1BWzyGuWa-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWAOGmRcdLduvKdKcdlc2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4l1I2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUplPg1oBShWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
```

```
Date: Thu, 16 Apr 2026 05:46:31 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653645353451520]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGrid/Ajax-Handler/GetHtml
实体：	_mp_metadataId (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。

未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uyrnm7lxxa3m5xKSIsWg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLvOQQjp6Krtxw0ZsejTLEWzyGuWa-RTWxgkbksX_RSjp4kY-Td-
QGP6iFAWAOGnRCdLdluvKxKcd1c2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UdmjwXFKHaYo1PSqjucMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqqBjLHoxSicB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmA741I2v_wsODvyLeUDv1F-Oy2dclwBtoOjGiILp1PgloBSHWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:46:32 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653648696311808]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/GetHtml
实体：	_mp_clientID (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lxxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxULLlCfDsuaW_uzULPaLVoQQjp6KsrtxWOZsejjT1BWzyGuWa-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWAOGmRcIdluvKodKcd1c2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4l1I2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUj1Pg1oBShWqcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:46:32 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653648973135872]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02201601/KhRule/GetUsedProviderTypeInfo
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lxxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxULLlCfDsuaW_uzULPaLVoQQjp6KsrtxWOZsejjT1BWzyGuWa-RTWxgjdoksX_RSjp4kY-Td-
QGP6iFAWAOGmRcIdluvKodKcd1c2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmAJ4l1I2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUj1Pg1oBShWqcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
```

```
Date: Thu, 16 Apr 2026 05:46:36 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653664357842944]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sgemc.com:8443/api/02201601/KhRule/GetKhRuleList
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。

未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uyrnm7l5xa3m5xKSIswg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLvOQQjp6Krtxw0ZsejJTlBWzyGuWa-RTWxgkbksX_RSjp4kY-Td-
QGP6iFAWAOGmRCdLdluvKxKcd1lc2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR7n036UdmjwXFKHaYo1PSqjucNMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqqBjLHoxSicB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMNzNqmA741I2v_wsODvyLeUDv1F-Oy2dclwBtoOjGiIJlp1PgloBSHWqcuEqgbzuPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:46:36 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653664550780928]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/GetHtml
实体：	_mp_controlFunctionCode (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lxxa3m5xKSI5Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxulLLlCfDsuaW_uzULPaLVoQQjp6KsrtxW0ZsejjT1BWzyGuWa-RTWxgjdkX_RSjp4kY-Td-
QGP6iFAWA0GmRcldluV6x6kd1c2Y-fGFZz531gRK4R632Js79abOsoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjudMhftDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWkLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1lNAHmtw5noiDys3-o7vMNzNgmAJ4l1I2v_wsODvYLeUDv1F-Oy2dc1wBtoOjGiLUj1Pg1oBShWqcuEeqbzupAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:46:49 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653721194856448]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetCacheManager
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
31aiZxN75bDP-
CvYfb_Ivbm442BgZ7hgnLxwIAClrmYXQMqpnNQDsFGyu5UaEb4pbhW9fp4mntYzke7KugH31v6qKdXyoYAe5fKwfgkqE2aaLtwH67taSvrzdt_Gv0wJZMcnt94ZFT5YHGQpLIY5cd30DeTLHF2XMDztcox6op4Oy98zGLIYIMCPWWTs
VnF3tIXjFiJvQ
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 30

{
  "ST": 1776314224982,
```

```

    "Total": 0
  }

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:44:00 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653011774472192]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sgemc.com:8443/api/02200201/ProviderGlobalSearch/SetCacheManager
实体:	->"Total" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。

未经处理的测试响应：

```

...
31aiZxN75bDP-
CvYb_IWx442BgZ7hgnLxwIACltmyX6MGpNNQDsFGyu5Uafb4pbhW9fp4mtYzke7KugH3lv6qKdXyoYAe5fKwfgkpeE2aaLTwh67taSwrdzt_Gv0wJZMCnt94ZFT5YHGQpLIY5d30DeTLHf2XMDztcox6op4Oy98zG1IYIMCPWWTs
VnF3tIXjFiJvQ
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Content-Length: 49

{
  "ST": 1776314224982,
  "Total": 9999999999999999999
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:44:02 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653018619576320]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetExportParam
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmVMDYzwDwdYhUFSZYpZL7uynrM7lxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxULLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejJT1BWzyGuIwa-RTWxgjdksX_RSjp4kY-Td-
QGP6iFAWA0GmRcdLduvKdKcd1c2Y-fGFZz531gRK4R632Js79abOsoSmsVIjXpcvR7n036UrtMjuXFKHaYo1PSgjudMhftDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWkLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8brnhwQl1NAHmtw5noiDYs3-o7vMNzNqmAJ41I2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUjplPg1oBShWqcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:44:04 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653029801590784]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect
实体：	->"param"->"application" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
{
  "defaultSelectMode": "first",
  "dynamicTree": true,
  "projGUID": null,
  "isFirstLoad": true,
  "functionCode": "32010602",
  "pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
}
```

```
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:44:42 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653188040097792]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect
实体:	->"param"->"displayType" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。

未经处理的测试响应：

```
...

{
  "defaultSelectMode": "first",
  "dynamicTree": true,
  "projGUID": null,
  "isFirstLoad": true,
  "functionCode": "32010602",
  "pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:44:45 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653202611109888]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect
实体：	->"param"->"filterType" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...  
  
  "defaultSelectMode": "first",  
  "dynamicTree": true,  
  "projGUID": null,  
  "isFirstLoad": true,  
  "functionCode": "32010602",  
  "pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"  
}  
}  
  
HTTP/1.1 500 Internal Server Error  
Date: Thu, 16 Apr 2026 05:44:47 GMT  
Content-Type: application/json; charset=utf-8  
Transfer-Encoding: chunked  
Connection: keep-alive  
Strict-Transport-Security: max-age=31536000; includeSubDomains  
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443  
  
{  
  "message": "系统发生异常,请使用错误编号 [2044653209108086784]到 [异常日志]搜索异常详情。",  
}  
...
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect
实体：	->"param"->"inherit" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...  
  
  "defaultSelectMode": "first",  
  "dynamicTree": true,  
  "projGUID": null,  
  "isFirstLoad": true,
```

```

    "functionCode": "32010602",
    "pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
  }
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:44:54 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653236429783040]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sgemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect
实体:	->"param"->"functionCode" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```

...

{
  "defaultSelectMode": "first",
  "dynamicTree": true,
  "projGUID": null,
  "isFirstLoad": true,
  "functionCode": "999999999999999999999999",
  "pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1"
}
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:45:05 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653284169351168]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjax-Handler/GetHtml
实体：	_mp_controlBelongFunctionCode (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMMDYzwDwdYhUFSZYpZL7uynnM7lsxa3m5xKSI$Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLVoQQjp6KsrtxW0ZsejjTlBWzyGuWa-RTWxgkbksX_RSjp4kY-Td-QGP6iFAWA0GmRCdLduvKx4xkd1c2Y-fGFZz531gRK4R632Js79abOsoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjucNmfTdc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSiob72N8nkM-i59_LiX8bnhwQ1lNAHmtw5noiDYs3-o7vMnzNqmAJ4lI2v_wsODvYLeUDv1F-Oy2dclwBtoOjGiLUjPlPgloBShWqcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:47:02 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653774676426752]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/03011407/setting/globalCss
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
NSR_VjCFVlLe1TRlWwaJvdmeJBDRuhKlU7gYNh9tkBgijOR2Hwax-gGuJVgFRSp_oRm8dLvClOYkcyO0GBngl7L_BsMmOu-BZiCGi5iQlY9ei_4KHsKxo123RwF3JwaK-
IARwJzmMDYzwDwdYhUFSZYpZL7uynnM7lsxa3m5xKSI$Wg; LoginTenant=qhgg; LoginSite=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3; _userHash=2021465632;
userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLVoQQjp6KsrtxW0ZsejjTlBWzyGuWa-RTWxgkbksX_RSjp4kY-Td-QGP6iFAWA0GmRCdLduvKx4xkd1c2Y-
fGFZz531gRK4R632Js79abOsoSmsVIjXpcVR7n036UrtMjuXFKHaYo1PSqjucNmfTdc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSiob72N8nkM-i59_LiX8bnhwQ1lNAHmtw5noiDYs3-
o7vMnzNqmAJ4lI2v_wsODvYLeUDv1F-Oy2dclwBtoOjGiLUjPlPgloBShWqcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
Content-Length: 0
```

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:45:20 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

<!DOCTYPE html>
<html>
...
```

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjax-Handler/LoadData
实体:	resFilterKeyType (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"conditionType": "load",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727dd6-b74c-47dd-233f-08da7feb73d1",
"paginationType": "default"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:47:10 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653809312989184]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200307/CgSolutionSimple/GetNodeList
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMMDYzwDwdYhUFSZYpZL7uyrnm7l5xa3m5xKSI5Wg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxulLLlCfDsuaW_uzULPaLVoQQjp6KsrtxWOZsejJT1BWzyGuIwa-RTWxgjdksX_RSjp4kY-Td-
QGP6iFAWA0GmRcdLuvKx6kcd1c2Y-fGFZz531gRK4R632Js79abOsoSmsVIjXpcvR7n036UrtMjuXFKHaYo1PSgjudMhftDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWkLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQl1NAHmtw5noiDys3-o7vMNzNqmAJ41I2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUjplPg1oBShWqcuEeqbzpuPAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:47:12 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653815436673024]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjax-Handler/LoadData
实体：	BUGUID (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
"conditionType": "load",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"paginationType": "default"
```

```
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:47:23 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653862769393664]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/LoadData
实体:	->"options"->"filters"[0]->"condition"[0]->"value" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"conditionType": "load",
"functionCode": "32010602",
"realFunctionCode": "",
"realPageId": "",
"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"paginationType": "default"
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:47:42 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044653942142402560]到 [异常日志]搜索异常详情。",
  ...
}
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.Controls.SubControls.FilterAppService/LoadFilter
实体：	resFilterKeyType (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"options": {
  "filters": [

  ]
}
}
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:49:59 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044654518397829120]到 [异常日志]搜索异常详情。",
}

...
```

问题 48 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.Controls.SubControls.FilterAppService/LoadFilter
实体：	BUGUID (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...

"metadataId": "d60bc42b-af3f-4fc2-2347-08da7feb73d1",
"pageId": "c727ddf6-b74c-47dd-233f-08da7feb73d1",
"options": {
  "filters": [

  ]
}
}
}

...
```

```
    ]
  }
}

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:50:08 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044654553881640960]到 [异常日志]搜索异常详情。",
  ...
}
```

问题 49 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02201204/BaseBidPriceAdjust/IsAdmin
实体：	[NUMERIC] (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uyrnM7lxa3m5xKSIswg; userHash=2021465632; userToken Core=CfDJ8J vUFkn2vtEvcouLLlCfdswaW uzULPaIvoQQjp6KsrtxWQZsejjTlBWzyGuWa-RTWxgkbksX_RSjp4KY-Td-
QGp6iFAWA0GmRcdlduv6x6kcdlc2Y-fGfZz53lgRk4R632Js79ab0SoSmsVIjXpcvR7n036UzmjwXFKHaYo1PSGjudMhftDc5Qs7Ip3fv9fkUjOx8g8wUJo9ueZSOBLcWIKLaPAJSPAq4aUoTggBjLHoxSioB72N8nkM-
i59_LiX8bnhwQl1lNAHmtw5noiDys3-o7vMNzNgmAJ4l1I2v wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUjP1Pg1oBShWgcuEeqbzupAwWtYHaDAKoIMNaUmL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:50:14 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044654580079263744]到 [异常日志]搜索异常详情。",
  ...
}
```

问题 50 / 53

TOC

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.SiteRedirectAppService/RedirectFunctionHomePageWithoutToken
实体：	functionId (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lsxa3m5xKSIsWg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejjTlBWzyGuWa-RTWwgjdxksX_RSjp4kY-Td-
QGP6iFAWAOGmRCdLdluvKd4kcd1c2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR/n036UrtMjuXFKHaYo1PSgjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQl1NAHmtw5noiDYs3-o7vMNzNgmAJ41I2v_wsODvryLeUDv1F-Oy2dcLwBtoOjGiLUjp1Pg1oBShWqcuEeqbzPuAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:50:58 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

<!DOCTYPE html>
<html>
...
```

整数溢出	
严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.SiteRedirectAppService/RedirectFunctionHomePageWithoutToken
实体：	_hid (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
zmMDYzwDwdYhUFSZYpZL7uynrM7lsxa3m5xKSIsWg; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEvcxuLLlCfDsuaW_uzULPaLVoQQjp6KsrtxwOZsejjTlBWzyGuWa-RTWwgjdxksX_RSjp4kY-Td-
QGP6iFAWAOGmRCdLdluvKd4kcd1c2Y-fGFZz531gRK4R632Js79abOSoSmsVIjXpcVR/n036UrtMjuXFKHaYo1PSgjudMhftDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiKLaPAJSPAq4aUoTqgBjLHoxSioB72N8nkM-
i59_LiX8bnhwQl1NAHmtw5noiDYs3-o7vMNzNgmAJ41I2v_wsODvryLeUDv1F-Oy2dcLwBtoOjGiLUjp1Pg1oBShWqcuEeqbzPuAwWtYHaDAKoIMNa0mL90X77_1B...
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Content-Length: 0

HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:51:00 GMT
```

```
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

<!DOCTYPE html>
<html>
...
```

严重性:	高
CVSS 分数:	8.6
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体:	->"chart_params"[3]->"pagination"->"page" (Parameter)
风险:	可能会收集敏感的调试信息
原因:	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值:	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

未经处理的测试响应:

```
...
},
"error_code": null,
"execute_status": 500,
"extra_data": [

],
"marklines": [

],
"msg": "SQL执行报错, 请检查SQL脚本\nSQL执行异常详情: \nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1500000000000000000000, 152' at line 4",
"msg_code": 5002,
"orderby": [
{
"col_name": "JCAMOUNT_14845351691",
"content": {

},
"dataset_field_id": "3a10273b-7211-17b7-3484-09a35bf1916b",
"field_source": "num",

}
]
}
...

```

整数溢出

严重性：	高
CVSS 分数：	8.6
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL：	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体：	->"chart_params"[4]->"pagination"->"page" (Parameter)
风险：	可能会收集敏感的调试信息
原因：	未对入局参数值执行适当的边界检查 未执行验证以确保用户输入与预期的数据类型匹配
固定值：	验证参数值是否在其预计范围和类型内。不要输出调试错误消息和异常

推理： 应用程序以错误消息响应，表示可能会泄露敏感信息的未定义状态。
未经处理的测试响应：

```
...
},
"error_code": null,
"execute_status": 500,
"extra_data": [

],
"marklines": [

],
"msg": "SQL执行报错, 请检查SQL脚本\nSQL执行异常详情: \nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1500000000000000000000000000000000, 150' at line 22",
"msg_code": 5002,
"orderby": [
{
"col_name": "PLANACHIEVEMENTRATE_19534060394",
"content": {

},
"dataset_field id": "3a10273b-7211-1deb-19a0-6e8f5392f297",
"field_source": "num",

}
]
}
...

```

高

查询中的密码参数 ①

TOC

问题 1 / 1

查询中的密码参数

严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02201601/KhRule/GetKhRuleList
实体：	keywords (Parameter)
风险：	可能会窃取查询字符串中发送的敏感数据，例如用户名和密码
原因：	查询字符串中传递了敏感输入字段（例如用户名、密码和信用卡号）
固定值：	发送敏感信息时，始终使用 SSL 和 POST （主体）参数。

推理: AppScan 识别出查询字符串中接收到的密码参数
原始请求

```
...
POST /api/02201601/KhRule/GetKhRuleList?keywords= HTTP/1.1
Host: emds.sqemc.com:8443
Connection: keep-alive
Content-Length: 0
X-Page-RequestId: {61f15c3833db4115b53a405d93cbd526}
sec-ch-ua-platform: "Windows"
x-reg-signature: fV0E6ug65S3MxEt8JwgW0NB54vhjTA0EW1YUdgQA1e0=
X-Gzip-Respond: 1
sec-ch-ua: "Not-A.Brand";v="24", "Microsoft Edge";v="146", "Chromium";v="146", "Microsoft Edge WebView2";v="146"
x-reg-timestamp: 1776314236382
...
```

问题 1 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/login
实体：	login (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:55 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 833ff3a841954cc2afc8be6e3b5dd57d
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

问题 2 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/version.json
实体：	version.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:58 GMT
Content-Type: application/json
Content-Length: 26
Connection: keep-alive
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "1a"
x-fast-trace-id: fef3f097428846eb816b476664efc7b3
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie:
platform_user_token=eyJraWQiOiJ4YyIxaGdhLWlkYyIsImFsZyI6ImlJTMjU2In0.eyJ1bmYiOiJlZ3NzYzZMTcyNzgsInVzZ2JfY29kZSI6ImFkbWluIiwic2Nlc19uYW11IjoiaH0cH
M6XC9cL2VtZlFmM3F1bW4y29tOjg0NDNcL2FldGgiLCJlc2VyX2dlaWQiOiI0MjMwM2ZS02OWU2LTQ2YTktYTM5ZS1iOTI5YTA2YTg0ZTg1LjZb3VvY2U0IiwiaWYyIsImV4cCI6MTc3NjMzNTMzOCwidG9rZW5fdHlwZSI6ImFj
Y2Vzcl90b2t1biIsImhhdCI6MTc3NjMzNTMzOCwidG9rZW5fdHlwZSI6ImFj
...

```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/pub/03011407/topNav/getMessageCount
实体：	getMessageCount (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:58 GMT
Content-Type: application/json
Content-Length: 98
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
x-fast-trace-id: 83b97d67b3ba4245bf46dcb878f5bab5
X-ERP-Version: 600

```

问题 4 / 58

TOC

缺少必需的CSP指令

严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/gzt/oauth2/refreshToken
实体：	refreshToken (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```

HTTP/1.1 302 Found
Date: Thu, 16 Apr 2026 05:28:59 GMT
Content-Length: 0
Connection: keep-alive
Location: /login?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Fends.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Fends.sqemc.com%253A8443%252Fpapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7dce3002734%26client_id%3Dplatform-x-fast-trace-id: e2ec86a20ddd4911b5a3247d9dd78791
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

GET /login?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Fends.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Fends.sqemc.com%253A8443%252Fpapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7dce3002734%26client_id%3Dplatform HTTP/1.1
Cookie: *=1776317276.932.87.724128|f4aafcb70292d200d9aa72f9f2bd29be
Accept-Language: en-US
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3bbe3
Referer: https://ends.sqemc.com:8443/gzt/oauth2/refreshToken?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Fends.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Fends.sqemc.com%253A8443%252Fpapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7dce3002734%26client_id%3Dplatform

```

问题 5 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/std/03011401/08dc5cec-6593-4af6-8de4-8bf200fca00a
实体：	08dc5cec-6593-4af6-8de4-8bf200fca00a (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:00 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: 64d8db9712ae430a86fc0917e9815f5e
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: _userHash=2021465632; expires=Fri, 16 Apr 2027 05:29:00 GMT; path=/
Set-Cookie: userToken_Core=CfdJ8J_vUFkn2vtEvcouLLlCfdmvmzd008BrNne6ASM_jBcktntRhcdMvLTy_DzFAwFWHrUCKUw_9-
JPIYagVhBHQRWuLKORw9DpSFmSBI3dwf5yyPwOuHkNMZfYyBNes8Kz99j97zg7yNgS7HLehGIHG3b1V-qPHtQS9G3-Ihoo476Pzg90Th9en3GXlg0XaUX3fgp23cko6mmiryza88AD1KkDOKyqUMvAu6-z-
JtBmatGoledK863zhPfoIEHS0HGMVcnafCImNKK67sMxb5ezgSNLJUfocceRrvksuee4URKzCTKafEz4UdhIyhtZnAf2ApG_akuiQkpF4YPsFWducatXavGgiE-Ot4_1RUMs2CvJSTWw... path=/; httponly

...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.PubPlatform.Nav.Handlers.WorkBenchLoginHandler/DoLogin
实体：	DoLogin (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:01 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 36722be3c3cf4727adceb4ba92880f99
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: emcLanguage=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/
```

问题 7 / 58

TOC

缺少必需的CSP指令

严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/PO/widgets/news/manifest.json
实体:	manifest.json (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了

未经处理的测试响应:

```

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:06 GMT
Content-Type: application/json
Content-Length: 816
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "330"
x-fast-trace-id: b2900c2550a048cf861e0f723ca97abd
X-ERP-version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgcnc.com:8443

{

"name": "企业新闻",
...

```

问题 8 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/widgets/notice/manifest.json
实体：	manifest.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 819
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "333"
x-fast-trace-id: 09509a8ceee641b59362f2a77e654bee
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

  "name": "企业公告",
  ...
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/widgets/functionList/manifest.json
实体：	manifest.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 187
Connection: keep-alive
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "bb"
```

```
x-fast-trace-id: 480bc0cad30e45df956dc1d477f75ca3
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

"name": "常用功能",
...
}
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/PO/widgets/messageCenter/manifest.json
实体:	manifest.json (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 486
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "1e6"
x-fast-trace-id: 56d6fbd76dcc47cc9863723f50be2152
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

"name": "消息中心",
...
}
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/std/32010650/81a01160-efa5-454f-509a-08da4c3076e6
实体:	81a01160-efa5-454f-509a-08da4c3076e6 (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:13 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 18f9241405984c559211987e6d3e5b4a
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml
实体:	GetHtml (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:16 GMT
Content-Type: text/html
Content-Length: 34577
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=86400
x-fast-trace-id: e080fe0632e947628e28a1200f3e33dd
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/GetHtml
实体：	GetHtml (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保険号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:29:17 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044649306350157824]到 [异常日志]搜索异常详情。",
  "html": "<!DOCTYPE html>\n<html>\n  <head>\n    <meta http-equiv=\"Content-Type\" content=\"text/html; charset=utf-8\" />\n    <title>思源云ERP</title>\n    <meta http-equiv=\"X-UA-Compatible\" content=\"IE=Edge\" />\n    <meta name=\"renderer\" content=\"webkit\" />\n    <script>\n      document.writeln('<link rel=\"shortcut icon\" href=\"/ajax/Mysoft.PubPlatform.Nav.Handlers.LoginHandler/SiteIcon? t=60302959\"/>');\n    </script>\n    <style type=\"text/css\">\n      body {\n        margin: 0;\n        padding: 0;\n        color: #222;\n        font-family: \"PingFang SC\", \"Microsoft Yahei\", Verdana, simsun, Arial, Helvetica, sans-serif;\n        font-size: 14px;\n      }\n      body.error-page-wrapper .error-page-details {\n        top: 8px;\n      }\n      ::-webkit-scrollbar-thumb:vertical,\n      ::-webkit-scrollbar-thumb:horizontal {\n        background-color: rgba(0, 0, 0, 0.12);\n        border-radius: 3px;\n      }\n      a,\n      a:link {\n        color: #266eff;\n      }\n      a:hover {\n        text-decoration: none;\n      }\n      .error-page-desc {\n        text-align: center;\n        position: absolute;\n        height: 264px;\n        top: 50%;\n        margin-top: -132px;\n        width: 100%;\n      }\n      .error-page-desc p {\n        margin: 0;\n        margin-bottom: 8px;\n        line-height: 14px;\n        color: #999;\n        font-size: 13px;\n      }\n      .error-page-desc _icon {\n        width: 278px;\n        height: 125px;\n        display: inline-block;\n        background: url(data:img/jpg;base64,iVBORw0KGgoAAAANSUHEUgAAARYAAAB9CAYAAABnClxiAAAAAANSR0IARs4c6QAMFZJREFUeAhtnQmczdK7x++MZcZ09pClSWYnkKtSIlEst0iX9GmfyV+2kv0a6eQJvTk1F8SQmi-jQNUwyK4IQQxcj/78/87uj0+Pu9/u9c8ec7+17vd7v99zrvOc5zzn0c95znPoiXK3y1DAUMAvQpw/fz56/PjxLc+ePVs7W7Zs9QgVo6KiSvK+2Llz5wzcPob/5wF2rns5wtno6Gd3PfWfeuZM2c2c4/Pnj376rvuumu3X5lm0kRmRRvg7ahg00UQGBevffeev0Qd0QIr...
      }
    </style>\n  </head>\n  <body>\n    <div class=\"error-page-wrapper\">\n      <div class=\"error-page-details\">\n        <div class=\"error-page-desc\">\n          <p></p>\n          <div class=\"error-page-desc _icon\"></div>\n        </div>\n      </div>\n    </body>\n  </html>
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.Controls.SubControls.FilterAppService/LoadFilter
实体：	LoadFilter (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保険号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:29:17 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
```

```
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044649306782171136]到 [异常日志]搜索异常详情。",
  "html": "<html>\n  <head>\n    <title>ERP错误报告</title>\n    <meta http-equiv=\"X-UA-Compatible\" content=\"IE=Edge\" />\n    <script>\n      document.writeln('<link\nrel=\"shortcut icon\" href=\"/ajax/Mysoft.PubPlatform.Nav.Handlers.LoginHandler/SiteIcon?_t=20173646\"/>');\n    </script>\n    <style>\n      body {\n        font-family:\n        \"PingFang SC\", \"Microsoft Yahei\", Verdana, simsun, Arial,\n        Helvetica, sans-serif;\n      }\n      .error-text {\n        position: relative;\n        top:\n        10px;\n        font-size: 18px;\n        color: #333333;\n        font-style: normal;\n        font-weight: 400;\n        line-height: 26px;\n        font-family: \"PingFang\nSC\", \"Microsoft Yahei\", Verdana, simsun, Arial,\n        Helvetica, sans-serif;\n      }\n      .error-header {\n        font-size:\n        16px;\n        color: #222;\n        margin-top: 15px;\n      }\n      .error-reason {\n        font-size: 14px;\n        color: #999;\n        line-height: 20px;\n        margin-top: 10px;\n      }\n      .error-content {\n        text-align: center;\n      }\n      .error-content_inner {\n        display: inline-block;\n        text-align:\n        left;\n      }\n      .error-des_one {\n        margin-top: 5px;\n        text-align: left;\n        font-size: 14px;\n        color: #999;\n      }\n      .error-page .online-errorTip {\n        display: block;\n        margin: 0;\n        margin-\ntop: 20px;\n        color: #999;\n        font-size: 13px;\n        line-height: 22px;\n      }\n      .error-page a {\n        color: #266eff;\n        text-decoration:\n        none;\n      }\n      .error-page a:hover {\n        text-decoration: underline;\n      }\n      .quick-switch {\n        padding: 5px 12px;\n        justify-content:\n        center;\n        align-items: center;\n        border-radius: 4px;\n        background: #266eff;\n        border: none;\n        ...
    }
  }
}
```

问题 15 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:U/UI:N/S:U/C:H/L:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect
实体：	GetProjectSelect (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:42 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: d81fc4c6e18f4fe18c34b042a5a6645a
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

[
  {
    "isLeaf": true,
    "isSelected": false,
    "isAllowSelect": false,
    ...
  }
]
```

问题 16 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetFianFinancePlanSettings
实体：	GetFianFinancePlanSettings (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:34 GMT
Content-Type: application/json
Content-Length: 302
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: a548a992d9ac41dd9ddbdc738d182475
X-ERP-Version: 600
x-my-TraceID: a548a992d9ac41dd9ddbdc738d182475
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  ...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData
实体：	LoadData (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:29:23 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
```


缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/std/32010604/08dacec8-4ad1-41eb-8a87-fc79865b5b56
实体:	08dacec8-4ad1-41eb-8a87-fc79865b5b56 (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:29 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: dc004a701c4b47128e2b00527861854e
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/32010604/MoneyPlanReportGroup/GetMoneyPlanGroupApprovalData
实体:	GetMoneyPlanGroupApprovalData (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:14 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: ded9ecee9616427d8b54269f777b36e3
X-ERP-Version: 600
x-my-TraceID: ded9ecee9616427d8b54269f777b36e3
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

```
{
  "code": "0",
  ...
}
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetMoneyPlanParamValue
实体:	GetMoneyPlanParamValue (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:34 GMT
Content-Type: application/json
Content-Length: 70
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 1f41e11310bd4fd38c9d5a29f91796d7
X-ERP-Version: 600
x-my-TraceID: 1f41e11310bd4fd38c9d5a29f91796d7
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/std/32010652/08db82a4-f76-43ff-80cd-70ffe3d0217e
实体:	08db82a4-f76-43ff-80cd-70ffe3d0217e (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:37 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: eec303af6a5742659c3c3b572836c398
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL:	https://emds.sgemc.com:8443/std/02200103/a43977ee-bc61-e911-9b41-001a7dda7111
实体：	a43977ee-bc61-e911-9b41-001a7dda7111 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:49 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: f51cbd54d09d4f0a942a910538664766
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL:	https://emds.sgemc.com:8443/PubPlatform/SysSetting/MD0002105/bizparam
实体：	bizparam (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:55 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: d1f8dc4691b24a71af3fb3c781033033
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL:	https://emds.sgemc.com:8443/std/02200105/1426487d-bfe1-ea11-9838-54e1adb0f0f
实体：	1426487d-bfe1-ea11-9838-54e1adb0f0f (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:57 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 3fca30ef77ee48f792faf286183ae3f4
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/std/02200201/8713a59f-0b9a-e911-aa80-54e1adee7d63
实体：	8713a59f-0b9a-e911-aa80-54e1adee7d63 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:09 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 8ecc7e1f9522461cbf1c2002dca15f42
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02209901/Common/enableRiskMain
实体：	enableRiskMain (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:57 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 6011e14ed54d4703ae8a31720fab4f8e
X-ERP-Version: 600
x-my-TraceID: 6011e14ed54d4703ae8a31720fab4f8e
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

{
 "code": "0",
 ...
}

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02200201/Provider/enableYcg
实体：	enableYcg (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:13 GMT
Content-Type: application/json
Content-Length: 72
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 2f27a9603c684ee18c66923c79de1af0
X-ERP-Version: 600
x-my-TraceID: 2f27a9603c684ee18c66923c79de1af0
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
 "code": "0",
 ...
}

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppCard/Ajax-Handler/LoadData
实体：	LoadData (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:14 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: a2960b43851d4543a254611bb1dd7ac9
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "labelConfig": [

  ],
  "titleConfig": [

  ],
  "data": [

  ]
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:NE/X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sgemc.com:8443/api/02200201/ProviderGlobalSearch/SetCacheManager
实体：	SetCacheManager (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:14 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sgemc.com:8443
x-fast-trace-id: ded9ecee9616427d8b54269f777b36e3
X-ERP-Version: 600
x-my-TraceID: ded9ecee9616427d8b54269f777b36e3
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "code": "0",
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetExportParam
实体：	SetExportParam (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:16 GMT
Content-Type: application/json
Content-Length: 82
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: f997c443bb1d4b95ad94f1a77ea8fb2f
X-ERP-Version: 600
x-my-TraceID: f997c443bb1d4b95ad94f1a77ea8fb2f
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/03011407/setting/globalCss
实体：	globalCss (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:25 GMT
Content-Type: text/css
Content-Length: 792
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
```

```
Cache-Control: public, max-age=31536000
x-fast-trace-id: 20d65c93e70f44969c49c06c47ee343f
X-ERP-Version: 600
x-my-TraceID: 20d65c93e70f44969c49c06c47ee343f
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

:root{
  --primaryColor:#266eff;
  --navBackgroundColor:#266eff;
  --navActiveBackgroundColor:#2265ed;
  ...
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:U/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL：	https://emds.sqemc.com:8443/POjs/3rd/login.js
实体：	login.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:26 GMT
Content-Type: application/javascript
Content-Length: 1352537
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Thu, 16 Apr 2026 03:37:37 GMT
Accept-Ranges: bytes
ETag: "1d0cd525e6075d9"
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

(function(){
"use strict";
var commonjsGlobal$1="undefined"!==typeof globalThis?globalThis:"undefined"!==typeof window?window:"undefined"!==typeof global?global:"undefined"!==typeof self?self: {};
function getDefaultExportFromCjs(e){return e&&e.__esModule&&Object.prototype.hasOwnProperty.call(e,"default")?e.default:e}
function getAugmentedNamespace(e){if(e.__esModule)return e;var t=e.default;if("function"===typeof t){var n=function e(){return this instanceof e?Reflect.construct(t,arguments,this.constructor):t.apply(this,arguments)};n.prototype=t.prototype}else n={};return Object.defineProperty(n,"__esModule",{value:!0}),Object.keys(e).forEach((function(t){var r=Object.getOwnPropertyDescriptor(e,t);Object.defineProperty(n,t,r.get?r:{enumerable:!0,get:function(){return e[t]}})})),n)var check=function(e){r...
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/static/08dc4e04-a714-4971-86ae-2cd2852308c4/codingpage/08dc5cec-6593-4ad7-84fc-b29a58a47bd8.js
实体：	08dc5cec-6593-4ad7-84fc-b29a58a47bd8.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:27 GMT
Content-Type: application/javascript; charset=utf-8
Content-Length: 4130
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
X-ERP-Version: 600
X-StaticFileHandler: 31536000second
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/03011407/setting/page/config
实体：	config (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:27 GMT
Content-Type: application/javascript; charset=UTF-8
Content-Length: 144868
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Cache-Control: public, max-age=86400
x-fast-trace-id: ff720785a5a14145b7fd41ddb8ed760
X-ERP-Version: 600
x-my-TraceID: ff720785a5a14145b7fd41ddb8ed760
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

var EMC_CONFIG = {"isShowPersonalSettings":true,"logoutUrls":["https://emds.sqemc.com:8443/bpm/api/sso/logout"],"customServiceSetting":{"loader":"/EO/js/3rd/emc-ai-loader.js?"
```

v=19d941f491d","enableRefu":true,"enableAI":true},"brandConfig":{"navTitle":"投建营一体化平台","navLogoImage":null,"siteIcon":null,"themeLayoutModel":"concise-full-left-nav"},"isShowExit":true,"menus":[{"top_nav_code":null,"nav_code":"de83215f-ba6...

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL：	https://emds.sqemc.com:8443/std/02201603/08daf383-e025-4769-846d-c6ac16e3e78b
实体：	08daf383-e025-4769-846d-c6ac16e3e78b (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:32 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 55cd8a383ea84e8d86aa7c49d2a83d55
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL：	https://emds.sqemc.com:8443/Cgzlb/ProviderAssess/M02201601/KhRuleForm/KhRuleForm
实体：	KhRuleForm (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:38 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding

x-fast-trace-id: e3890e8977c5437581b2828b2d8f51d8
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02201601/KhRule/GetUsedProviderTypeInfo
实体:	GetUsedProviderTypeInfo (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:38 GMT
Content-Type: application/json
Content-Length: 111
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: ec6c6d543a7a4ab0a04b263343b29032
X-ERP-Version: 600
x-my-TraceID: ec6c6d543a7a4ab0a04b263343b29032
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02201601/KhRule/GetKhRuleList
实体:	GetKhRuleList (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:39 GMT
Content-Type: application/json
Content-Length: 69
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 67062d6f579b4798bc8997b2419b1ff7
X-ERP-Version: 600
x-my-TraceID: 67062d6f579b4798bc8997b2419b1ff7
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

问题 40 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/L/L/ANE:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL:	https://emds.sqemc.com:8443/std/02201604/08db0d8b-7f4f-4abe-863c-8da6af976f0c
实体：	08db0d8b-7f4f-4abe-863c-8da6af976f0c (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:40 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: d9e5da581ea64d5d8ab85354b17d2f37
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...
```

问题 41 / 58

TOC

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200307/CgSolutionSimple/GetNodeList
实体：	GetNodeList (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:09 GMT
Content-Type: application/json
Content-Length: 14218
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 69090df532f24a8982ac1f424cf0b6f0
X-ERP-Version: 600
x-my-TraceID: 69090df532f24a8982ac1f424cf0b6f0
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  ...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.ThemeSettingsAppService/GetCustomizeThemeBySiteId
实体：	GetCustomizeThemeBySiteId (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:25 GMT
Content-Type: text/css
Content-Length: 395106
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
x-fast-trace-id: 5f6ae22d542146c1b3bd1f5370f5e906
X-ERP-Version: 600
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/_frontend/sea-config.js
实体：	sea-config.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:51 GMT
Content-Type: application/javascript
Content-Length: 179503
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
Last-Modified: Thu, 16 Apr 2026 03:53:44 GMT
Accept-Ranges: bytes
ETag: "1dcd549ed7e92f"
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 1year
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

var __lang = !!window.Mysoft ? window.Mysoft.Map6.UI.page.lang : "";
var __tenantCode=Mysoft.Map6.UI.page.tenantCode;
var __langhash = !!window.Mysoft ? window.Mysoft.Map6.UI.page.langhash : "";
var query= "&lang=" + __lang;
...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/static/6807139e-1939-4353-d61e-08da49468f55/uemplate/71b1e5d2-bd54-4d55-5099-08da4c3076e6.js
实体:	71b1e5d2-bd54-4d55-5099-08da4c3076e6.js (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:52 GMT
Content-Type: application/javascript; charset=utf-8
Content-Length: 3773
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
X-ERP-Version: 600
X-StaticFileHandler: 31536000second
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02201204/BaseBidPriceAdjust/IsAdmin
实体:	IsAdmin (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:57 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 6011e14ed54d4703ae8a31720fab4f8e
X-ERP-Version: 600
x-my-TraceID: 6011e14ed54d4703ae8a31720fab4f8e
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

```
{
  "code": "0",
  ...
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/std/32010604/febfed58-34fc-44ee-5bc8-08dad0e746f6
实体：	febfed58-34fc-44ee-5bc8-08dad0e746f6 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:01 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: ebd4f89e59aa4db599162ed6db29ebef
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/Cgzfb/ProviderManage/M02200201/ProviderCompare/ProviderCompareIframe
实体：	ProviderCompareIframe (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:30 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
```

...

严重性：高

CVSS 分数: 8.2

CVSS 向量: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X

URL: <https://emds.sgmc.com:8443/api/Msoft.PubPlatform.Nav.AppServices.SiteRedirectAppService/RedirectFunctionHomePageWithoutToken>

实体: RedirectFunctionHomePageWithoutToken (Page)

风险：可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了

未经处理的测试响应:

```
HTTP/1.1 302 Found
Date: Thu, 16 Apr 2026 05:31:30 GMT
Content-Length: 0
Connection: keep-alive
Location: /PubPlatform/Nav/Common/OutsiteLinkPage?
functionCode=02209801&_functionName=7e7bb9f8e8ae1a1e68a5e8a1a8&_nav=0220&link=https%3a2f2femms.sjeng.com%3a8443%2fdp%2freport-
micro%2fhome%2fapi%2fssso%2ferp%3fportal_id%3d11111111-0000-0000-0000-000000000220%26type%3dportal&siteName=7e7bb8f8e890a5e5%88%86e6%9e90%e5b9b3e5%8fb0&_hid=02209801
x-fast-trace-id: ce87ae3c5c674450ad0afff07409b0b
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sjeng.com:8443
```

```
GET /PubPlatform/Nav/Common/OutsiteLinkPage?functionCode=02209801& functionName=e7bb9f8e8a5e8a1a8g_nav=0220&link=https%3A%2F%2Femds.sgcc.com%3A8443%2Fcdp%2Freport-micro%2Fhome%2Fapi%2Fss%2Fer%3Fportal_id%3D11111111-0000-0000-0000-000000000022%26type%3Dportal&siteName=e7bb8f8e8990a5e5888e69e90e5b9b3e58f8b0c_hid=02209801 HTTP/1.1
Cookie: **1776317276.932.787.124128|faaafcb7d292d2009aa72f9f2db2be; LoginTenant=qhgq; LoginSite=f4095c3-8fe3-1lec-aed9-fa163bd3de3; platform_user_token=eYraWjQlJ4yYxlaGhnlWLkYisImFsZyG1LJTmJzU2Ino.eYuhmfrOJE3NznzyTctYxzgsInvZwJFY2K2SGI6mfKbwLuIiwidvQNLcl9uWlllJoi57075fu566h55GS3GYiwiawXziJoiaRH0CHMXXCzclVZhMuc3rHlwMy29vOgtONNCL2Fd3grILCL2vYzdclaQwioJlOMjMwmNmZS2SO2WLJ2TGtY2ktYMTCSLS1IOT1Y5TA2YTGT02gTiPCLzb3YyZUioJwYizysJio4CCTMc3nJm2mNmCoWiagGrZW5fHwZSI6ImfJYZVzcrl9kb2tlslImhlldClfTCc3NjMmZmZS2OWianPfojoi... userHash=0221465632; authToken=CEDF581 vufRn2...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/PubPlatform/Nav/Common/OutsiteLinkPage
实体:	OutsiteLinkPage (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:32 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 0135dac342a44698a33bd3d70e5e7058
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/Pubplatform/SysSetting/M00002105/bizparam
实体:	bizparam (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:44 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 5b6967c3901c4af5a09cd962e8c3f8c3
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200302/CgSolution/GetNodeList
实体：	GetNodeList (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:09 GMT
Content-Type: application/json
Content-Length: 14218
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 69090df532f24a8982ac1f424cf0b6f0
X-ERP-Version: 600
x-my-TraceID: 69090df532f24a8982ac1f424cf0b6f0
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  ...
}
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/std/02200308/08dc4246-562e-49b4-8864-54313a31b750
实体：	08dc4246-562e-49b4-8864-54313a31b750 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:14 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
```

```
x-fast-trace-id: 7b3f0afdbc3c42e8b34beadd9dd1675
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/std/02200911/5cf49f23-3d86-ea11-aa7f-54e1ade4a50e
实体:	5cf49f23-3d86-ea11-aa7f-54e1ade4a50e (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:29 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: a1c3ccdee26943ec9458fa1151fe5eb8
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/CurrentUserExistsDataMaskingRights
实体:	CurrentUserExistsDataMaskingRights (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:52:41 GMT
```

```
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: a6cd53b9ab0146b4bc9a4694ad528064
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

false...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IsSyncProviderUser2MyUser
实体：	IsSyncProviderUser2MyUser (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:52:41 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 0d715b4cf6b548a988f1c4c26b15834f
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

true...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/BusinessModelsOP
实体：	BusinessMbdelsOP (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:09:40 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: ea4f4454c488449ebb8c75fd5721bc19
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

true...
```

缺少必需的CSP指令	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.PublicServices.OrganizationUserImpAppService/GetIntegratedLicenseUserKindTitle
实体：	GetIntegratedLicenseUserKindTitle (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:28:57 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://bogus.origin.hcl.com
x-fast-trace-id: 74f439f593664487bbb1f8883915edd4
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

缺少必需的CSP指令	
严重性:	高
CVSS 分数:	8.2
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:NE/X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IntegrationCategoryManager
实体:	IntegrationCategoryManager (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 重要的指令丢失了
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:53:03 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: bbc1f355f252460297e1cde4440c1642
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "ERPOP": true,
  "ERPSAAS": false,
  "IndustrialConstruction": false,
  "SmartPark": false,
  ...
}
```

通过 URL 重定向钓鱼	
严重性：	高
CVSS 分数：	8.2
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/auth/oauth2/authorize
实体：	redirect_uri (Parameter)
风险：	可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序执行指向外部站点的重定向
固定值：	禁用基于参数值指向外部站点的重定向

推理： 测试结果似乎指示存在脆弱性，因为响应包含指向 demo.testfire.net 的重定向，这显示应用程序允许重定向到外部站点，这是网络钓鱼攻击可利用的弱点。

问题 1 / 1

TOC

CORS 策略根据任意初始头进行设置	
严重性:	中
CVSS 分数:	5.3
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/
实体:	emds.sqemc.com (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

推理： AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多
未经处理的测试响应：

```
...
My_suiAWITyTXjjxv3ho_KZ3ZMEjjMxZITP7FEELSQZQ; _userHash=2021465632; userToken_Core=CfDJ8J_vUFkn2vtEycxulLlCfDsuaW_uzULPaLVoQQjp6Ksrtx#0ZsejjTlBWzyGu#la-RTWxgkbksX_RSjp4kY-Td-
QGP6iFAWA0GmRQdLdluv7o6xkd1c2Y-fGfZz531gRk4R632Js79abOSoSmsVIjXpcVR7n036UrtfjwXFKHaYo1PSgjudMhFTDc5Qs7Ip3fv9fkUiOx8g8wUJo9ueZSOBLcWiiKLaPAJSPAg4aUoTggBjLHoxSioB72N8nkM-
i59_LiX8bnhwQ1l1NfHmtw5noiDYs3-o7vMNzNgmAJ41lI2v_wsODvryLeUDv1F-Oy2dc1wBtoOjGiLUjP1Pg1oBShWgcuEeqbzPawWtYHaDAKoIMNa0mL90X77_1B...
Content-Length: 0

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:56 GMT
Content-Type: application/json
Content-Length: 98
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
x-fast-trace-id: 9122976ad2184835b9629724d72131f5
X-ERP-Version: 600
x-my-TraceID: 9122976ad2184835b9629724d72131f5

...
```

问题 1 / 2

TOC

OAuth 隐式授权类型缺陷	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/auth/oauth2/authorize
实体：	authorize (Page)
风险：	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务
原因：	应用程序使用的认证方法不充分
固定值：	添加代码交换证明密钥 (PKCE)

推理： 请求不包含 code_verify 参数
未经处理的测试响应：

```
HTTP/1.1 302
Date: Thu, 16 Apr 2026 05:28:48 GMT
Content-Length: 0
Connection: keep-alive
Location: https://emds.sqemc.com:8443/gzt/oauth2/refreshToken?request_id=elfa826b-5052-4291-8dbc-34f2ac299317&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Femds.sqemc.com%253A8443%252Ffapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D168a4f08-0801-4c18-b04b-a1efb941d51d%26client_id%3Dplatform
Strict-Transport-Security: max-age=31536000; includeSubDomains

GET /gzt/oauth2/refreshToken?request_id=elfa826b-5052-4291-8dbc-34f2ac299317&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Femds.sqemc.com%253A8443%252Ffapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D168a4f08-0801-4c18-b04b-a1efb941d51d%26client_id%3Dplatform HTTP/1.1
Cookie: *=1776317276.932.87.724128|f4aaadb70292cd00d9aa72f9f2bd29be
Accept-Language: en-US
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3
Referer: https://emds.sqemc.com:8443/auth/oauth2/authorize?redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Ffapaas-auth%2Foauth2%2Fportal%3Fredirect_uri%3D%252F%26response_type=code&state=168a4f08-0801-4c18-b04b-a1efb941d51d&client_id=platform
Host: emds.sqemc.com:8443
...
```

问题 2 / 2

TOC

OAuth 隐式授权类型缺陷	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/gzt/oauth2/refreshToken
实体：	refreshToken (Page)
风险：	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务
原因：	应用程序使用的认证方法不充分
固定值：	添加代码交换证明密钥 (PKCE)

推理： 请求不包含 code_verify 参数
未经处理的测试响应：

```
HTTP/1.1 302 Found
Date: Thu, 16 Apr 2026 05:28:59 GMT
Content-Length: 0
Connection: keep-alive
Location: /login?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Femds.sqemc.com%253A8443%252Ffapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7doe3002734%26client_id%3Dplatform
x-fast-trace-id: e2ec86a20dbb4911b5a3247d9dd78791
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

GET /login?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Femds.sqemc.com%253A8443%252Fapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7doe3002734%26client_id%3Dplatform HTTP/1.1
Cookie: *=1776317276.932.87.724128|f4aafdb70292cd200d9aa72f9f2bd29be
Accept-Language: en-US
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3db3
Referer: https://emds.sqemc.com:8443/gzt/oauth2/refreshToken?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%...

中 SRI (Subresource Integrity) 的检查 ①

TOC

问题 1 / 1

TOC

SRI (Subresource Integrity) 的检查

严重性: 中

CVSS 分数: 5.3

CVSS 向量: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X

URL: https://emds.sqemc.com:8443/dp/bi-visual/app/index/11111111-0000-0000-0000-000000000220

实体: 11111111-0000-0000-0000-000000000220 (Page)

风险: 在第三方服务器被破坏的情况下，站点的内容/行为将更改。

原因: SRI(Subresource Integrity) 不受支持

固定值: 将每个第三方脚本/链接元素支持添加到 SRI(Subresource Integrity)。

推理: 第三方链接/脚本没有完整性属性，浏览器无法确认它们没有被破坏。

未经处理的测试响应:

```
...
c0 0 0 0 0 0 0-53.019 42.981-96 96-96s96 42.981 96 96c0 0 0 0 0 0 53.019-42.981 96-96 96s-96-42.981-96-96z456 512c0-39.765 32.235-72 72-72s72 32.235 72 72c0 39.765-32.235
72-72 72s-72-32.235-72-72z">
</path>
</g>
</svg>
<div class="loadingText">正在回退中，请稍后</div>
</div>
<!-- 启动脚本动态生成的文件 在这里引入 需要确保放在天眼探针引入之前 -->
<script src="/dp/fastTrackerConfig.js" async="async"></script>
<!-- 天眼探针引入 -->
<script src="https://mic-open.mypaas.com.cn/fast-tracker/skyline/dp/dp-frontend/fastTracker.js" async="async"></script>
<script>
  if (/\/dataview-mobile\/(view)\/.test(window.location.pathname) && window.location.href.indexOf('no-prejs=1') === -1) {
    console.log("prejs-开始执行时间:", new Date().getTime())
    window && window.preload()
  }
</script>
<script>
  // 检测浏览器是否支持webp图片格式
  function checkWebp() {
    ...
```

中 具有不安全、不正确或缺少 SameSite 属性的 Cookie ⑦

TOC

严重性:	中
CVSS 分数:	4.7
CVSS 向量:	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/
实体:	LoginTenant (Cookie)
风险:	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄漏，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。
原因:	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie
固定值:	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案

原始响应

```
...
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443
Set-Cookie: emcLanguage=: expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/
Set-Cookie:
platform_user_token=eyJraWQiOiJ4YyYxZGlnIiwiaWF0IjE3NzYzMjc1MzIsInVzZXJfY29kZSI6ImFkbWluIiwidmVudC1nYWllIjoiejoyOTUwY29kZS5QSG52GYiwiawXNzIjoiaHR0cH
M6XC9lZVtZHMuc3FlbmMuY290Y29kZGNDN2Fid3giLCJ1c2VyY2dlaWQiOiJ0MjhmM2S0ZSU0ZWU2LTQ2YTktYTM5ZS1iOTU1YTA2YTg0T2gtLjIC3Zlb3Y3YyZUoiOjwyaSImV4cCI6MTc3NjM4bnZuZWUiianRpiOi... path=/
YZvzcl90bt2ltbiImldhClQMtc3NjM4bnZuZWUiianRpiOi... path=/
Set-Cookie: LoginTenant=chgq; max-age=31104000; path=/
Set-Cookie: LoginSite=f4095c3-8fe3-11ec-ae49-fa163eb3dbe3; max-age=31104000; path=/

{
  "action": "redirect",
  "isSelectTenants": false,
  "tenants": [

],
  "redirectUrl": "https://emds.sgemc.com:8443/auth/oauth2/callback?code=v9wkQnArFF2yK6rL_Cf22-nsKu2cq-PuasOt331PQQj72v8JDH31gUeJF2-
3g2gnFX9K0KHm8clxdC61uaWrjj16IDf9nQSrPLvMpyBeD9Mz-stLIrRKtyrz9QLBTLtd&
...

```

TOC

严重性:	中
CVSS 分数:	4.7
CVSS 向量:	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/
实体:	auth_token (Cookie)
风险:	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄漏，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。
原因:	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie
固定值:	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案

原始响应

```
HTTP/1.1 500
Date: Thu, 16 Apr 2026 05:33:19 GMT
```

```
Content-Type: application/json
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains

{
  "error": "授权码关联的token不存在，请确认",
  "detail": "",
  "errorCode": -1
}...
```

具有不安全、不正确或缺少 SameSite 属性的 Cookie	
严重性：	中
CVSS 分数：	4.7
CVSS 向量：	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	dmp_env_code (Cookie)
风险：	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄漏，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。
原因：	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie
固定值：	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案

推理： 响应包含不安全、不正确或缺少 SameSite 属性的敏感 Cookie，这可能会导致 Cookie 信息泄露，如果没有额外的保护措施，可能会扩展为跨站点请求伪造 (CSRF) 攻击。

原始响应

```
...

Content-Length: 0

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:33:21 GMT
Content-Type: application/json
Content-Length: 114
Connection: keep-alive
x-dap-upstream-latency: 1045
Strict-Transport-Security: max-age=31536000; includeSubDomains
Set-Cookie: dmp_env_code=xc-qhgg-idx; Domain=emds.sqemc.com; Path=/dp
Set-Cookie: yl-fab=""; Domain=sqemc.com; Max-Age=-1; Path=/dp

{
  "result": true,
  "msg": null,
  "data": {
    "items": [

  ],
  "total": 1,
}

...
```

具有不安全、不正确或缺少 SameSite 属性的 Cookie	
严重性：	中
CVSS 分数：	4.7
CVSS 向量：	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	yl-fab (Cookie)
风险：	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄露，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。
原因：	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie
固定值：	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案

推理： 响应包含不安全、不正确或缺少 SameSite 属性的敏感 Cookie，这可能会导致 Cookie 信息泄露，如果没有额外的保护措施，可能会扩展为跨站点请求伪造 (CSRF) 攻击。

原始响应

```
...

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:33:21 GMT
Content-Type: application/json
Content-Length: 114
Connection: keep-alive
x-dap-upstream-latency: 1045
Strict-Transport-Security: max-age=31536000; includeSubDomains
Set-Cookie: dmp env code=xc-ghgg-idx; Domain=emds.sqemc.com; Path=/dp
Set-Cookie: yl-fab=""; Domain=sqemc.com; Max-Age=-1; Path=/dp

{
  "result": true,
  "msg": null,
  "data": {
    "items": [
      ],
    "total": 1,
    "env_code": "xc-ghgg-idx",
    "auth_mode": "normal"
  }
}
...
```

具有不安全、不正确或缺少 SameSite 属性的 Cookie	
严重性：	中
CVSS 分数：	4.7
CVSS 向量：	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	LoginSite (Cookie)
风险：	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄露，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。
原因：	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie
固定值：	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案

推理： 响应包含不安全、不正确或缺少 SameSite 属性的敏感 Cookie，这可能会导致 Cookie 信息泄露，如果没有额外的保护措施，可能会扩展为跨站点请求伪造 (CSRF) 攻击。

原始响应

具有不安全、不正确或缺少 SameSite 属性的 Cookie	
严重性：	中
CVSS 分数：	4.7
CVSS 向量：	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	userToken_Core (Cookie)
风险：	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄漏，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。
原因：	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie
固定值：	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案

推理： 响应包含不安全、不正确或缺少 SameSite 属性的敏感 Cookie，这可能会导致 Cookie 信息泄露，如果没有额外的保护措施，可能会扩展为跨站点请求伪造 (CSRF) 攻击。

原始响应

```
...
Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: 0ff2d54400754a20a080b13b4087c8e5
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: userHash=2021465632; expires=Fri, 16 Apr 2027 05:33:20 GMT; path=/
Set-Cookie: userToken_Core=CfDJ8J_vUfKn2vtEvcxwLlLlCfdvFJgP3kr1pdBXLernp712m6WzAx0SHoXAFY_2ksuQ-e1YjpRhdJv8MQJMOIG409m-0gTXV08z5syE7QMKBUscEimgCrOXy-tvexB_o_6WG3E-jZIpUaMyzjRkwo0-5nq9LJUPbFWQm93CbnFn2B8Np1KERUlnQPZJfPAK_kCLt6242c0Fqrc7VqdPGM7wgcj2kwxrV0dFDGcFs7uflkFkcx008nFUSRT0H55to0qba6s4dnBnCARq6ZSXpQnkGnkB8xhLwFzVCoR9WgjbN0OdZjV7N8xWLDvY7MBJHi0B8FBHkhe-JD1zw3jqFUIWs62FJyhFWLmLRjtoUaW460FaCWLkUf-iyd2... path=/; httponly
...
```

加密会话（SSL）Cookie 中缺少 Secure 属性	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	LoginTenant (Cookie)
风险：	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
原因：	Web 应用程序通过 SSL 发送不安全的 cookie
固定值：	向所有敏感的 cookie 添加“Secure”属性

推理： AppScan 发现加密会话（SSL）使用的是没有“secure”属性的 cookie。

原始响应

```
...
X-ERP-Version: 600
```

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: emcLanguage=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/
Set-Cookie:
platform_user_token=eyJraWQioiJ4YyYlkaGdnLWlkYyIsImFsZyI6IlJTMjU2In0.eyJubmYiOiE3NzYzMjc1MzIsInVzZjYy29k2SI6ImFkbWluIiwic2Nlc19uYW11Ijo1570757uf566h55Q35ZGYIiwiaXNzIjoiaHR0cH
M6XC9cL2VtZFMuc3FlbWMy29tOjg0NDNcL2FldGgiLCJlc2VyZ2dlaWQioiI0MjMwYmZ2S02OWU2LTQ2YTktYTM5ZS1lOTI15YTA2YTg0ZTg1LjZb3VyY2UiOiJwYyIsImV4cCI6MTc3NjMzNTU5MiwidG9rZW5fdHlwZSI6ImFj
YZVzcl90b2t1biIsImhhdCI6MTc3NjM3MzUzMiwiianRpIjo1... path=/
Set-Cookie: LoginTenant=qhgg; max-age=31104000; path=/
Set-Cookie: LoginSite=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3; max-age=31104000; path=/

{
  "action": "redirect",
  "isSelectTenants": false,
  "tenants": [
  ],
  "redirectUrl": "https://emds.sqemc.com:8443/auth/oauth2/callback?
code=vukdnYexUS24ZMkB_zf2_FZPLXc0aExbtU0JImaIiRcVs7TN2OCefWddHLEW9Ky157umgVM7yGyg3fbfnknY8lbr6ToREwWWE5QNlKhLQnL2J4NiWlXvd3z8HsGkx
...
```

加密会话（SSL）Cookie 中缺少 Secure 属性	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	dmp_env_code (Cookie)
风险：	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
原因：	Web 应用程序通过 SSL 发送不安全的 cookie
固定值：	向所有敏感的 cookie 添加“Secure”属性

推理： AppScan 发现加密会话（SSL）使用的是没有“secure”属性的 cookie。
原始响应

```
...

Content-Length: 0

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:33:21 GMT
Content-Type: application/json
Content-Length: 114
Connection: keep-alive
x-dap-upstream-latency: 1045
Strict-Transport-Security: max-age=31536000; includeSubDomains
Set-Cookie: dmp_env_code=xc-qhgg-idx; Domain=emds.sqemc.com; Path=/dp
Set-Cookie: yl-fab=""; Domain=sqemc.com; Max-Age=-1; Path=/dp

{
  "result": true,
  "msg": null,
  "data": {
    "items": [
    ],
    "total": 1,
  },
}
```

加密会话（SSL）Cookie 中缺少 Secure 属性	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	LoginSite (Cookie)
风险：	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
原因：	Web 应用程序通过 SSL 发送不安全的 cookie
固定值：	向所有敏感的 cookie 添加“Secure”属性

推理： AppScan 发现加密会话（SSL）使用的是没有“secure”属性的 cookie。
原始响应

```
...

Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: emcLanguage=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/
Set-Cookie:
platform user token=eyJraWQiOiJ4Yy1kaGdhLWlkYyIsImFsZyI6IiJIMjU2In0.eyJ1Ym9iOiJlZ3ZyZmVzZjY2ZSI6ImFkbWluIiwic29uYm9iOiJlZ3ZyZmVzZjY2ZSI6ImFkbWluIiwiaWF0Ijoi570757uf566h550G5ZGYIiwiaXNzIjoiaHR0cH
M6XC9cL2VtZHMjc3Flb3RlbnM2Y29tOjg0NDNcL2Flc2VhZ2dlawQioiIOMjM2S0Z0WUJlTQ2YTktYTM5ZS1iOTI5YTA2YTg0ZTgiLCJzb3VyY2UiOiJwYyIsImV4cCI6MTc3NjMzNTYwMDwidG9rZW5fdHlwZSI6ImFj
YZVzcl90b2t1biIsImhhdCI6MTc3NjMzNTYwMDwianRpIjoj... path=/
Set-Cookie: LoginTenant=qhgg; max-age=31104000; path=/
Set-Cookie: LoginSite=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3; max-age=31104000; path=/

{
  "action": "redirect",
  "isSelectTenants": false,
  "tenants": [

  ],
  "redirectUrl": "https://emds.sqemc.com:8443/auth/oauth2/callback?code=tpX41JYZIt1TtjDbB4N802Y8QxaoPGzEjwG78J8ludQpS-
bn5xG0vX9LjTj1Uo60dEOQB2EjIVCbnuYjIp4SJF_x0Ln3Kn9zvRqG3suRfkIjV-EXzjKQYi5zwPtrz&state=518abf26-3f91-47d2-ae2d-
01120f8c8a3c&redirect_uri=https%3a%2f%2femds.sqemc.com%3a8443%2fstcd%2f03011401%2f08dc5cec-6593-4af6-8de4-8bf200fca00a",
  ...
}
```

加密会话（SSL）Cookie 中缺少 Secure 属性	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	userToken_Core (Cookie)
风险：	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
原因：	Web 应用程序通过 SSL 发送不安全的 cookie
固定值：	向所有敏感的 cookie 添加“Secure”属性

推理： AppScan 发现加密会话（SSL）使用的是没有“secure”属性的 cookie。
原始响应

```
...

Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: 9b6ca04e4d324dfd8cce85421f6646c9
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: userHash=2021465632; expires=Fri, 16 Apr 2027 05:33:19 GMT; path=/
Set-Cookie: userToken Core=CfDJ8J vUfkn2vtEvcouLLlCfDt24 5JB5CIuxQwvuyDI7SoujYS_Ew-W4iPBEnlNaRVcmiTE_iiMyaNrFYiKo8Of3xyNUjBGouTRWMIUGQvnydnkmfRhdMAAjiimZezVE_d2HORTznRS5wx6-
spaMf8AxpCBhxpOnaXaeXiuW6Wyo9AKwzU KNOuS8GP1-vyR0VSimcmT66U04F-
FKFYldatPKUbuZlajgvn4FitN2pT6iwhzALipajfwPeKGJsv28KQmBYH3G3y1ReEAHZR426wrmMaLJLYE1lxyYfw3XVG2YB0dgRfDkR7lRvc7Dl0qRAhVxcY_btpaZ4i1JETKaZWfpgf_iwFq6Jno1X_TV5Bwa8LgQR6gLLld...
path=/; httponly

...

加密会话（SSL）Cookie 中缺少 Secure 属性	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	_userHash (Cookie)
风险：	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
原因：	Web 应用程序通过 SSL 发送不安全的 cookie
固定值：	向所有敏感的 cookie 添加“Secure”属性

推理： AppScan 发现加密会话（SSL）使用的是没有“secure”属性的 cookie。

原始响应

...

Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: 6908941f0dc14ff7914e5cecb388f6e2
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: userHash=2021465632; expires=Fri, 16 Apr 2027 05:33:20 GMT; path=/
Set-Cookie: userToken Core=CfDJ8J vUfkn2vtEvcouLLlCfDseJ5JzP2OP_hd7dyF0GJZQ7DEJjgys2BRlkyWbHgC3Br5T4edpNiiWuQYSeiY4YiWgRD5YTE-32CY0eC2BWRtiuMM013211K1R1eXJK-
GiM7Dd0mNHIS_yaTFerrHogG1S-Ts11K8JjeVUGWsdL76AlM005YenfDpRIUE8mTn_QloqVTD5_OK9np3YFXRMJ8ybHF12J3BeduH2Co-FU3mMY_CS_9niV-NWku_yRqpZekXd1FJtCd0V_CgAgw_uxaRmMMWML33CZS4mw-
IWzry3v770BMoRMznSSqZCdcm7/cr9a-sBcK0Uau3tHktV1VDATzCERdFVU5P4co0ueAzye9P4Ibw9zn... path=/; httponly

...

加密会话（SSL）Cookie 中缺少 Secure 属性	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	yl-fab (Cookie)
风险：	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
原因：	Web 应用程序通过 SSL 发送不安全的 cookie
固定值：	向所有敏感的 cookie 添加“Secure”属性

推理： AppScan 发现加密会话（SSL）使用的是没有“secure”属性的 cookie。
原始响应

```
...

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:33:21 GMT
Content-Type: application/json
Content-Length: 114
Connection: keep-alive
x-dap-upstream-latency: 1045
Strict-Transport-Security: max-age=31536000; includeSubDomains
Set-Cookie: dmp_env_code=xc-ghgg-idc; Domain=emds.sqemc.com; Path=/dp
Set-Cookie: yl-fab="" ; Domain=sqemc.com; Max-Age=-1; Path=/dp

{
  "result": true,
  "msg": null,
  "data": {
    "items": [

  ],
  "total": 1,
}

...
```

问题 1 / 4

TOC

发现数据库错误模式	
严重性：	中
CVSS 分数：	5.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C/L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体：	data (Global)
风险：	可能会查看、修改或删除数据库条目和表
原因：	未对用户输入正确执行危险字符清理
固定值：	查看危险字符注入的可能解决方案

推理： 以下情况之一已发生：1. 测试响应中包含指向文件 "WF_XSRF.html" 的链接，这证明了SQL注入尝试成功。2. 响应中包含RDBMS错误。这表明测试成功地穿透了应用程序并到达了SQL查询本身，通过注入有害字符。
未经处理的测试响应：

```
...

"code": "ghgg",
"fetchTimestamp": 1776314256532,
"filter_val_empty_mode": 0
},
"is_key": 0,
"code": "ghgg"
}

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:41 GMT
Content-Type: application/json
Content-Length: 7885
Connection: keep-alive
Vary: Accept-Encoding
access-control-allow-origin: https://emds.sqemc.com:8443
access-control-allow-methods: POST, GET, PUT, DELETE, OPTIONS
```

```

access-control-allow-headers: Access-Control-Allow-HeadersAuthorization,Content-Type,Accept,Origin,User-Agent,DNT,Cache-Control,X-Mx-ReqToken,Keep-Alive,X-Requested-With,If-Modified-Since
access-control-allow-credentials: true

...

...

access-control-allow-credentials: true
x-dap-upstream-latency: 113
Strict-Transport-Security: max-age=31536000; includeSubDomains

{
  "result": true,
  "msg": "",
  "data": {
    "d866a72f-a6aa-11ec-8ac4-117b22c26fdb": {
      "errmsg": "(pymysql.err.ProgrammingError) (1064, 'You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '\\\\'\\$ne\\\\': '\\\"\\'1\\\\'\\\\'\"' LIMIT 1\\\\' at line 1')\\n[SQL: SELECT * FROM `dap_bi_dashboard_released_snapshot_chart` WHERE `id`=(id)s AND `snapshot_id`=(snapshot_id)s LIMIT 1 ]\\n[parameters: {'id': 'd866a72f-a6aa-11ec-8ac4-117b22c26fdb', 'snapshot_id': {'$ne': '1'}}]\\n(Background on this error at: https://sqlalche.me/e/20/f405)",
      "data": [

        ],
        "marklines": [

        ],
        "conditions": [

        ]
      },
      "msg": "单图取数接口异常，异常信息：(pymysql.err.ProgrammingError) (1064, 'You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '\\\\'\\$ne\\\\': '\\\"\\'1\\\\'\\\\'\"' LIMIT 1\\\\' at line 1')\\n[SQL: SELECT * FROM `dap_bi_dashboard_released_snapshot_chart` WHERE `id`=(id)s AND `snapshot_id`=(snapshot_id)s LIMIT 1 ]\\n[parameters: {'id': 'd866a72f-a6aa-11ec-8ac4-117b22c26fdb', 'snapshot_id': {'$ne': '1'}}]\\n(Background on this error at: https://sqlalche.me/e/20/f405)",
      "msg_code": 5004,
      "error_code": 10000,
      "pagination": {

      },
      "sql": "",
      "sql_execute_time": "",
      "dataset_versions": {

      }
    },
    "507456c3-ae6e-11ec-a621-ff55762e63d9": {
      "errmsg": "(pymysql.err.ProgrammingError) (1064, 'You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '\\\\'\\$ne\\\\': '\\\"\\'1\\\\'\\\\'\"' LIMIT 1\\\\' at line 1')\\n[SQL: SELECT * FROM `dap_bi_dashboard_released_snapshot_chart` WHERE `id`=(id)s AND `snapshot_id`=(snapshot_id)s LIMIT 1 ]\\n[parameters: {'id': '507456c3-ae6e-11ec-a621-ff55762e63d9', 'snapshot_id': {'$ne': '1'}}]\\n(Background on this error at: https://sqlalche.me/e/20/f405)",
      "data": [

        ],
        "marklines": [

        ],
        "conditions": [

        ]
      },
      "msg": "单图取数接口异常，异常信息：(pymysql.err.ProgrammingError) (1064, 'You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '\\\\'\\$ne\\\\': '\\\"\\'1\\\\'\\\\'\"' LIMIT 1\\\\' at line 1')\\n[SQL: SELECT * FROM `dap_bi_dashboard_released_snapshot_chart` WHERE `id`=(id)s AND `snapshot_id`=(snapshot_id)s LIMIT 1 ]\\n[parameters: {'id': '507456c3-ae6e-11ec-a621-ff55762e63d9', 'snapshot_id': {'$ne': '1'}}]\\n(Background on this error at: https://sqlalche.me/e/20/f405)",
      "msg_code": 5004,
      "error_code": 10000,
      "pagination": {

      },
      "sql": "",
      "sql_execute_time": "",
      "dataset_versions": {

      }
    }
  }
}

```

```

    },
    "msg": "单图取数接口异常, 异常信息: (pymysql.err.ProgrammingError) (1064, 'You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '\\\\'$ne\\\\': '\\\\'1\\\\\\\\'') LIMIT 1\\\\' at line 1')\\n[SQL: SELECT * FROM `dap bi dashboard released snapshot chart` WHERE `id`=(id)s AND `snapshot_id`=(snapshot_id)s LIMIT 1 ]\\n[parameters: {'id': '507456c3-ae6e-11ec-a621-ff55762e63d9', 'snapshot_id': {'$ne': '1'}}]\\n(Background on this error at: https://sqlalche.me/e/20/f405)",
    "msg_code": 5004,
    "error_code": 10000,
    "pagination": {

    },
    "sql": "",
    "sql_execute_time": "",
    "dataset_versions": {

    }
  },
  ...
  ...

  },
  "sql": "",
  "sql_execute_time": "",
  "dataset_versions": {
    "data_version": "",
    "version": ""
  }
},
"3a000f79-fd5a-be4e-7620-ad3c04cb923b": {
  "errmsg": "(pymysql.err.ProgrammingError) (1064, 'You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '\\\\'$ne\\\\': '\\\\'1\\\\\\\\'') LIMIT 1\\\\' at line 1')\\n[SQL: SELECT * FROM `dap bi dashboard released snapshot chart` WHERE `id`=(id)s AND `snapshot_id`=(snapshot_id)s LIMIT 1 ]\\n[parameters: {'id': '3a000f79-fd5a-be4e-7620-ad3c04cb923b', 'snapshot_id': {'$ne': '1'}}]\\n(Backgro..."

```

问题 2 / 4

TOC

发现数据库错误模式	
严重性:	中
CVSS 分数:	5.3
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体:	->"chart_params"[1]->"query_vars"[0]->"value_from"->"conditions"[0]->"col_value" (Global)
风险:	可能会查看、修改或删除数据库条目和表
原因:	未对用户输入正确执行危险字符清理
固定值:	查看危险字符注入的可能解决方案

推理： 以下情况之一已发生：1. 测试响应中包含指向文件 "WF_XSRF.html" 的链接，这证明了SQL注入尝试成功。2. 响应中包含RDBMS错误。这表明测试成功地穿透了应用程序并到达了SQL查询本身，通过注入有害字符。

未经处理的测试响应：

```

...

  "code": "qhgg",
  "fetchTimestamp": 1776314256533,
  "filter_val_empty_mode": 0
}
},
"is_key": 0,
"code": "qhgg"
}

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:07:59 GMT
Content-Type: application/json
Content-Length: 4232
Connection: keep-alive
Vary: Accept-Encoding
access-control-allow-origin: https://emds.sqemc.com:8443
access-control-allow-methods: POST, GET, PUT, DELETE, OPTIONS
access-control-allow-headers: Access-Control-Allow-HeadersAuthorization,Content-Type,Accept,Origin,User-Agent,DNT,Cache-Control,X-Mx-ReqToken,Keep-Alive,X-Requested-With,If-Modified-Since
access-control-allow-credentials: true

...

```

```
    }
  },
  "subtotal_row": [

  ]
},
"3a000f79-fd5c-595e-7b26-3534f9f8b697": {
  "errmsg": "单图 810da3e9-a6bc-11ec-8acf-117b22c26fdb 间接关联条件无法获取到数据, 错误信息 [ SQL执行报错, 请检查SQL脚本\nSQL执行异常详情: \nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '``公司``'WEXSSProbe' ORDER BY `idx` ASC LIMIT 0, 50000' at line 5 ] ",
  "data": [

  ],
  "marklines": [

  ],
  "conditions": [

  ],
  "msg": "单图取数接口异常, 异常信息: 单图 810da3e9-a6bc-11ec-8acf-117b22c26fdb 间接关联条件无法获取到数据, 错误信息 [ SQL执行报错, 请检查SQL脚本\nSQL执行异常详情: \nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '``公司``'WEXSSProbe' ORDER BY `idx` ASC LIMIT 0, 50000' at line 5 ] ",
  "msg_code": 500,
  "error_code": 10000,
  "pagination": {

  },
  "sql": "",
  "sql_execute_time": "",
  "dataset_versions": {
    "data_version": "",
  },
  ...
}
```

发现数据库错误模式	
严重性:	中
CVSS 分数:	5.3
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:XM/MA:X
URL:	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体:	->"chart_params"[3]->"pagination"->"page" (Global)
风险:	可能会查看、修改或删除数据库条目和表
原因:	未对用户输入正确执行危险字符清理
固定值:	查看危险字符注入的可能解决方案

推理： 以下情况之一已发生：1. 测试响应中包含指向文件 "WF_XSRF.html" 的链接，这证明了SQL注入尝试成功。2. 响应中包含RDBMS错误。这表明测试成功地穿透了应用程序并到达了SQL查询本身，通过注入有害字符。

未经处理的测试响应：

```
...

},
"fetchTimestamp": 1776314256534,
"filter_val_empty_mode": 0
}
},
"is_key": 0,
"code": "qhgq"
}

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:52:59 GMT
Content-Type: application/json
Content-Length: 5353
Connection: keep-alive
Vary: Accept-Encoding
access-control-allow-origin: https://emds.sqemc.com:8443
access-control-allow-methods: POST, GET, PUT, DELETE, OPTIONS
access-control-allow-headers: Access-Control-Allow-HeadersAuthorization,Content-Type,Accept,Origin,User-Agent,DNT,Cache-Control,X-Mx-ReqToken,Keep-Alive,X-Requested-With,If-
```

```
Modified-Since  
access-control-allow-credentials: true  
  
...  
  
...  
  
},  
"error_code": null,  
"execute_status": 500,  
"extra_data": [  
  
],  
"marklines": [  
  
],  
"msg": "SQL执行报错，请检查SQL脚本\nSQL执行异常详情：\nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version  
for the right syntax to use near '1500000000000000000000, 152' at line 4",  
"msg_code": 5002,  
"orderby": [  
  {  
    "col_name": "JCAMOUNT_14845351691",  
    "content": {  
  
    },  
    "dataset_field_id": "3a10273b-7211-17b7-3484-09a35bf1916b",  
    "field_source": "num",  
  
  }  
  
]
```

TOC

发现数据库错误模式	
严重性：	中
CVSS 分数：	5.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体：	->"chart_params"[4]->"pagination"->"page" (Global)
风险：	可能会查看、修改或删除数据库条目和表
原因：	未对用户输入正确执行危险字符清理
固定值：	查看危险字符注入的可能解决方案

推理： 以下情况之一已发生：1. 测试响应中包含指向文件“WF_XSRF.html”的链接，这证明了SQL注入尝试成功。2. 响应中包含RDBMS错误。这表明测试成功地穿透了应用程序并到达了SQL查询本身，通过注入有害字符。

未经处理的测试响应:

```
...

  ],
  "fetchTimestamp": 1776314256534,
  "filter_val_empty_mode": 0
}
],
"is_key": 0,
"code": "ghgg"
}

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 07:01:15 GMT
Content-Type: application/json
Content-Length: 5350
Connection: keep-alive
Vary: Accept-Encoding
access-control-allow-origin: https://emds.sqemc.com:8443
access-control-allow-methods: POST, GET, PUT, DELETE, OPTIONS
access-control-allow-headers: Access-Control-Allow-HeadersAuthorization, Content-Type, Accept, Origin, User-Agent, DNT, Cache-Control, X-Mx-ReqToken, Keep-Alive, X-Requested-With, If-Modified-Since
access-control-allow-credentials: true

...

...
```

```

    },
    "error_code": null,
    "execute_status": 500,
    "extra_data": [

    ],
    "marklines": [

    ],
    "msg": "SQL执行报错, 请检查SQL脚本\nSQL执行异常详情: \nError 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1500000000000000000000, 150' at line 22",
    "msg_code": 5002,
    "orderby": [
      {
        "col_name": "PLANACHIEVEMENTRATE_19534060394",
        "content": {

        },
        "dataset_field_id": "3a10273b-7211-1deb-19a0-6e8f5392f297",
        "field_source": "num",

      }
    ]
  }
}
...

```

问题 1 / 19 TOO

跨站点请求伪造

严重性:	中
CVSS 分数:	6.5
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/AN:E/XRL:XRC:XCR:XIR:XAR:XMAV:XMAC:XMPR:XMUI:XMS:XMC:XMI:XMAX
URL:	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetFianFinancePlanSettings
实体:	GetFianFinancePlanSettings (Page)
风险:	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因:	应用程序使用的认证方法不充分
固定值:	验证“Referer”头的值, 并对每个提交的表单使用 one-time-nonce

推理：测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

问题 2 / 19

跨站点请求伪造

严重性:	中
CVSS 分数:	6.5
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL:	https://emds.sqemc.com:8443/api/32010604/MoneyPlanReportGroup/GetMoneyPlanGroupApprovalData
实体:	GetMoneyPlanGroupApprovalData (Page)
风险:	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因:	应用程序使用的认证方法不充分
固定值:	验证“Referer”头的值, 并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetMoneyPlanParamValue
实体：	GetMoneyPlanParamValue (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02209901/Common/enableRiskMain
实体：	enableRiskMain (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02200201/Provider/enableYcg
实体：	enableYcg (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetCacheManager
实体：	SetCacheManager (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

问题 7 / 19

TOC

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetExportParam
实体：	SetExportParam (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

问题 8 / 19

TOC

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02201601/KhRule/GetUsedProviderTypeInfo
实体：	GetUsedProviderTypeInfo (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

问题 9 / 19

TOC

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02201601/KhRule/GetKhRuleList
实体：	GetKhRuleList (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200307/CgSolutionSimple/GetNodeList
实体：	GetNodeList (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02201204/BaseBidPriceAdjust/IsAdmin
实体：	IsAdmin (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200302/CgSolution/GetNodeList
实体：	GetNodeList (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppCardAjaxHandler/LoadData
实体：	pageId (Parameter)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的 CSRF 令牌。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/CurrentUserExistsDataMaskingRights
实体：	CurrentUserExistsDataMaskingRights (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IsSyncProviderUser2MyUser
实体：	IsSyncProviderUser2MyUser (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/chart/data
实体：	t (Parameter)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的 CSRF 令牌。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/BusinessModelsOP
实体：	BusinessModelsOP (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.PublicServices.OrganizationUserImpAppService/GetIntegratedLicenseUserKindTitle
实体：	GetIntegratedLicenseUserKindTitle (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IntegrationCategoryManager
实体：	IntegrationCategoryManager (Page)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的“Referer”头。

“X-Content-Type-Options”头缺失或不安全	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MAX
URL:	https://emds.sqemc.com:8443/
实体：	emds.sqemc.com (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	将服务器配置为使用值为“nosniff”的“X-Content-Type-Options”头

推理： AppScan 检测到“X-Content-Type-Options”响应头缺失或具有不安全值，这可能会更大程度地暴露于偷渡式下载攻击之下
未经处理的测试响应：

```
...
Accept-Language: en-US
Cookie: *=1776317276.932.87.724128|f4aafdb70292d200d9aa72f9f2bd29be
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d1be3
Referer: https://emds.sqemc.com:8443/gzt/oauth2/refreshToken?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Femds.sqemc.com%253A8443%252Fpapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7doe3002734%26client_id%3Dplatform
Content-Length: 0

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:51 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 03263085d2e94ac9b44841092999c339
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

会话 cookie 中缺少 HttpOnly 属性	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	LoginSite (Cookie)
风险：	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务
原因：	Web 应用程序设置了缺少 HttpOnly 属性的会话 cookie
固定值：	向所有会话 cookie 添加“HttpOnly”属性

推理： AppScan 发现所用的会话 cookie 没有“HttpOnly”属性。
原始响应

```
...

Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: emcLanguage=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/
Set-Cookie:
platform user token=eyJraWQiOiJ4Yy1xGdhLWlkYyIsImFsZyI6IiJ1JmJpU2In0.eyJ1YmYiOiJlZGE3NzYzMTc1NDAsInVzZzI6ImFkbWluIiwic2Nlcl9uYW11Ijo1570757uf566h550G5ZGYIiwiaXNzIjoiaHR0ch
M6XC9cL2VtZHMjc3FlbWMyY29tOjg0NDNcL2Flc2VvY2dlawQioiIOMjM2S0Z0WUJlTQ2YktYTM5ZS1iOTI5YTA2YTg0ZTg1LCJzb3VyY2UiOiJwYyIsImV4cCI6MTc3NjMzNTYwMDwidG9rZW5fdHlwZSI6ImFj
Y2Vzcl90b2t1biIsImh0cCI6MTc3NjMzNTYwMDwianRpIjo1... path=/
Set-Cookie: LoginTenant=qhgg; max-age=31104000; path=/
Set-Cookie: LoginSite=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3; max-age=31104000; path=/

{
  "action": "redirect",
  "isSelectTenants": false,
  "tenants": [

  ],
  "redirectUrl": "https://emds.sqemc.com:8443/auth/oauth2/callback?code=KZZZgglfbOhTYFE88CwsCDZhyEihBh0KZLzOtITK0f_A5MMzv3mc_G19IShf9QZRoqv6r00C03Qsb47-
mIx4xV3vNk8taA1lM5fDiqlTu3lm9-T80m6Pkpt5mLFUCs&state=c83cd28bd-e453-4057-81d9-94628898a541&redirect_uri=https%3a%2f%2fernds.sqemc.com%3a8443%2fstcd%2f03011401%2f08dc5cec-6593-
4af6-8de4-8bf200fca00a",
  ...
```

会话 cookie 中缺少 HttpOnly 属性	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/
实体：	_userHash (Cookie)
风险：	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务
原因：	Web 应用程序设置了缺少 HttpOnly 属性的会话 cookie
固定值：	向所有会话 cookie 添加“HttpOnly”属性

推理： AppScan 发现所用的会话 cookie 没有“HttpOnly”属性。
原始响应

```
...

Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: ea6885530e4a44ab9bf53439c505aeb
X-ERP-Version: 600
```

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: userHash=2021465632; expires=Fri, 16 Apr 2027 05:33:19 GMT; path=/
Set-Cookie: userToken_Core=CfDJ8J_vUfkn2vtEvcxouLLlCfDs5J2SDZhek_q3lT6494SDyZlNga9xlnRTGxpp0mzoXoeAb26Yf4jVytLxYUtWG9gxYWSHb863R0VA3IWtmKhQeSjhF8H3ciwqjm0jx-qfX6TH_VIlyh04Qkf3fDuNRLMk3CBg22wtidBx_Vix0MbrGcNEZDFt_HpXipn7NRGjuZaVuNMAZt7dKl4CunXPKFOzTVP9ImtiqAL9XMHCOXA7zycZkneUtYBQmB9hHQ-0z7xtwktJfLF5a0ClejElVtPIax4waB8jt34auXHeZa55mmyqgKJO1XKt5fmWUjPdVtr9Dpi88U4Mxjm_TBCTTgC6gFUh1wZ7A9WKLcTVrBe7z6dL3CNPFQU... path=/; httponly

...
```

问题 1 / 1

TOC

发现 Web 应用程序源代码泄露模式	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/POfs/3rd/login.js
实体:	login.js (Page)
风险:	可能会检索服务器端脚本的源代码，这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息
原因:	在生产环境中留下临时文件 程序员在 Web 页面上留下调试信息 未安装第三方产品的最新补丁或最新修补程序
固定值:	除去 web-server 中的源代码文件并应用任何相关补丁

推理： 响应包含可能会泄露有关站点和应用程序逻辑的敏感信息的脚本文件源代码。

未经处理的测试响应：

```
...
...t\)\ \+\n'';/g,W=/&(?amp;[lt|gt|quot|#39);/g,G=/[<>'"]/g,Y=RegExp(W.source),J=RegExp(G.source),X=/<[^\s\S]+?>/g,Z=/<[^\s\S]+?>/g,Q=/<[^\s\S]+?>/g,ee=/\.\|\\[(?:
[^\[\]]*|(['"])(?:?!\\1)[^\[\]]*\1|\\.)?\\1\\)/,te=/^w*$/;ne=/[^\.[\]]+|[(?: (...
...

```

问题 1 / 34

TOC

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/login
实体：	login (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:51 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 03263085d2e94ac9b44841092999c339
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/version.json
实体：	version.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:59 GMT
Content-Type: application/json
Content-Length: 26
Connection: keep-alive
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "la"
x-fast-trace-id: 782874281e054b35b4fd736994c3c043
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "version": 1769673696395
}
```

...}

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/pub/03011407/topNav/getMessageCount
实体:	getMessageCount (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:56 GMT
Content-Type: application/json
Content-Length: 98
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
x-fast-trace-id: 9122976ad2184835b9629724d72131f5
X-ERP-Version: 600
x-my-TraceID: 9122976ad2184835b9629724d72131f5
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  "message": "成功",
  "success": true,
  "error": null,
  "data": {
    ...
  }
}
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/PO/widgets/news/manifestjson
实体:	manifestjson (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:06 GMT
Content-Type: application/json
Content-Length: 816
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "330"
x-fast-trace-id: b2900c2550a048cf86e10f723ca97abd
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

"name": "企业新闻",
...
}
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/PO/widgets/notice/manifest.json
实体:	manifest.json (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理：应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 819
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "333"
x-fast-trace-id: 09509a8ceee641b59362f2a77e654bee
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

"name": "企业公告",
...
}
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/widgets/functionList/manifest.json
实体：	manifest.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 187
Connection: keep-alive
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "bb"
x-fast-trace-id: 480bc0cad30e45df956dc1d477f75ca3
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

  "name": "常用功能",

  ...
}
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/widgets/messageCenter/manifest.json
实体：	manifest.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 486
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
```

ETag: "1e6"
x-fast-trace-id: 56d6fbd76dcc47cc9863723f50be2152
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

"name": "消息中心",
...
}

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/32010650/81a01160-efa5-454f-509a-08da4c3076e6
实体:	81a01160-efa5-454f-509a-08da4c3076e6 (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理：应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:11 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 6274aef5cf594cc7a5290ec817c11a14
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml
实体:	GetHtml (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理：应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:16 GMT
Content-Type: text/html
Content-Length: 34577
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=86400
x-fast-trace-id: e080fe0632e947628e28a1200f3e33dd
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MAX
URL:	https://emds.sqemc.com:8443/std/32010604/08dacec8-4ad1-41eb-8a87-fc79865b5b56
实体：	08dacec8-4ad1-41eb-8a87-fc79865b5b56 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:27 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: eca93b0dbb114288b63f741bfdf53682
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MAX
URL:	https://emds.sqemc.com:8443/std/32010652/08db82a4-f76-43ff-80cd-70ffe3d0217e
实体：	08db82a4-f76-43ff-80cd-70ffe3d0217e (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:35 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: cadc20a343194cd8b898cd2c6aa7e4a9
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sgemc.com:8443/std/02200103/a43977ee-bc61-e911-9b41-001a7dda7111
实体：	a43977ee-bc61-e911-9b41-001a7dda7111 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:46 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 1c776f7c51af47758071e2227db95855
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/PubPlatform/SysSetting/MD0002105/bizparam
实体：	bizparam (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:52 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 4db7a92a68774473b17ba6dc5e22f374
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/02200105/1426487d-bfe1-ea11-9838-54e1adb0f0f
实体：	1426487d-bfe1-ea11-9838-54e1adb0f0f (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:54 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 182388e67d714155ae0053d5d981337d
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/02200201/8713a59f-0b9a-e911-aa80-54e1adee7d63
实体:	8713a59f-0b9a-e911-aa80-54e1adee7d63 (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:07 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 0c01874bb0184fd69a7ea313c0de033e
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/03011407/setting/globalCss
实体:	globalCss (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:25 GMT
Content-Type: text/css
Content-Length: 792
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Cache-Control: public, max-age=31536000
x-fast-trace-id: 20d65c93e70f44969c49c06c47ee343f
X-ERP-Version: 600
x-my-TraceID: 20d65c93e70f44969c49c06c47ee343f
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

```
:root{
--primaryColor:#266eff;
--navBackgroundColor:#266eff;
--navActiveBackgroundColor:#2265ed;
...
}
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/static/08dc4e04-a714-4971-86ae-2cd2852308c4/codingpage/08dc5cec-6593-4ad7-84fc-b29a58a47bd8.js
实体:	08dc5cec-6593-4ad7-84fc-b29a58a47bd8.js (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:27 GMT
Content-Type: application/javascript; charset=utf-8
Content-Length: 4130
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
X-ERP-Version: 600
X-StaticFileHandler: 31536000second
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/03011407/setting/page/config
实体:	config (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
```

```
Date: Thu, 16 Apr 2026 05:30:27 GMT
Content-Type: application/javascript; charset=UTF-8
Content-Length: 144868
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Cache-Control: public, max-age=86400
x-fast-trace-id: ff720785a5a14145b7fd41ddb8ed760
X-ERP-Version: 600
x-my-TraceID: ff720785a5a14145b7fd41ddb8ed760
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

var EMC_CONFIG = {"isShowPersonalSettings":true,"logoutUrls":["https://emds.sqemc.com:8443/bpm/api/sso/logout"],"customServiceSetting":{"loader":"/EO/js/3rd/emc-ai-loader.js?v=19d941f491d","enableRefu":true,"enableAI":true},"brandConfig":{"navTitle":"投建营一体化平台","navLogoImage":null,"siteIcon":null,"themeLayoutModel":"concise-full-left-nav"},"isShowExit":true,"menus":[{"top_nav_code":null,"nav_code":"de83215f-ba6....
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/std/02201603/08daf383-e025-4769-846d-c6ac16e3e78b
实体:	08daf383-e025-4769-846d-c6ac16e3e78b (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:30 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 937a6d88aac7470988c23671ee21acff
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/Cgzib/ProviderAssess/M02201601/KhRuleForm/KhRuleForm
实体：	KhRuleForm (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:36 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: f06c0cb5e1404f4faaef80abe5928366
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/02201604/08db0d8b-7f4f-4abe-863c-8da6af976f0c
实体：	08db0d8b-7f4f-4abe-863c-8da6af976f0c (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:38 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: f204b6ec18b542d5bbe35d356f32cd66
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.ThemeSettingsAppService/GetCustomizeThemeBySiteld
实体：	GetCustomizeThemeBySiteld (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:25 GMT
Content-Type: text/css
Content-Length: 395106
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
x-fast-trace-id: 5f6ae22d542146c1b3bdlf5370f5e906
X-ERP-Version: 600
X-StaticFileHandler: 31536000second
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

@charset "UTF-8";.hc-image-upload_item:hover{border-color:#266EFF}.el-checkbox .el-checkbox_input.is-checked:not(.is-disabled) .el-checkbox_inner{background-color:#266EFF;border-color:#266EFF}.el-checkbox .el-checkbox_input.is-focus .el-checkbox_inner,.el-checkbox .el-checkbox_input .el-checkbox_inner:hover{border-color:#266EFF}.el-checkbox .el-checkbox_input.is-indeterminate .el-checkbox_inner{background-color:#266EFF;border-color:#266EFF}.hc-checkbox .hc-checkbox_input:not(.is-disabled).is-checked .hc-checkbox_inner{background-color:#266EFF;border-color:#266EFF}.hc-checkbox .hc-checkbox_input:not(.is-disabled).is-focus .hc-checkbox_inner{border-color:#266EFF}.hc-checkbox .hc-checkbox_input:not(.is-disabled) .hc-checkbox_inner:hover{border-color:#266EFF}.hc-checkbox .hc-checkbox_input:not(.is-disabled).is-indeterminate .hc-checkbox_inner{background-color:#266EFF;border-color:#266EFF}.hc-checkbox:hover .hc-checkbox_input:not(.is-disabled) .hc-checkbox_inner{border-color:#266EFF}.fc-table .fc-table-checkbox.is-checked,.fc-table .fc-table-checkbox.is-indeterminate{background-color:#266EFF;border-color:#266EFF}.fc-table .fc-table-checkbox:hover{border-color:#266EFF}.el-radio .el-radio_input.is-checked:not(.is-disabled) .el-radio_inner{border-color:#266EFF}.el-radio .el-radio_input.is-checked:not(.is-disabled) .el-radio_inner:after{background-color:#266EFF}.el-radio...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/_frontend/sea-config.js
实体：	sea-config.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:51 GMT
Content-Type: application/javascript
Content-Length: 179503
Connection: keep-alive
```

```
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
Last-Modified: Thu, 16 Apr 2026 03:53:44 GMT
Accept-Ranges: bytes
ETag: "1d0cd549ed7e92f"
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 1year
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

var __lang = !!window.Mysoft ? window.Mysoft.Map6.UI.page.lang : "";
var __tenantCode=Mysoft.Map6.UI.page.tenantCode;
var __langhash = !!window.Mysoft ? window.Mysoft.Map6.UI.page.langhash : "";
var query= "&lang=" + __lang;
...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/static/6807139e-1939-4353-d61e-08da49468f55/wuetemplate/71b1e5d2-bd54-4d55-5099-08da4c3076e6.js
实体:	71b1e5d2-bd54-4d55-5099-08da4c3076e6.js (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:52 GMT
Content-Type: application/javascript; charset=utf-8
Content-Length: 3773
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
X-ERP-Version: 600
X-StaticFileHandler: 31536000second
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/32010604/febfeb58-34fc-44ee-5bc8-08dad0e746f6
实体：	febfeb58-34fc-44ee-5bc8-08dad0e746f6 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:00 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 717f74d3c6e74f31bbd698dbb391ad33
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/dp/api/home_page/list
实体：	list (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:33:21 GMT
Content-Type: application/json
Content-Length: 114
Connection: keep-alive
x-dap-upstream-latency: 1045
Strict-Transport-Security: max-age=31536000; includeSubDomains
Set-Cookie: dnp_env_code=xc-qhgg-idx; Domain=emds.sqemc.com; Path=/dp
Set-Cookie: yl-fab=""; Domain=sqemc.com; Max-Age=-1; Path=/dp

{
  "result": true,
  "msg": null,
  "data": {
    "items": [

  ],
  "total": 1,
}
```

```
"env_code": "xc-qhgg-ids",
"auth_mode": "normal"
...
```

发现可高速缓存的 SSL 页面

严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/Cgzib/ProviderManage/M02200201/ProviderCompare/ProviderCompareIframe
实体:	ProviderCompareIframe (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理：应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:22 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 66a08337141e4a5f9f641348ae18aad1
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面

严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/dp/api/app_menu/app/get_relation
实体:	get_relation (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理：应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:37 GMT
Content-Type: application/json
Content-Length: 96
Connection: keep-alive
```

```
x-dap-upstream-latency: 24
Strict-Transport-Security: max-age=31536000; includeSubDomains

{
  "result": false,
  "msg": "没有权限操作该资源, 请联系管理员开通权限",
  "code": 500
}...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/dp/api/released_dashboard_chart/project/info
实体:	info (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题, 可以阻止高速缓存 SSL 页面。

推理: 应用程序已进行响应, 指示该页面应进行高速缓存, 但未设置高速缓存控件 (可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存)。

未经处理的测试响应:

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:40 GMT
Content-Type: application/json
Content-Length: 106
Connection: keep-alive
cache-control: no-cache
x-dap-upstream-latency: 3
Strict-Transport-Security: max-age=31536000; includeSubDomains

{
  "result": false,
  "msg": "访问受限, 组织机构代码不一致, 请联系管理员处理!",
  "code": 408
}...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/dp/api/app_menu/app/get
实体:	get (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题, 可以阻止高速缓存 SSL 页面。

推理: 应用程序已进行响应, 指示该页面应进行高速缓存, 但未设置高速缓存控件 (可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存)。

未经处理的测试响应:

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:37 GMT
Content-Type: application/json
Content-Length: 96
Connection: keep-alive
x-dap-upstream-latency: 24
Strict-Transport-Security: max-age=31536000; includeSubDomains

{
  "result": false,
  "msg": "没有权限操作该资源, 请联系管理员开通权限",
  "code": 500
}...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/dp/bi-visual/chartlibs/components.json
实体:	components.json (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:40 GMT
Content-Type: application/json
Content-Length: 230874
Connection: keep-alive
Vary: Accept-Encoding
Last-Modified: Thu, 29 Jan 2026 11:01:19 GMT
ETag: "697b3dff-385da"
x-dap-upstream-latency: 0
Expires: Fri, 16 Apr 2027 05:31:40 GMT
Cache-Control: max-age=31536000
Access-Control-Allow-Origin: *
Accept-Ranges: bytes
Strict-Transport-Security: max-age=31536000; includeSubDomains

[
  {
    "name": "i18n 经纬度楼栋图",
    "icon": "/platform/icon/icon.svg",
    "package": "3d_map",
    ...
  }
]
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/Pubplatform/SysSetting/M00002105/bizparam
实体：	bizparam (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:40 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 59c87810bec244bbacd8ec88e3c27c0
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/02200308/08dc4246-562e-49b4-8864-54313a31b750
实体：	08dc4246-562e-49b4-8864-54313a31b750 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:12 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 85aa6bc4d6324c499adfa9f0daf2fadf
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/02200911/5cf49f23-3d86-ea11-aa7f-54e1ade4a50e
实体:	5cf49f23-3d86-ea11-aa7f-54e1ade4a50e (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:27 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 94e630ec4d274b58bf0b27d04d3d170f
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

低

在CSP中未强制执行脚本中的可信类型 58

TOC

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/login
实体:	login (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:48 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: fb481a993089470591a64de2951a4a2f
```

X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/PO/version.json
实体:	version.json (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理: 缺少需要信任类型的 'script'
未经处理的测试响应:

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:59 GMT
Content-Type: application/json
Content-Length: 26
Connection: keep-alive
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "1a"
x-fast-trace-id: 782874281e054b35b4fd736994c3c043
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "version": 1769673696395
}...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/pub/03011407/topNav/getMessageCount
实体:	getMessageCount (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理: 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:56 GMT
Content-Type: application/json
Content-Length: 98
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
x-fast-trace-id: 9122976ad2184835b9629724d72131f5
X-ERP-Version: 600
x-my-TraceID: 9122976ad2184835b9629724d72131f5
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  "message": "成功",
  "success": true,
  "error": null,
  "data": {
    ...
  }
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/gzt/oauth2/refreshToken
实体：	refreshToken (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 302 Found
Date: Thu, 16 Apr 2026 05:28:59 GMT
Content-Length: 0
Connection: keep-alive
Location: /login?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Femds.sqemc.com%253A8443%252Fpapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7doe3002734%26client_id%3Dplatform
x-fast-trace-id: e2ec86a20ddb4911b5a3247d9dd78791
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

GET /login?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%3Dhttps%253A%252F%252Femds.sqemc.com%253A8443%252Fpapaas-auth%252Foauth2%252Fportal%253Fredirect_uri%253D%25252F%26response_type%3Dcode%26state%3D21a2adee-c79a-4aaf-9995-a7doe3002734%26client_id%3Dplatform HTTP/1.1
Cookie: *=1776317276.932.87.724128|f4aafdb70292d200d9aa72f9f2bd29be
Accept-Language: en-US
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3d8e3
Referer: https://emds.sqemc.com:8443/gzt/oauth2/refreshToken?request_id=73bb2286-790a-4bae-85e5-53de86d020c8&redirect_uri=https%3A%2F%2Femds.sqemc.com%3A8443%2Fauth%2Foauth2%2Fauthorize%3Fredirect_uri%...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/03011401/08dc5cec-6593-4af6-8de4-8bf200fca00a
实体：	08dc5cec-6593-4af6-8de4-8bf200fca00a (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:51 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: 39506681d07749acab2868dfb5e119a2
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Set-Cookie: _userHash=2021465632; expires=Fri, 16 Apr 2027 05:28:50 GMT; path=/
Set-Cookie: userToken_Core=CfDJ8J vUFkn2vtEvcxulLlCfDusVnGPF5oBEFBqOm8Zst_yudgMpEh3S8SXx4-
9Sw4oVvUBCyPiEIV7XlX3Sz5znf8gxoHsxLHB8tSY5br7jgtNuntxjHzhLyjYK64WGSuDuUAzqPbxFDwIOOGItEgsszczm7rMg3VOb4L_jIMIWBCFLH1T5dvEX6Az0m0kuTOIU055wkm2x4Mx_-
kkqyRqujgaizu9xwtUUwswS5WziFi0snJ99R0dwPcYmYAOFOXm4E6a2nUQcM5QkL1u6jZKDH0F0dsuysvJY4d3-NzZt1WPU561JnO_8WgP1J6xKF6C4buuTYThbC8VBBENKIjseXi1-
fqbhBBWvIogMAzy142RhBGExPLBOuEBI... path=/; httponly
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.PubPlatform.Nav.Handlers.WorkBenchLoginHandler/DoLogin
实体：	DoLogin (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:28:51 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 467c2da7c1784d1790a96cf3c6b9234c
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/widgets/news/manifest.json
实体：	manifest.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:06 GMT
Content-Type: application/json
Content-Length: 816
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "330"
x-fast-trace-id: b2900c2550a048cf86e10f723ca97abd
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

  "name": "企业新闻",
  ...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/widgets/notice/manifestjson
实体：	manifest.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 819
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "333"
x-fast-trace-id: 09509a8ceee641b59362f2a77e654bee
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

  "name": "企业公告",
  ...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/PO/widgets/functionList/manifest.json
实体：	manifest.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 187
Connection: keep-alive
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "bb"
```

```
x-fast-trace-id: 480bc0cad30e45df956dc1d477f75ca3
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

  "name": "常用功能",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/PO/widgets/messageCenter/manifest.json
实体:	manifest.json (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: application/json
Content-Length: 486
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Mon, 01 Jan 1601 00:00:00 GMT
Accept-Ranges: bytes
ETag: "1e6"
x-fast-trace-id: 56d6fbd76dcc47cc9863723f50be2152
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{

  "name": "消息中心",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/32010650/81a01160-efa5-454f-509a-08da4c3076e6
实体:	81a01160-efa5-454f-509a-08da4c3076e6 (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:07 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 2c77514f91fd46e484e819b90c540ee3
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/GetHtml
实体:	GetHtml (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:16 GMT
Content-Type: text/html
Content-Length: 34577
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=86400
x-fast-trace-id: e080fe0632e947628e28a1200f3e33dd
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/Mi:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppGridAjaxHandler/GetHtml
实体：	GetHtml (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保険号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:29:10 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044649279384977408]到 [异常日志]搜索异常详情。",
  "html": "<!DOCTYPE html>\n<html>\n  <head>\n    <meta http-equiv=\"Content-Type\" content=\"text/html; charset=utf-8\" />\n    <title>明源云ERP</title>\n    <meta http-equiv=\"X-UA-Compatible\" content=\"IE=Edge\" />\n    <meta name=\"renderer\" content=\"webkit\" />\n    <script>\n      document.writeln('<link rel=\"shortcut icon\" href=\"/ajax/Mysoft.PubPlatform.Nav.Handlers.LoginHandler/SiteIcon? t=45550395\"/>');\n    </script>\n    <style type=\"text/css\">\n      body {\n        margin: 0;\n        padding: 0;\n        color: #222;\n        font-family: \"PingFang SC\", \"Microsoft Yahei\", Verdana, simsun, Arial, Helvetica, sans-serif;\n        font-size: 14px;\n      }\n      body.error-page-wrapper .error-page-details {\n        top: 8px;\n      }\n      ::-webkit-scrollbar {\n        width: 6px;\n        height: 6px;\n      }\n      ::-webkit-scrollbar-thumb:vertical {\n        background-color: rgba(0, 0, 0, 0.12);\n        border-radius: 3px;\n      }\n      a {\n        a:link {\n          color: #266eff;\n        }\n        a:hover {\n          text-decoration: none;\n        }\n      }\n      .error-page-desc {\n        text-align: center;\n        position: absolute;\n        height: 264px;\n        top: 50%;\n        margin-top: -132px;\n        width: 100%;\n      }\n      .error-page-desc p {\n        margin: 0;\n        margin-bottom: 8px;\n        line-height: 14px;\n        color: #999;\n        font-size: 13px;\n      }\n      .error-page-desc _icon {\n        height: 125px;\n        display: inline-block;\n        background: url(data:img/jpg;base64,iVBORw0KGgoAAAANSUHEUgVAAARYAAAB9CAYAAABnClxiAAAAAANSR0IARs4c6QAMFZJREfUeAhtnQmczdK7x++MZcZ09pClSWYnkKtSILEst0iX9GmfyV+2kv0a6eQJvTk1F8SQmi-jQNUwyK4IQGxcj/78/87uj0+Pu9/u9c8ec7+t17vd7v99zrvOc5zznOc95znPoiXK3y1DAUMAvQpw/fz56/PjxLc+ePVs7W7Zs9QgVo6KiSvK+2L1z5wzxPob/5wF2rns5wtm06Gd3PfWfeuZM2c2c4/Pnj376rvuumu3X5lm0kRmRRvg7ahg00UQGBevfFeew0QdH0QIr...
      }
    }
  }
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/Mi:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.Controls.SubControls.FilterAppService/LoadFilter
实体：	LoadFilter (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保険号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:29:10 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
```

```
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "message": "系统发生异常,请使用错误编号 [2044649280282558464] 到 [异常日志] 搜索异常详情。",
  "html": "<html>\n  <head>\n    <title>ERP错误报告</title>\n    <meta http-equiv=\"X-UA-Compatible\" content=\"IE=Edge\" />\n    <script>\n      document.writeln('<link\nrel=\"shortcut icon\" href=\"/ajax/Mysoft.PubPlatform.Nav.Handlers.LoginHandler/SiteIcon?_t=34294934\"/>');\n    </script>\n    <style>\n      body {\n        font-family:\n        \"PingFang SC\", \"Microsoft Yahei\", Verdana, simsun, Arial,\n        Helvetica, sans-serif;\n      }\n      .error-text {\n        position: relative;\n        top:\n        10px;\n        font-size: 18px;\n        color: #333333;\n        font-style: normal;\n        font-weight: 400;\n        line-height: 26px;\n        font-family: \"PingFang\nSC\", \"Microsoft Yahei\", Verdana, simsun, Arial,\n        Helvetica, sans-serif;\n      }\n      .error-header {\n        font-size:\n        16px;\n        color: #222;\n        margin-top: 15px;\n      }\n      .error-reason {\n        font-size: 14px;\n        color: #999;\n        line-height: 20px;\n        margin-top: 10px;\n      }\n      .error-content {\n        text-align: center;\n      }\n      .error-content_inner {\n        display: inline-block;\n        text-align:\n        left;\n      }\n      .error-des_one {\n        margin-top: 5px;\n        text-align: left;\n        font-size: 14px;\n        color: #999;\n      }\n      .error-page .online-errorTip {\n        display: block;\n        margin: 0;\n        margin-\ntop: 20px;\n        color: #999;\n        font-size: 13px;\n        line-height: 22px;\n      }\n      .error-page a {\n        color: #266eff;\n        text-decoration:\n        none;\n      }\n      .error-page a:hover {\n        text-decoration: underline;\n      }\n      .quick-switch {\n        padding: 5px 12px;\n        justify-content:\n        center;\n        align-items: center;\n        border-radius: 4px;\n        background: #266eff;\n        border: none;\n        ...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.Map6.Modeling.AppServices.Controls.ProjectTreeAppService/GetProjectSelect
实体：	GetProjectSelect (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:42 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: d81fc4c6e18f4fe18c34b042a5a6645a
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

[
  {
    "isLeaf": true,
    "isSelected": false,
    "isAllowSelect": false,
    ...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetFianFinancePlanSettings
实体：	GetFianFinancePlanSettings (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:34 GMT
Content-Type: application/json
Content-Length: 302
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: a548a992d9ac41dd9ddbdc738d182475
X-ERP-Version: 600
x-my-TraceID: a548a992d9ac41dd9ddbdc738d182475
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  ...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppTreeGridAjaxHandler/LoadData
实体：	LoadData (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 500 Internal Server Error
Date: Thu, 16 Apr 2026 05:29:19 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
```


在CSP中未强制执行脚本中的可信类型

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/32010604/08dacec8-4ad1-41eb-8a87-fc79865b5b56
实体：	08dacec8-4ad1-41eb-8a87-fc79865b5b56 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:23 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 58ed0d75dfab41039cbc400db7372c7f
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/32010604/MoneyPlanReportGroup/GetMoneyPlanGroupApprovalData
实体：	GetMoneyPlanGroupApprovalData (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:14 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: ded9ecee9616427d8b54269f777b36e3
X-ERP-Version: 600
x-my-TraceID: ded9ecee9616427d8b54269f777b36e3
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

```
{
  "code": "0",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/32010650/MoneyPlanSettings/GetMoneyPlanParamValue
实体:	GetMoneyPlanParamValue (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:34 GMT
Content-Type: application/json
Content-Length: 70
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 1f41e11310bd4fd38c9d5a29f91796d7
X-ERP-Version: 600
x-my-TraceID: 1f41e11310bd4fd38c9d5a29f91796d7
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/32010652/08db82a4-f76-43ff-80cd-70ffe3d0217e
实体:	08db82a4-f76-43ff-80cd-70ffe3d0217e (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:32 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 06e2298a438d4a178b34e75e7fb126ac
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sgemc.com:8443/std/02200103/a43977ee-bc61-e911-9b41-001a7dda7111
实体：	a43977ee-bc61-e911-9b41-001a7dda7111 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:41 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 12fdeab281db4224b28095ab15d7c687
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sgemc.com:8443/PubPlatform/SysSetting/MD0002105/bizparam
实体：	bizparam (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:44 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: a91063190edd4b68bd1133e6754202e
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL：	https://emds.sgemc.com:8443/std/02200105/1426487d-bfe1-ea11-9838-54e1adb0f0f
实体：	1426487d-bfe1-ea11-9838-54e1adb0f0f (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:29:47 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 68354b16e5974delb2f511964959b43b
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/02200201/8713a59f-0b9a-e911-aa80-54e1adee7d63
实体：	8713a59f-0b9a-e911-aa80-54e1adee7d63 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:03 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: d8fb23e226e24b778c9d19c8d4e52831
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02209901/Common/enableRiskMain
实体：	enableRiskMain (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:57 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 6011e14ed54d4703ae8a31720fab4f8e
X-ERP-Version: 600
x-my-TraceID: 6011e14ed54d4703ae8a31720fab4f8e
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

```
{
  "code": "0",
  ...
}
```

问题 28 / 58

TOC

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02200201/Provider/enableYcg
实体:	enableYcg (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:13 GMT
Content-Type: application/json
Content-Length: 72
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 2f27a9603c684ee18c66923c79de1af0
X-ERP-Version: 600
x-my-TraceID: 2f27a9603c684ee18c66923c79de1af0
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

问题 29 / 58

TOC

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/ajax/Mysoft.Map6.Modeling.Controls.AppCard/Ajax-Handler/LoadData
实体:	LoadData (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:14 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: a2960b43851d4543a254611bb1dd7ac9
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "labelConfig": [
  ],
  "titleConfig": [
  ],
  "data": [
  ]
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sgemc.com:8443/api/02200201/ProviderGlobalSearch/SetCacheManager
实体：	SetCacheManager (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:14 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sgemc.com:8443
x-fast-trace-id: ded9ecce9616427d8b54269f777b36e3
X-ERP-Version: 600
x-my-TraceID: ded9ecce9616427d8b54269f777b36e3
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sgemc.com:8443

{
  "code": "0",
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200201/ProviderGlobalSearch/SetExportParam
实体：	SetExportParam (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:16 GMT
Content-Type: application/json
Content-Length: 82
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: f997c443bb1d4b95ad94f1a77ea8fb2f
X-ERP-Version: 600
x-my-TraceID: f997c443bb1d4b95ad94f1a77ea8fb2f
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/03011407/setting/globalCss
实体：	globalCss (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:25 GMT
Content-Type: text/css
Content-Length: 792
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
```

```
Cache-Control: public, max-age=31536000
x-fast-trace-id: 20d65c93e70f44969c49c06c47ee343f
X-ERP-Version: 600
x-my-TraceID: 20d65c93e70f44969c49c06c47ee343f
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

:root{
--primaryColor:#266eff;
--navBackgroundColor:#266eff;
--navActiveBackgroundColor:#2265ed;
...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/POjs/3rd/login.js
实体：	login.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:26 GMT
Content-Type: application/javascript
Content-Length: 1352537
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=1800
Last-Modified: Thu, 16 Apr 2026 03:37:37 GMT
Accept-Ranges: bytes
ETag: "1d0cd525e6075d9"
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 30minute
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

(function(){
"use strict";
var commonjsGlobal$1="undefined"!==typeof globalThis?globalThis:"undefined"!==typeof window?window:"undefined"!==typeof global?global:"undefined"!==typeof self?self:{};function getDefaultExportFromCjs(e){return e&&e.__esModule&&Object.prototype.hasOwnProperty.call(e,"default")?e.default:e}function getAugmentedNamespace(e){if(e.__esModule)return e;var t=e.default;if("function"===typeof t){var n=function e(){return this instanceof e?Reflect.construct(t,arguments,this.constructor):t.apply(this,arguments)};n.prototype=t.prototype}else n={};return Object.defineProperty(n,"__esModule",{value:!0}),Object.keys(e).forEach((function(t){var r=Object.getOwnPropertyDescriptor(e,t);Object.defineProperty(n,t,r.get?r:{enumerable:!0,get:function(){return e[t]}})})),n)var check=function(e){r...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/static/08dc4e04-a714-4971-86ae-2cd2852308c4/codingpage/08dc5cec-6593-4ad7-84fc-b29a58a47bd8.js
实体：	08dc5cec-6593-4ad7-84fc-b29a58a47bd8.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:27 GMT
Content-Type: application/javascript; charset=utf-8
Content-Length: 4130
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
X-ERP-Version: 600
X-StaticFileHandler: 31536000second
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/03011407/setting/page/config
实体：	config (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:21 GMT
Content-Type: application/javascript; charset=UTF-8
Content-Length: 144868
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Cache-Control: public, max-age=86400
x-fast-trace-id: 02564c1cf2084e3b9806ca865b9c3bc1
X-ERP-Version: 600
x-my-TraceID: 02564c1cf2084e3b9806ca865b9c3bc1
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

var EMC_CONFIG = {"isShowPersonalSettings":true,"logoutUrls":["https://emds.sqemc.com:8443/bpm/api/sso/logout"],"customServiceSetting":{"loader":"/FO/js/3rd/emc-ai-loader.js?"
```

v=19d941f372a","enableRefu":true,"enableAI":true},"brandConfig":{"navTitle":"投建营一体化平台","navLogoImage":null,"siteIcon":null,"themeLayoutModel":"concise-full-left-nav"},"isShowExit":true,"menus":[{"top_nav_code":null,"nav_code":"de83215f-ba6...

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/02201603/08daf383-e025-4769-846d-c6ac16e3e78b
实体：	08daf383-e025-4769-846d-c6ac16e3e78b (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:27 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 015524270b5a4f138a950c3dd3697812
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/Cgzlb/ProviderAssess/M02201601/KhRuleForm/KhRuleForm
实体：	KhRuleForm (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'

未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:31 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
```

```
x-fast-trace-id: 34d27b0e2a7f4d9d83e32da652543190
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02201601/KhRule/GetUsedProviderTypeInfo
实体:	GetUsedProviderTypeInfo (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:38 GMT
Content-Type: application/json
Content-Length: 111
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: ec6c6d543a7a4ab0a04b263343b29032
X-ERP-Version: 600
x-my-TraceID: ec6c6d543a7a4ab0a04b263343b29032
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02201601/KhRule/GetKhRuleList
实体:	GetKhRuleList (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:39 GMT
Content-Type: application/json
Content-Length: 69
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 67062d6f579b4798bc8997b2419b1ff7
X-ERP-Version: 600
x-my-TraceID: 67062d6f579b4798bc8997b2419b1ff7
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  "code": "0",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/02201604/08db0d8b-7f4f-4abe-863c-8da6af976f0c
实体：	08db0d8b-7f4f-4abe-863c-8da6af976f0c (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:33 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: d88c0c2ba67f40b69f50431e98d7c8a5
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02200307/CgSolutionSimple/GetNodeList
实体：	GetNodeList (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:09 GMT
Content-Type: application/json
Content-Length: 14218
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 69090df532f24a8982ac1f424cf0b6f0
X-ERP-Version: 600
x-my-TraceID: 69090df532f24a8982ac1f424cf0b6f0
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.ThemeSettingsAppService/GetCustomizeThemeBySiteId
实体：	GetCustomizeThemeBySiteId (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:25 GMT
Content-Type: text/css
Content-Length: 395106
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
x-fast-trace-id: 5f6ae22d542146c1b3bd1f5370f5e906
X-ERP-Version: 600
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://emds.sqemc.com:8443/_frontend/sea-config.js
实体：	sea-config.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:51 GMT
Content-Type: application/javascript
Content-Length: 179503
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
Last-Modified: Thu, 16 Apr 2026 03:53:44 GMT
Accept-Ranges: bytes
ETag: "1dcd549ed7e92f"
X-ERP-Version: 600
X-Language: zh
X-StaticFileHandler: 1year
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

var __lang = !!window.Mysoft ? window.Mysoft.Map6.UI.page.lang : "";
var __tenantCode=Mysoft.Map6.UI.page.tenantCode;
var __langhash = !!window.Mysoft ? window.Mysoft.Map6.UI.page.langhash : "";
var query= "&lang=" + __lang;
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/static/6807139e-1939-4353-d61e-08da49468f55/uemplate/71b1e5d2-bd54-4d55-5099-08da4c3076e6.js
实体：	71b1e5d2-bd54-4d55-5099-08da4c3076e6.js (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:52 GMT
Content-Type: application/javascript; charset=utf-8
Content-Length: 3773
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: public,max-age=31536000
X-ERP-Version: 600
X-StaticFileHandler: 31536000second
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/api/02201204/BaseBidPriceAdjust/IsAdmin
实体：	IsAdmin (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:57 GMT
Content-Type: application/json
Content-Length: 71
Connection: keep-alive
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 6011e14ed54d4703ae8a31720fab4f8e
X-ERP-Version: 600
x-my-TraceID: 6011e14ed54d4703ae8a31720fab4f8e
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

```
{
  "code": "0",
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/32010604/febfed58-34fc-44ee-5bc8-08dad0e746f6
实体：	febfed58-34fc-44ee-5bc8-08dad0e746f6 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:30:58 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: c33c1030955a404996a705b54dd6ce55
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/Cgzfb/ProviderManage/M02200201/ProviderCompare/ProviderCompareIframe
实体：	ProviderCompareIframe (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:13 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
```

```
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 39a2381ccf6f47d89018f1cae2ddacfe
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

...

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:U/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Nav.AppServices.SiteRedirectAppService/RedirectFunctionHomePageWithoutToken
实体:	RedirectFunctionHomePageWithoutToken (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 302 Found
Date: Thu, 16 Apr 2026 05:31:30 GMT
Content-Length: 0
Connection: keep-alive
Location: /PubPlatform/Nav/Common/OutsiteLinkPage?
functionCode=02209801&_functionName=%e7%bb%9f%e8%ae%a1%e6%8a%a5%e8%a1%a8&_nav=0220&link=https%3a%2f%2femds.sqemc.com%3a8443%2fdp%2freport-
micro%2fhome%2fapi%2fssso%2ferp%3fportal_id%3d11111111-0000-0000-0000-
000000000220%26type%3dportal&siteName=%e7%bb%8f%e8%a5%e5%88%86%e6%9e%90%e5%b9%b3%e5%8f%b0&_hid=02209801
x-fast-trace-id: ce87ae3c5c674450ald0afff07409b0b
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

GET /PubPlatform/Nav/Common/OutsiteLinkPage?
functionCode=02209801&_functionName=%e7%bb%9f%e8%ae%a1%e6%8a%a5%e8%a1%a8&_nav=0220&link=https%3a%2f%2femds.sqemc.com%3a8443%2fdp%2freport-
micro%2fhome%2fapi%2fssso%2ferp%3fportal_id%3d11111111-0000-0000-0000-
000000000220%26type%3dportal&siteName=%e7%bb%8f%e8%a5%e5%88%86%e6%9e%90%e5%b9%b3%e5%8f%b0&_hid=02209801 HTTP/1.1
Cookie: *=1776317276.932.87.724128|f4aafdb70292d200d9aa72f9f2bd29be; LoginTenant=qhgg; LoginSite=fa4095c3-8fe3-11ec-ae49-fa163eb3d3e3;
platform_user_token=eyJraWQiOiJ4Yy1xaGdhLWlkYyIsImFsZyI6IiJIMjU2In0.eyJ1bmYiOiJlZ3NzYzYzMTcyNzgsInVzZXJfY29kZSI6ImFkbWluIiwidmNlcl9uYW1lIjoia570757uf566h550G5ZGYIiwiaXNzIjoiaHR0cH
M6XC9cL2VtZHMuc3FlbWMy29tOjg0NDNcL2FlZGgiLCJlc2VyZ2dlaWQiOiI0MjMwM2ZS02OWU2LTQ2YTktYTM5ZS1iOTI5YTA2YTgtZGIJCjZv3VyY2UiOiJwYyIsImV4cCI6MTc3NjMzNTMzOQwidG9rZW5fdHlwZSI6ImFj
Y2Vzci90b2t1biIsImhhdCI6MTc3NjMzNTMzI3OwianRpIjo1..._userHash=2021465632; userToken_Core=CfDJ8J_vUfKn2...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/PubPlatform/Nav/Common/OutsiteLinkPage
实体：	OutsiteLinkPage (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:13 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: f8d06f8e54b14239b3d19735dadbac47
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/Pubplatform/SysSetting/M00002105/bizparam
实体：	bizparam (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:35 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: f1341e79c8184f58a50725b500c9585a
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/02200308/08dc4246-562e-49b4-8864-54313a31b750
实体:	08dc4246-562e-49b4-8864-54313a31b750 (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:09 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: fb1b5990774549079aca42522baf109c
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/02200302/CgSolution/GetNodeList
实体:	GetNodeList (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:09 GMT
Content-Type: application/json
Content-Length: 14218
Connection: keep-alive
Vary: Accept-Encoding
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 69090df532f24a8982ac1f424cf0b6f0
X-ERP-Version: 600
```

x-my-TraceID: 69090df532f24a8982ac1f424cf0b6f0
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

{
...
}

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/std/02200911/5cf49f23-3d86-ea11-aa7f-54e1ade4a50e
实体:	5cf49f23-3d86-ea11-aa7f-54e1ade4a50e (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:32:24 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
x-fast-trace-id: 6380074d02b64a1282d0d3e8ba10ae9a
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
...

```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IsSyncProviderUser2MyUser
实体:	IsSyncProviderUser2MyUser (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:52:41 GMT

```

```
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://ends.sqemc.com:8443
x-fast-trace-id: 0d715b4cf6b548a988f1c4c26b15834f
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

true...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://ends.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/CurrentUserExistsDataMaskingRights
实体:	CurrentUserExistsDataMaskingRights (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:52:41 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://ends.sqemc.com:8443
x-fast-trace-id: a6cd53b9ab0146b4bc9a4694ad528064
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

false...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/BusinessModelsOP
实体:	BusinessModelsOP (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:09:39 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: http://bogus.hcl.com
x-fast-trace-id: 53323181641f467da800a772356ab0aa
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

true...
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.AppServices.OrganizationUserAppService/IntegrationCategoryManager
实体:	IntegrationCategoryManager (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:52:16 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://emds.sqemc.com:8443
x-fast-trace-id: 39059cf7bcd94318a63beab4b99bae65
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
```

```
{
  "ERPOP": true,
  "ERPSAAS": false,
  "IndustrialConstruction": false,
  "SmartPark": false,
  ...
}
```

在CSP中未强制执行脚本中的可信类型	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://emds.sqemc.com:8443/api/Mysoft.PubPlatform.Organization.PublicServices.OrganizationUserImpAppService/GetIntegratedLicenseUserKindTitle
实体:	GetIntegratedLicenseUserKindTitle (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	配置具有适当值的Content-Security-Policy

推理： 缺少需要信任类型的 'script'
未经处理的测试响应：

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 06:28:57 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: *
Access-Control-Allow-Methods: GET, POST, PUT, DELETE
Access-Control-Allow-Origin: https://bogus.origin.hcl.com
x-fast-trace-id: 74f439f593664487bbb1f8883915edd4
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443

"集成用户类型"...
```

永久 Cookie 包含敏感的会话信息	
严重性：	低
CVSS 分数：	3.1
CVSS 向量：	AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/ajax/Mysoft.PubPlatform.Nav.Handlers.WorkBenchLoginHandler/DoLogin
实体：	LoginSite (Cookie)
风险：	可能会窃取保存在磁盘上作为永久 cookie 的会话信息（cookie）
原因：	Web 应用程序将敏感的会话信息存储在永久 cookie 中（磁盘上）
固定值：	避免在永久 cookie 中存储敏感的会话信息

推理： AppScan 发现会话 ID cookie 存储在客户机中。
原始响应

```
...

Content-Security-Policy: frame-ancestors https://*.sqemc.com:8443
Content-Length: 548
Set-Cookie: emcLanguage=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/
Set-Cookie:
platform user token=eyJraWQiOiJ4Yy1kaGdhLWlkYyIsImFsZyI6IiJ1bWU2In0.eyJ1bWYiOiJlZ3NzYzMTQwODYsInVzZ2ZkZjY29kZSI6ImFkbWluIiwic29udC19uYW11Ijo1570757uf566h550G5ZGYIiwiaXNzIjoiaHR0cH
M6XC9cL2VtZHMjc3FlbWMy29tOjg0NDNcL2FlcGgiLCJlc2VyaXZclawQioiIOMjM2S0Z0WU2LTQ2YTktYTM5ZS1iOTI5YTA2YTg0ZTgiLCJzb3VyY2UiOiJwYyIsImV4cCI6MTc3NjMzMjE0NiwiZG9rZW5fdHlwZSI6ImFj
Y2Vzcl90b2t1biIsImhhdCI6MTc3NjM4NDANiwiianRpIjo1... path=/
Set-Cookie: LoginTenant=qhgg; max-age=31104000; path=/
Set-Cookie: LoginSite=fa4095c3-8fe3-11ec-ae49-fa163eb3dbe3; max-age=31104000; path=/

{
  "action": "redirect",
  "isSelectTenants": false,
  "tenants": [

  ],
  "redirectUrl": "https://emds.sqemc.com:8443/auth/oauth2/callback?code=FsKZhtHC8w-
c4t2GjYe3b0vR8m019pM0Jd715yJFVDNnAKezTaK3n0TIBc611KqGSviS8T6XURdwJNrtN158W3B8vzF5hfV_eHPTw7TtWGeZiNJQnIEEK3QnpG8Yte5r&state=97467a85-2291-4f32-a62b-
9e3eb19223e0&redirect_uri=https%3a%2f%2femds.sqemc.com%3a8443%2fstcd%2f03011401%2f08dc5cec-6593-4af6-8de4-8bf200fca00a",
  ...
}
```

永久 Cookie 包含敏感的会话信息	
严重性：	低
CVSS 分数：	3.1
CVSS 向量：	AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/std/03011401/08dc5cec-6593-4af6-8de4-8bf200fca00a
实体：	_userHash (Cookie)
风险：	可能会窃取保存在磁盘上作为永久 cookie 的会话信息（cookie）
原因：	Web 应用程序将敏感的会话信息存储在永久 cookie 中（磁盘上）
固定值：	避免在永久 cookie 中存储敏感的会话信息

推理： AppScan 发现会话 ID cookie 存储在客户机中。
原始响应

```
...

Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: d1821971883a43ccb0ec9408d93177b3
X-ERP-Version: 600
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

...

TOC

TOC

严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL:	https://emds.sqemc.com:8443/
实体:	emds.sqemc.com (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	将服务器配置为使用值为 DENY 或 SAMEORIGIN 的“X-Frame-Options”头

推理: AppScan 检测到 X-Frame-Options 响应头缺失或具有不安全值, 这可能会造成跨帧脚本攻击未经处理的测试响应:

[illegible]

```
HTTP/1.1 200 OK
Date: Thu, 16 Apr 2025 05:28:50 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Vary: Accept-Encoding
Cache-Control: no-cache
Pragma: no-cache
Expires: Thu, 01 Jan 1970 00:00:00 GMT
x-fast-trace-id: a5125b6f052948779b1c050484b0e092
X-ERP-Version: 600
```

...

TOC

过度许可的 CORS 访问测试	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://emds.sqemc.com:8443/dp/bi-visual/chartlibs/components.json
实体：	components.json (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

推理： AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多
未经处理的测试响应：

```
...
4aUoTqgBjLHoxSioB72N8nkM-i59_LiX8bnhwQ1lNAHmtw5noiDys3-o7vMNzNgnAJ4lI2v_wsODryLeUDv1F-
Oy2dc1wBtoOjGiLLUp1Pg1oBShWqcuEecqzuPAwWtYHaDARoIMNa0mL90X77_1B_KxeW0AhLLfdWwjxAIAFCo3Tvd09i8KwztefK_HVnP1D-qGV-F00z6D3fyITN_qRiDPjS3SL9bYFSCiGi6gm_SEBCyuK-
eHu7adInFWoPa460kjYjwichYiDbUNPJuOHuIoi2ZTHLzTkEgue1Gi2343jwnSfQV1uwWoOwhcaAQL_g4xy6zjnK_wFCJncAAVxrl_treZ6TfkJR2z28K_I2uvc920jqETaZcsw-uQGutPPbInwjrxKiVYN...
external_params1=report_type%3Dportal%2Cportal_id%3D11111111-0000-0000-0000-000000000220%2Cproject_code%3Dqhgg
x-my-login-site: fa4095c3-8fe3-11ec-ae49-fa163eb3cbe3
Content-Length: 0

HTTP/1.1 200 OK
Date: Thu, 16 Apr 2026 05:31:40 GMT
Content-Type: application/json
Content-Length: 230874
Connection: keep-alive
Vary: Accept-Encoding
Last-Modified: Thu, 29 Jan 2026 11:01:19 GMT
ETag: "697b3dff-385da"
x-dap-upstream-latency: 0
Expires: Fri, 16 Apr 2027 05:31:40 GMT
Cache-Control: max-age=31536000

...
```

修复方法

SQL 注入

TOC

原因:

- 未对用户输入正确执行危险字符清理。
- 动态生成包含未经验证的用户输入的查询可能会导致 SQL 注入攻击。攻击者可以在用户输入中插入 SQL 命令或修饰符，从而导致以不安全的方式运行查询。
- 如果没有充分地验证并封装用户可控制的输入，则生成的 SQL 查询可能会导致这些输入被解释为 SQL 而不是普通用户数据。这种做法可用于修改查询逻辑以绕过安全检查，或插入其他可用于修改后端数据库的语句（可能包括执行系统命令）。
- SQL 有效负载可以通过任何不受信任的数据进入系统，这些数据包括用户输入、先前存储在数据库中的数据、文件、第三方 API 等。

风险:

- 可能的后果包括以下方面的损害：
- 机密性 - 由于 SQL 数据库通常用于存储敏感数据，因此丧失机密性是 SQL 注入漏洞的常见问题。
 - 身份验证 - 如果使用不良的 SQL 命令检查用户名和密码，则有可能以其他用户的身份连接到系统，而无需提前知道密码。
 - 授权 - 如果授权信息保存在 SQL 数据库中，则可以通过成功利用 SQL 注入漏洞来更改这些信息。
 - 完整性 - 正如有可能读取敏感信息一样，通过 SQL 注入攻击还可以更改甚至删除这些信息。

修订建议:

常规

使用包含参数的存储过程，以防止在数据中注入 SQL 命令，或者至少使用不允许注入代码的参数化数据库调用。请勿在存储过程中包含执行动态 SQL 的任何语句。

更好的解决方案是使用 ORM（对象关系映射）框架，例如 Hibernate 或 EntityFramework（如果平台上提供了此类框架）。

确保在服务器端验证和过滤所有用户输入，这样不仅仅可以禁止使用诸如单引号 (') 和双引号 (") 之类的不良字符，而且只允许使用安全字符。根据请求中参数的期望值严密地定义安全字符集。

对所有用户输入使用转义函数。

配置应用程序身份，以授予完成必要任务所需的最小数据库特权。加固数据库服务器以禁用任何不需要的功能，例如 shell 命令。

CWE:

89
74
707
943
20

外部引用:

OWASP - 防止 SQL 注入速查表

整数溢出

TOC

原因:

当以整数数据类型（包括字节、短、长和其他类型）存储的值过大（大于变量可容纳的最大值）的值时，将发生整数溢出（或环绕）。整数的最高有效位丢失，而其余值则相对于最小值（对于带符号类型，为 0 或负值）。

风险:

- 当发生整数溢出时，解释后的值似乎已“环绕”过最大值，然后重新设置回最小值。
- 该值可能会意外变为零或负数。如果该值用于控制循环、管理资源（例如内存分配）或制定业务逻辑决策，可能会带来安全隐患。
- 例如，当交易完成时，整数溢出可导致除购买物之外还需要向客户支付钱款。
- 尤其是，如果数学运算得出的数字大于该整数类型可能的最大值，则该值会环绕并将变量设置为零或负数。
- i=UINT_MAX+1; //无符号整数类型的变量的最大值 - 4294967295 (0xffffffff)。结果为：i=0

修订建议：

常规

验证所有输入是否在预期范围内且带有符号，然后才能依赖输入的值或在算术计算中使用这些输入。
务必同时检查上限和下限，包括带符号整数的负下限（即使是非常大的负数，也可能发生整数溢出）。
尽可能使用无符号整数。
考虑使用安全的整数处理库（例如 C/C++ SafeInt 或 IntegerLib）。
考虑启用编译器扩展，以防止出现某些种类的缓冲区溢出。

CWE:

190
707
20

外部引用：

SafeInt 库

查询中的密码参数

TOC

原因：

查询字符串中传递了敏感输入字段（例如用户名、密码和信用卡号）

风险：

可能会窃取查询字符串中发送的敏感数据，例如用户名和密码
在应用程序测试过程中，检测到查询字符串中接收到密码参数。由于登录过程所用的部分输入字段（例如：用户名、密码、电子邮件地址、社会保险号码，等等）是个人敏感信息，建议将其放在请求的主体部分或加密连接（如 SSL）中来发送到服务器。任何通过查询字符串传给服务器的信息都可能被窃，稍后可用来电子欺骗身份或伪装用户。
此外，若干隐私法规指出，用户凭证之类的敏感信息一律以加密方式传给网站。

受影响产品：

该问题可能会影响各种类型的产品

修订建议：

常规

- 1. 确保所有登录请求都在主体中（并加密）发送到服务器。
 - 2. 请确保敏感信息，例如：
 - 用户名
 - 密码
 - 社会保险号码
 - 信用卡号码
 - 驾照号码
 - 电子邮件地址
 - 电话号码
 - 邮政编码
- 始终放在请求主体中（并加密）来发送到服务器。

CWE:

523
284
522

外部引用：

金融隐私权：格拉斯-斯蒂格尔法案
健康保险可移植性和责任法案 (HIPAA)
萨班斯法案
加利福尼亚州 SB1386

缺少必需的CSP指令

原因:

不安全的网络应用程序编程或配置

风险:

"Content-Security-Policy"头部设计用于修改浏览器渲染页面的方式，从而保护免受各种跨站注入，包括跨站脚本。正确设置头部值非常重要，以免阻止网站的正常运行。缺少必要的指令可能会使网站变得脆弱，因此，攻击向量如XSS可能会被利用。

受影响产品:

这个问题可能会影响不同类型的产品。

修订建议:

常规

包括必要的指令，如default-src、script-src和style-src，以执行安全性。

CWE:

1032
79
693
830
1021

外部引用:

MDN 网络文档 - 内容安全策略

通过 URL 重定向钓鱼

原因:

- Web 应用程序将用户重定向到基于不受信任的数据的外部站点。
- 尤其是，发现提交的请求包含 URL 作为参数。Web 应用程序使用此值将用户的浏览器重定向到指定的 URL。
- 攻击者可以将此 URL 值修改为任意地址。然后，攻击者将诱骗受害者提交修改后的请求，从而将其重定向到攻击者选择的站点。

风险:

此漏洞允许攻击者利用用户对应用程序的信任，使他们信任受攻击者控制的任意站点。通常情况下，通过使用网络钓鱼技术利用此漏洞。网络钓鱼是一种社交工程技术，攻击者伪装成受害者可能与之进行交易的合法实体，以提示用户透露机密信息（通常是身份验证凭据），而攻击者稍后可以利用这些信息。网络钓鱼实质上是收集信息或“捕捞”信息的一种形式。攻击者可能会成功发起网络钓鱼诈骗并窃取用户凭据或其他敏感信息，例如信用卡号、社会保险号等。攻击者还可以重定向用户，使其安装可能会感染用户计算机的恶意软件。

利用示例:

以下示例显示 URL 重定向到不受信任的站点。
redir 参数用于自动将用户重定向到其他页面。

```
[REQUEST]
GET /MyPage.php?redir=/AnotherPage.php HTTP/1.1
```

```
[RESPONSE]
```

攻击者可能会欺骗受害者提供用于将用户重定向到外部站点的 GET 参数

```
[REQUEST]
GET /MyPage.php?redir=https://www.malware.com HTTP/1.1
```

```
[RESPONSE]
```

修订建议：

常规

尽量避免基于不受信任的数据重定向请求。
如果无法避免依赖用户输入，则在重定向之前应先验证 URL。用户可以修改的数据必须被视为不受信任的数据。
链接到当前用户会话的唯一令牌应随重定向字段值一起发送。然后，在重定向实际发生之前，应由服务器验证此唯一令牌。这样可以确保攻击者更难使用重定向字段来传播其恶意活动，因为他们无法猜测用户的会话令牌。
根据允许列表，通过与预定义的受信任 URL 列表进行比较来清理输入。
强制所有重定向先进入一个页面，在该页面中通知用户它们即将离开您的网站，并清楚地显示目的地，然后要求用户单击链接进行确认。

CWE:

601
610

外部引用：

未经验证的重定向和转发速查表

CORS 策略根据任意初始头进行设置

TOC

原因：

不安全的 Web 应用程序编程或配置

风险：

可能会收集有关 Web 应用程序的敏感信息，例如用户名、密码、计算机名称和/或敏感文件位置
可能会诱使防备心不强的用户提供敏感信息，如用户名、密码、信用卡号、社会保险号等
跨源资源共享 (CORS) 是一种机制，允许网站从外部站点请求资源，而无需复制这些资源。
授予对外部站点的访问权时，它们还可以在授予站点上执行各种操作，并在这些站点上运行脚本
因此，非常重要的一点是，不要授予对任意站点的访问权，而应仅授予对可信站点的访问权。
如果更改策略以反映源值，则必须针对可信站点的白名单对源进行测试。

受影响产品：

此问题可能会影响不同类型的产品。

修订建议：

常规

根据可信站点列表检查源头，将有效站点设置为 Access-Control-Allow-Origin 头的值。
如果不需要外部访问，请完全除去此头。

CWE:

200
693

外部引用：
启用跨源资源共享

OAuth 隐式授权类型缺陷

TOC

原因：
缺少 code_verify (PKCE)

风险：
黑客可能能够窃取或操纵客户会话和 cookie，并且可能将其用于假冒合法用户，从而以该用户身份查看或变更用户记录以及执行事务操作

修订建议：

常规

添加代码交换证明密钥 (PKCE)

CWE:
285
284

外部引用：
授权代码交换
Okta: 实施 PKCE

SRI (Subresource Integrity) 的检查

TOC

原因：
子资源完整性不受支持。

风险：
用户代理不验证来自第三方服务的脚本。如果第三方服务被破坏，用户将处于无保护状态。源自其他域的脚本和链接标签不支持完整性检查。如果托管脚本的服务被破坏，这种漏洞可能会被利用。
不支持SRI的样本脚本元素：
<script src="https://example.com/example-framework.js" crossorigin="anonymous"></script>
支持SRI的样本脚本元素：
<script src="https://example.com/example-framework.js" integrity="sha384-Li9vy3DqF8tnTXuiaAJuML3ky+er10rcgNR/VqsVpcw+ThHmYcwiB1pbOxEbzJr7" crossorigin="anonymous"></script>

受影响产品：
该问题可能会影响各种类型的产品。

修订建议：

常规

将子资源完整性添加到源不在您的域中的每个脚本/链接。
W3C子资源完整性：
<https://www.w3.org/TR/SRI/>
SRI哈希生成器：
<https://srihash.org>
不支持SRI的样本脚本元素：
<script src="https://example.com/example-framework.js" crossorigin="anonymous"></script>
示例脚本元素支持SRI：
<script src="https://example.com/example-framework.js" integrity="sha384-oqVuAfXRKap7fdgcCY5uykM6+R9GqQ8K/uxy9rx7HNQlGYI1kPzQh01wx4JwY8wC" crossorigin="anonymous"></script>

CWE:

829
669
830
354
345

外部引用：

[FrontPage 服务器扩展：安全考虑](#)
[解释](#)

具有不安全、不正确或缺少 SameSite 属性的 Cookie

TOC

原因：

具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie

风险：

通过将 Cookie 限制为第一方或同一站点上下文，防止 Cookie 信息泄露
如果没有额外的保护措施（例如反 CSRF 令牌），攻击可能会扩展到跨站点请求伪造 (CSRF) 攻击。
SameSite 属性控制如何为跨域请求发送 Cookie。
该属性可以有三个值：“Lax”、“Strict”或“None”。如果使用“None”，Web 站点可能会向另一个 Web 站点创建跨域 POST HTTP 请求，浏览器会自动向该请求添加 Cookie。
如果没有适当的保护措施（例如反 CSRF 令牌），则可能会导致跨站请求伪造 (CSRF) 攻击。
模式及其用途：
“Lax”模式：Cookie 将仅随顶级 GET 请求一起发送。“Strict”模式：即使用户点击另一个 Web 站点的链接，也不会以任何跨站点使用方式发送该 Cookie。“None”模式：Cookie 将随跨站点请求一起发送。
具有“Lax”或“None”的属性必须设置“Secure”标志，并且必须通过 https 传输。示例 - Set-Cookie: key=value; SameSite=Lax; Secure
建议将属性设置为“Strict”。
示例 - Set-Cookie: key=value; SameSite=Strict

受影响产品：

此问题可能影响不同类型的产品。

修订建议：

常规

[1] 查看将 SameSite Cookie 属性配置为推荐值的可能解决方案。[2] 将 Cookie 限制为第一方或同一站点上下文。[3] 验证并将 Cookie 的 SameSite 属性设置为 Strict，以确保仅在第一方上下文中发送 Cookie。[4] 或者，如果要放宽第一方上下文的限制，请验证 Cookie 的 SameSite 属性并将其设置为 Lax，同时启用 Secure 标志并通过 HTTPS 进行传输。

CWE:

1275
284
923

外部引用：
WASC 威胁分类：信息泄露
SameSite Cookie

加密会话（SSL）Cookie 中缺少 Secure 属性

TOC

原因：
Web 应用程序通过 SSL 发送不安全的 cookie

风险：
可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
在应用程序测试过程中，检测到在加密会话过程中，所测试的 Web 应用程序设置了不含“secure”属性的 cookie。由于这个 cookie 不包含“secure”属性，因此，也可能在未加密的会话过程中将它发送到站点。任何以明文形式发送到服务器的 cookie、会话令牌或用户凭证之类的信息都可能被窃取，并在稍后用于身份盗窃或用户伪装。
此外，若干隐私法规指出，用户凭证之类的敏感信息要始终以加密的方式发送到 Web 站点

受影响产品：
该问题可能会影响各种类型的产品

修订建议：
常规

基本上，cookie 的唯一必需属性是“name”字段。常见的可选属性如下：“comment”、“domain”、“path”，等等。常见的可选属性如下：“comment”、“domain”、“path”，等等。必须相应地设置“secure”属性，才能防止以未加密的方式发送 cookie。
有关如何设置安全标志的更多信息，请参阅 OWASP“安全属性”备忘单，地址为：
https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#secure-attribute
RFC 2965 指出：
“Secure 属性（不含值）会指导用户代理程序不管何时返回此 cookie，都只用（未指定）安全方法来联络原始服务器，以保护 cookie 中的信息的机密性和真实性。”如需进一步的引用，请参阅“HTTP 状态管理机制”RFC 2965，网址为：
<http://www.ietf.org/rfc/rfc2965.txt>
，如需使用“HTTP 状态管理机制”的“当前最佳做法”，请参阅
<http://tools.ietf.org/html/rfc2964>

CWE：
614
311
319

外部引用：
金融隐私权：The Gramm-Leach Bliley Act
Health Insurance Portability and Accountability Act（HIPAA）
Sarbanes-Oxley Act
California SB1386

发现数据库错误模式

TOC

原因：
未对用户输入正确执行危险字符清理

风险：

可能会查看、修改或删除数据库条目和表

AppScan 在测试响应中发现数据库错误，该错误可能已被“SQL 注入”以外的攻击所触发。虽然不确定，但这个错误可能表示应用程序有“SQL 注入”漏洞。

若是如此，请仔细阅读下列“SQL 注入”咨询。该软件使用受外部影响的输入构造整个 SQL 命令或 SQL 命令的一部分，但是会错误的无害化某些特殊元素，这些元素可在所需 SQL 命令发送到数据库时对其进行修改。如果在用户可控制的输入中没有对 SQL 语法充分地除去或加上引号，那么生成的 SQL 查询可能会导致将这些输入解释为 SQL 而不是普通用户数据。这可用于修改查询逻辑以绕过安全性检查，或者插入其他用于修改后端数据库的语句，也可能包括执行系统命令。

SELECT * FROMaccounts WHERE username=\$user' AND password=\$pass'

这两个变量（\$user 和 \$pass）包含了用户在登录表单中输入的用户凭证。因此，如果用户输入“jsmith”作为用户名，输入“Demo1234”作为密码，那么 SQL 查询将如下所示：

SELECT * FROMaccounts WHERE username='jsmith' AND password='Demo1234'

但如果用户输入""（单引号）作为用户名，输入""（单引号）作为密码，那么 SQL 查询将如下所示：

SELECT * FROMaccounts WHERE username="" AND password=""

当然，这是格式错误的 SQL 查询，并将调用错误消息，而 HTTP 响应中可能会返回此错误消息。通过此类错误，攻击者会知道 SQL 注入已成功，这样攻击者就会尝试进一步的攻击媒介。利用的样本：

以下 C# 代码会动态构造并执行 SQL 代码来搜索与指定名称匹配的项。该查询将所显示的项限制为其所有者与当前已认证用户的用户名相匹配的项。

```
... string userName = ctx.GetAuthenticatedUserName(); string query = "SELECT * FROMitems WHERE owner = '" + userName + "' AND itemname = '" + ItemName.Text + "'"; sda = new SqlDataAdapter(query, conn); DataTable dt = new DataTable(); sda.Fill(dt); ...
```

此代码打算执行的查询如下所示：

SELECT * FROMitems WHERE owner = AND itemname = ;

不过，由于该查询是通过将常量基本查询字符串和用户输入字符串进行并置来自动构造而成，因此仅当 itemName 不包含单引号字符时，查询才会正常工作。如果用户名为 wiley 的攻击者针对 itemName 输入字符串“name' OR 'a'='a”，那么查询将变为以下内容：

SELECT * FROMitems WHERE owner = 'wiley AND itemname = 'name' OR 'a'='a';

添加 OR 'a'='a' 条件导致 where 子句始终求值为 true，因此该查询在逻辑上将变为等价于以下更简单的查询：

SELECT * FROMitems;

受影响产品：

该问题可能会影响各种类型的产品。

修订建议：

常规

有多种减轻威胁的技巧：

[1] 策略：库或框架

使用不允许此弱点出现的经过审核的库或框架，或提供更容易避免此弱点的构造。

[2] 策略：参数化

如果可用，使用自动实施数据和代码之间的分离的结构化机制。这些机制也许能够提供自动提供相关引用、编码和验证，而不是依赖于开发者在生成输出的每个点提供此能力。

[3] 策略：环境固化

使用完成必要任务所需的最低特权来运行代码。

[4] 策略：输出编码

如果在有风险的情况下仍需要使用动态生成的查询字符串或命令，请对参数正确地加引号并将这些参数中的任何特殊字符转义。

[5] 策略：输入验证假定所有输入都是恶意的。使用“接受已知善意”输入验证策略：严格遵守规范的可接受输入的白名单。拒绝任何没有严格遵守规范的输入，或者将其转换为遵守规范的内容。不要完全依赖于将恶意或格式错误的输入加入黑名单。但是，黑名单可帮助检测潜在攻击，或者确定哪些输入由于格式严重错误而应直接拒绝。

以下是保护 Web 应用程序免遭 SQL 注入攻击的两种可行方法：

[1] 使用存储过程，而不用动态构建的 SQL 查询字符串。将参数传递给 SQL Server 存储过程的方式，可防止使用单引号和连字符。

以下是如何在 ASP.NET 中使用存储过程的简单示例：

```
'Visual Basic example Dim DS As DataSet Dim MyConnection As SqlConnection Dim MyCommand As SqlCommand Dim SelectCommand As String = "select * from users where username = @username" ... MyCommand.SelectCommand.Parameters.Add(New SqlParameter("@username", SqlDbType.NVarChar, 20)) MyCommand.SelectCommand.Parameters("@username").Value = UserNameField.Value // C# example String selectCmd = "select * from Authors where state = @username"; SqlConnection myConnection = new SqlConnection("server=..."); SqlDataAdapter myCommand = new SqlDataAdapter(selectCmd, myConnection); myCommand.SelectCommand.Parameters.Add(new SqlParameter("@username", SqlDbType.NVarChar, 20)); myCommand.SelectCommand.Parameters["@username"].Value = UserNameField.Value;
```

[2] 您可以使用验证控件，将输入验证添加到“Web 表单”页面。验证控件提供适用于所有常见类型的标准验证的易用机制 — 例如，测试验证日期是否有效，或验证值是否在范围内 — 以及进行定制编写验证的方法。此外，验证控件还使您能够完整定制向用户显示错误信息的方式。验证控件可搭配“Web 表单”页面的类文件中处理的任何控件使用，其中包括 HTML 和 Web 服务器控件。

为了确保用户输入仅包含有效值，您可以使用以下其中一种验证控件：

a. “RangeValidator”：检查用户条目（值）是否在指定的上下界限之间。您可以检查配对数字、字母字符和日期内的范围。

b. “RegularExpressionValidator”：检查条目是否与正则表达式定义的模式相匹配。此类型的验证使您能够检查可预见的字符序列，如社会保险号码、电子邮件地址、电话号码、邮政编码等中的字符序列。

重要注意事项：验证控件不会阻止用户输入或更改页面处理流程；它们只会设置错误状态，并产生错误消息。程序员的职责是，在执行进一步的应用程序特定操作前，测试代码中控件的状态。

有两种方法可检查用户输入的有效性：

1. 测试常规错误状态：

在您的代码中，测试页面的 IsValid 属性。该属性会将页面上所有验证控件的 IsValid 属性值汇总（使用逻辑 AND）。如果将其中一个验证控件设置为无效，那么页面属性将会返回 false。

2. 测试个别控件的错误状态：

在页面的“验证器”集合中循环，该集合包含对所有验证控件的引用。然后，您就可以检查每个验证控件的 IsValid 属性。

** 预编译语句：

以下是保护应用程序免遭 SQL 注入（即恶意篡改 SQL 参数）的三种可行方法。使用以下方法，而非动态构建 SQL 语句：

[1] PreparedStatement，通过预编译并且存储在 PreparedStatement 对象池中。PreparedStatement 定义 setter 方法，以注册与受支持的 JDBC SQL 数据类型兼容的输入参数。例如，setString 应该用于 VARCHAR 或 LONGVARCHAR 类型的输入参数（请参阅 Java API，以获取进一步的详细信息）。通过这种方法来设置输入参数，可防止攻击者通过注入错误字符（如单引号）来操纵 SQL 语句。

如何在 J2EE 中使用 PreparedStatement 的示例：

```
// J2EE PreparedStatement Example // Get a connection to the database Connection myConnection; if (isDataSourceEnabled()) { // using the DataSource to get a managed connection Context ctx = new InitialContext(); myConnection = ((DataSource)ctx.lookup(datasourceName)).getConnection(dbUserName, dbPassword); } else { try { // using the DriverManager to get a JDBC connection Class.forName(jdbcDriverClassName); myConnection = DriverManager.getConnection(jdbcURL, dbUserName, dbPassword); } catch (ClassNotFoundException e) { ... } ... try { PreparedStatement myStatement = myConnection.prepareStatement("select * from users where username = ?"); myStatement.setString(1, userNameField); ResultSet rs = myStatement.executeQuery(); ... rs.close(); } catch (SQLException sqlException) { ... } finally { myStatement.close(); myConnection.close(); }
```

[2] CallableStatement, 扩展 PreparedStatement 以执行数据库 SQL 存储过程。该类继承 PreparedStatement 的输入 setter 方法（请参阅上面的 [1]）。

以下示例假定已创建该数据库存储过程：

CREATE PROCEDURE select_user (@username varchar(20))AS SELECT * FROM USERS WHERE USERNAME = @username;如何在 J2EE 中使用 CallableStatement 以执行以上存储过程的示例：

```
// J2EE PreparedStatement Example // Get a connection to the database Connection myConnection; if (isDataSourceEnabled()) { // using the DataSource to get a managed connection Context ctx = new InitialContext(); myConnection = ((DataSource)ctx.lookup(datasourceName)).getConnection(dbUserName, dbPassword); } else { try { // using the DriverManager to get a JDBC connection Class.forName(jdbcDriverClassName); myConnection = DriverManager.getConnection(jdbcURL, dbUserName, dbPassword); } catch (ClassNotFoundException e) { ... } ... try { PreparedStatement myStatement = myConnection.prepareCall("=? call select_user ?,?"); myStatement.setString(1, userNameField); myStatement.registerOutParameter(1, Types.VARCHAR); ResultSet rs = myStatement.executeQuery(); ... rs.close(); } catch (SQLException sqlException) { ... } finally { myStatement.close(); myConnection.close(); }
```

[3] 实体 Bean, 代表持久存储机制中的 EJB 业务对象。实体 Bean 有两种类型：bean 管理和容器管理。当使用 bean 管理的持久性时，开发者负责撰写访问数据库的 SQL 代码（请参阅以上的 [1] 和 [2] 部分）。当使用容器管理的持久性时，EJB 容器会自动生成 SQL 代码。因此，容器要负责防止恶意尝试篡改生成的 SQL 代码。

如何在 J2EE 中使用实体 Bean 的示例：

```
// J2EE EJB Example try { // lookup the User home interface UserHome userHome = (UserHome)context.lookup(User.class); // find the User remote interface User = userHome.findByPrimaryKey(new UserKey(userNameField)); ... } catch (Exception e) { ... }
```

推荐使用的 JAVA 工具

不适用

参考资料

链接：<https://docs.oracle.com/javase/7/docs/api/java/sql/PreparedStatement.html>

链接：<https://docs.oracle.com/javase/7/docs/api/java/sql/CallableStatement.html>

** 输入数据验证：

虽然为方便用户而在客户端层上提供数据验证，但仍必须使用 Servlet 在服务器层上执行数据验证。客户端验证本身就不安全，因为这些验证可轻易绕过，例如，通过禁用 Javascript。一份好的设计通常需要 Web 应用程序框架，以提供服务器端实用程序例程，从而验证以下内容：[1] 必需字段[2] 字段数据类型（缺省情况下，所有 HTTP 请求参数都是“字符串”）[3] 字段长度[4] 字段范围[5] 字段选项[6] 字段模式[7] cookie 值[8] HTTP 响应好的做法是将以上例程作为“验证器”实用程序类中的静态方法实现。以下部分描述验证器类的一个示例。

```
// Java example to validate required fields public Class Validator { ... public static boolean validateRequired(String value) { boolean isFieldValid = false; if (value != null && value.trim().length() > 0) { isFieldValid = true; return isFieldValid; } ... } ... String fieldValue = request.getParameter("fieldName"); if (Validator.validateRequired(fieldValue)) { // fieldValue is valid, continue processing request ... }
```

[2] 输入的 Web 应用程序中的字段数据类型和输入参数欠佳。例如，所有 HTTP 请求参数或 cookie 值的类型都是“字符串”。开发者负责验证输入的数据类型是否正确。使用 Java 基本包装程序类，来检查是否可将字段值安全地转换为所需的基本数据类型。

验证数字字段（int 类型）的方式的示例：

```
// Java example to validate that a field is an int number public Class Validator { ... public static boolean validateInt(String value) { boolean isFieldValid = false; try { Integer.parseInt(value); isFieldValid = true; } catch (Exception e) { isFieldValid = false; } return isFieldValid; } ... } ... // check if the HTTP request parameter is of type int String fieldValue = request.getParameter("fieldName"); if (Validator.validateInt(fieldValue)) { // fieldValue is valid, continue processing request ... }
```

好的做法是将所有 HTTP 请求参数转换为其各自的数据类型。例如，开发者应将请求参数的“integerValue”存储在请求属性中，并按以下示例所示来使用：

```
// Example to convert the HTTP request parameter to a primitive wrapper data type // and store this value in a request attribute for further processing String fieldValue = request.getParameter("fieldName"); if (Validator.validateInt(fieldValue)) { // convert fieldValue to an Integer Integer integerValue = Integer.getInteger(fieldValue); // store integerValue in a request attribute request.setAttribute("fieldName", integerValue); } ... // Use the request attribute for further processing Integer integerValue = (Integer)request.getAttribute("fieldName"); ...
```

应用程序应处理的主要 Java 数据类型：

- Byte
- Short
- Integer
- Long
- Float
- Double
- Date

[3] 字段长度“始终”确保输入参数（HTTP 请求参数或 cookie 值）有最小长度和/或最大长度的限制。以下示例验证 userName 字段的长度是否在 8 至 20 个字符之间：

```
// Example to validate the field length public Class Validator { ... public static boolean validateLength(String value, int minLength, int maxLength) { String validatedValue = value; if (!validateRequired(value)) { validatedValue = ""; } return (validatedValue.length() >= minLength && validatedValue.length() <= maxLength); } ... } ... String userName = request.getParameter("userName"); if (Validator.validateRequired(userName)) { if (Validator.validateLength(userName, 8, 20)) { // userName is valid, continue further processing ... } }
```

[4] 字段范围

始终确保输入参数是在由功能需求定义的范围內。

以下示例验证输入 numberOfChoices 是否在 10 至 20 之间：

```
// Example to validate the field range public Class Validator { ... public static boolean validateRange(int value, int min, int max) { return (value >= min && value <= max); } ... } ... String fieldValue = request.getParameter("numberOfChoices"); if (Validator.validateRequired(fieldValue)) { if (Validator.validateInt(fieldValue)) { int numberOfChoices = Integer.parseInt(fieldValue); if (Validator.validateRange(numberOfChoices, 10, 20)) { // numberOfChoices is valid, continue processing request ... } }
```

[5] 字段选项 Web 应用程序通常会为用户显示一组可供选择的选项（例如，使用 SELECT HTML 标记），但不能执行服务器端验证以确保选定的值是其中一个允许的选项。请记住，恶意用户能够轻易修改任何选项值。始终针对由功能需求定义的受允许的选项来验证选定的用户值。以下示例验证用户针对允许的选项列表进行的选择：

```
// Example to validate user selection against a list of options public Class Validator { ... public static boolean validateOption(Object[] options, Object value) { boolean isValidValue = false; try { List list = Arrays.asList(options); if (list != null) { isValidValue = list.contains(value); } } catch (Exception e) { } return isValidValue; } ... } ... // Allowed options String[] options = {"option1", "option2", "option3"}; // Verify that the user selection is one of the allowed options String userSelection = request.getParameter("userSelection"); if (Validator.validateOption(options, userSelection)) { // valid user selection, continue processing request ... }
```

[6] 字段模式

始终检查用户输入与由功能需求定义的模式是否匹配。例如，如果 userName 字段应仅允许字母数字字符，且不区分大小写，那么请使用以下正则表达式：`^[a-zA-Z0-9]*$`

Java 1.3 或更早的版本不包含任何正则表达式包。建议将“Apache 正则表达式包”（请参阅以下“资源”）与 Java 1.3 一起使用，以解决该缺乏支持的问题。执行正则表达式验证的示例：

```
// Example to validate that a given value matches a specified pattern // using the Apache regular expression package import org.apache.regexp.RE; import org.apache.regexp.RESyntaxException; public Class Validator { ... public static boolean matchPattern(String value, String expression) { boolean match = false; if
```

(validateRequired(expression)) { RE r = new RE(expression); match = r.match(value); } return match; } ... } ... // Verify that the userName request parameter is alpha-numeric String
userName = request.getParameter("userName"); if (Validator.matchPattern(userName, "[a-zA-Z0-9]*\$")) { // userName is valid, continue processing request ... }
Java 1.4 引进了一种新的正则表达式包 (java.util.regex)。以下是使用新的 Java 1.4 正则表达式包的 Validator.matchPattern 修订版：
// Example to validate that a given value matches a specified pattern // using the Java 1.4 regular expression package import java.util.regex.Pattern; import java.util.regex.Matcher;
public Class Validator { ... public static boolean matchPattern(String value, String expression) { boolean match = false; if (validateRequired(expression)) { match =
Pattern.matches(expression, value); } return match; } ... }
[7] cookie 值使用 javax.servlet.http.Cookie 对象来验证 cookie 值。适用于 cookie 值的相同的验证规则（如上所述）取决于应用程序需求（如验证必需值、验证长度等）。验证必需
cookie 值的示例：
// Example to validate a required cookie value // First retrieve all available cookies submitted in the HTTP request Cookie[] cookies = request.getCookies(); if (cookies != null) { // find
the "user" cookie for (int i=0; i<cookies.length; ++i) { if (cookies[i].getName().equals("user")) { // validate the cookie value if (Validator.validateRequired(cookies[i].getValue())) { // valid
cookie value, continue processing request ... } } }
[8] HTTP 响应
[8-1] 过滤用户输入要保护应用程序免遭跨站点脚本编制的攻击，请通过将敏感字符转换为其对应的字符实体来清理 HTML。这些是 HTML 敏感字符：<>"'%;)(& +
以下示例通过将敏感字符转换为其对应的字符实体来过滤指定字符串：
// Example to filter sensitive data to prevent cross-site scripting public Class Validator { ... public static String filter(String value) { if (value == null) { return null; } StringBuffer result =
new StringBuffer(value.length()); for (int i=0; i<value.length(); ++i) { switch (value.charAt(i)) { case '<': result.append("<"); break; case '>': result.append(">"); break; case '\"':
result.append(\"'\"); break; case '\\': result.append("\\"); break; case '%': result.append("%"); break; case ';': result.append(";"); break; case ':': result.append(":"); break; case '<!--':
result.append("<!--"); break; case '&': result.append("&"); break; case '+': result.append("+"); break; default: result.append(value.charAt(i)); break; } return result; } ... } // Filter the
HTTP response using Validator.filter PrintWriter out = response.getWriter(); // set output response out.write(Validator.filter(response)); out.close();
Java Servlet API 2.3 引进了“过滤器”，它支持拦截和转换 HTTP 请求或响应。
以下示例使用 Validator.filter 来用“Servlet 过滤器”清理响应：
// Example to filter all sensitive characters in the HTTP response using a Java Filter. // This example is for illustration purposes since it will filter all content in the response,
including HTML tags! public class SensitiveCharsFilter implements Filter { ... public void doFilter(ServletRequest request, ServletResponse response, FilterChain chain) throws
IOException, ServletException { PrintWriter out = response.getWriter(); ResponseWrapper wrapper = new ResponseWrapper((HttpServletResponse)response);
chain.doFilter(request, wrapper); CharArrayWriter caw = new CharArrayWriter(); caw.write(Validator.filter(wrapper.toString())); response.setContentType("text/html");
response.setContentLength(caw.toString().length()); out.write(caw.toString()); out.close(); } ... public class CharResponseWrapper extends HttpServletResponseWrapper { private
CharArrayWriter output; public String toString() { return output.toString(); } public CharResponseWrapper(HttpServletResponse response) { super(response); output = new
CharArrayWriter(); } public PrintWriter getWriter() { return new PrintWriter(output); } } }
[8-2] 保护 cookie
在 cookie 中存储敏感数据时，确保使用 Cookie.setSecure（布尔标志）在 HTTP 响应中设置 cookie 的安全标志，以指导浏览器使用安全协议（如 HTTPS 或 SSL）发送 cookie。
保护“用户”cookie 的示例：
// Example to secure a cookie, i.e. instruct the browser to // send the cookie using a secure protocol Cookie cookie = new Cookie("user", "sensitive"); cookie.setSecure(true);
response.addCookie(cookie);
推荐使用的 JAVA 工具用于服务器端验证的两个主要 Java 框架是：
[1] Jakarta Commons Validator（与 Struts 1.1 集成）Jakarta Commons Validator 是 Java 框架，定义如上所述的错误处理机制。Jakarta Commons Validator 是一种强大的框架，用
来实现所有以上数据验证需求。这些规则配置在定义表单字段的输入验证规则的 XML 文件中。在缺省情况下，Struts 支持在使用 Struts“bean:write”标记撰写的所有数据上，过滤 [8]
HTTP 响应中输出的危险字符。可通过设置“filter=false”标志来禁用该过滤。
Struts 定义以下基本输入验证器，但也可定义定制的验证器：
required: 如果字段包含空格以外的任何字符，便告成功。
mask: 如果值与掩码属性给定的正则表达式相匹配，便告成功。
range: 如果值在 min 和 max 属性给定的值的范围内（value >= min）&（value <= max），便告成功。
maxLength: 如果字段长度小于或等于 max 属性，便告成功。
minLength: 如果字段长度大于或等于 min 属性，便告成功。
byte、short、integer、long、float、double: 如果可将值转换为对应的基本类型，便告成功。
date: 如果值代表有效日期，便告成功。可能会提供日期模式。
creditCard: 如果值可以是有效的信用卡号码，便告成功。
e-mail: 如果值可以是有效的电子邮件地址，便告成功。
<form-validation> <global> ... <validator name="required" classname="org.apache.struts.validator.FieldChecks" method="validateRequired" msg="errors.required"> </validator>
<validator name="mask" classname="org.apache.struts.validator.FieldChecks" method="validateMask" msg="errors.invalid"> </validator> ... </global> <formset> <form
name="loginForm"> <!-- userName is required and is alpha-numeric case insensitive --> <field property="userName" depends="required,mask"> <!-- message resource key to
display if validation fails --> <msg name="mask" key="login.userName.maskmsg"> <arg0 key="login.userName.displayName"> <var> <var-name>mask</var-name> <var-
value>[a-zA-Z0-9]*\$</var-value> </var> </field> ... </form> ... </formset> </form-validation>
[2] JavaServer Faces 技术
“JavaServer Faces 技术”是一组代表 UI 组件、管理组件状态、处理事件和输入验证的 Java API (JSR 127)。
JavaServer Faces API 实现以下基本验证器，但可定义定制的验证器： validate_doublerrange: 在组件上注册 DoubleRangeValidator
validate_length: 在组件上注册 LengthValidator
validate_longrange: 在组件上注册 LongRangeValidator
validate_required: 在组件上注册 RequiredValidator
validate_stringrange: 在组件上注册 StringRangeValidator
validator: 在组件上注册定制的 Validator
JavaServer Faces API 定义以下 UIInput 和 UIOutput 处理器（标记）：
input_date: 接受以 java.text.Date 实例格式化的 java.util.Date
output_date: 显示以 java.text.Date 实例格式化的 java.util.Date
input_datetime: 接受以 java.text.DateTime 实例格式化的 java.util.Date
output_datetime: 显示以 java.text.DateTime 实例格式化的 java.util.Date
input_number: 显示以 java.text.NumberFormat 格式化的数字数据类型（java.lang.Number 或基本类型）
output_number: 显示以 java.text.NumberFormat 格式化的数字数据类型（java.lang.Number 或基本类型）
input_text: 接受单行文本字符串。
output_text: 显示单行文本字符串。
input_time: 接受以 java.text.DateFormat 时间实例格式化的 java.util.Date
output_time: 显示以 java.text.DateFormat 时间实例格式化的 java.util.Date
input_hidden: 允许页面作者在页面中包括隐藏变量
input_secret: 接受不含空格的单行文本，并在输入时，将其显示为一组星号
input_textarea: 接受多行文本
output_errors: 显示整个页面的错误消息，或与指定的客户端标识相关联的错误消息

output_label: 将嵌套的组件显示为指定输入字段的标签

output_message: 显示本地化消息

```
<%@taglib uri="https://docs.oracle.com/javase/6/tutorial/doc/glxce.html" prefix="h" %> <%@taglib uri="http://mrbool.com/how-to-create-a-login-validation-with-jsf-java-server-faces/27046" prefix="f" %> ... <jsp:useBean id="UserBean" class="myApplication.UserBean" scope="session" /> <f:use_faces> <h:form formName="loginForm"> <h:input_text id="userName" size="20" modelReference="UserBean.userName"> <f:validate_required/> <f:validate_length minimum="8" maximum="20"> <h:input_text> <!-- display errors if present --> <h:output_errors id="loginErrors" clientId="userName"/> <h:command_button id="submit" label="Submit" commandName="submit" /><p> </h:form> </f:use_faces>
```

参考资料

Java API 1.3 -

链接: <https://www.oracle.com/java/technologies/java-archive-13docs-downloads.html>

Java API 1.4 -

链接: <https://www.oracle.com/java/technologies/java-archive-142docs-downloads.html>

Java Servlet API 2.3 -

链接: <https://mvnrepository.com/artifact/javax.servlet/javax.servlet-api>

Java 正则表达式包 -

链接: <http://jakarta.apache.org/regex/>

Jakarta 验证器 -

链接: <http://jakarta.apache.org/commons/validator/>

JavaServer Faces 技术 -

链接: <http://www.java-serverfaces.org/>

** 错误处理:

许多 J2EE Web 应用程序体系结构都遵循“模型视图控制器 (MVC)”模式。在该模式中, Servlet 扮演“控制器”的角色。Servlet 将应用程序处理委派给 EJB 会话 Bean (模型) 之类的 JavaBean。然后, Servlet 再将请求转发给 JSP (视图), 以呈现处理结果。Servlet 应检查所有的输入、输出、返回码、错误代码和已知的异常, 以确保实际处理按预期进行。

数据验证可保护应用程序免遭恶意数据篡改, 而有效的错误处理策略则是防止应用程序意外泄露内部错误消息 (如异常堆栈跟踪) 所不可或缺的。好的错误处理策略会处理以下项:

[1] 定义错误

[2] 报告错误

[3] 呈现错误

[4] 错误映射

[1] 定义错误

应避免在应用程序层 (如 Servlet) 中硬编码错误消息。相反地, 应用程序应该使用映射到已知应用程序故障的错误密钥。好的做法是定义错误密钥, 且该错误密钥映射到 HTML 表单字段或其他 Bean 属性的验证规则。例如, 如果需要 "user_name" 字段, 其内容为字母数字, 并且必须在数据库中是唯一的, 那么就应定义以下错误密钥:

(a) ERROR_USERNAME_REQUIRED: 该错误密钥用于显示消息, 以通知用户需要 "user_name" 字段;

(b) ERROR_USERNAME_ALPHANUMERIC: 该错误密钥用于显示消息, 以通知用户 "user_name" 字段应该是字母数字;

(c) ERROR_USERNAME_DUPLICATE: 该错误密钥用于显示消息, 以通知用户 "user_name" 值在数据库中重复;

(d) ERROR_USERNAME_INVALID: 该错误密钥用于显示一般消息, 以通知用户 "user_name" 值无效;

好的做法是定义用于存储和报告应用程序错误的以下框架 Java 类:

- ErrorKeys: 定义所有错误密钥

```
// Example: ErrorKeys defining the following error keys: // - ERROR_USERNAME_REQUIRED // - ERROR_USERNAME_ALPHANUMERIC // - ERROR_USERNAME_DUPLICATE // - ERROR_USERNAME_INVALID // ... public Class ErrorKeys { public static final String ERROR_USERNAME_REQUIRED = "error.username.required"; public static final String ERROR_USERNAME_ALPHANUMERIC = "error.username.alphanumeric"; public static final String ERROR_USERNAME_DUPLICATE = "error.username.duplicate"; public static final String ERROR_USERNAME_INVALID = "error.username.invalid"; ... }
```

- Error: 封装个别错误

```
// Example: Error encapsulates an error key. // Error is serializable to support code executing in multiple JVMs. public Class Error implements Serializable { // Constructor given a specified error key public Error(String key) { this(key, null); } // Constructor given a specified error key and array of placeholder objects public Error(String key, Object[] values) { this.key = key; this.values = values; } // Returns the error key public String getKey() { return this.key; } // Returns the placeholder values public Object[] getValues() { return this.values; } private String key = null; private Object[] values = null; }
```

- Errors: 封装错误的集合

```
// Example: Errors encapsulates the Error objects being reported to the presentation layer. // Errors are stored in a HashMap where the key is the bean property name and value is an // ArrayList of Error objects. public Class Errors implements Serializable { // Adds an Error object to the Collection of errors for the specified bean property. public void addError(String property, Error error) { ArrayList propertyErrors = (ArrayList)errors.get(property); if (propertyErrors == null) { propertyErrors = new ArrayList(); errors.put(property, propertyErrors); } propertyErrors.put(error); } // Returns true if there are any errors public boolean hasErrors() { return (errors.size > 0); } // Returns the Errors for the specified property public ArrayList getErrors(String property) { return (ArrayList)errors.get(property); } private HashMap errors = new HashMap(); }
```

以下是使用上述框架类来处理 "user_name" 字段验证错误的示例:

```
// Example to process validation errors of the "user_name" field. Errors errors = new Errors(); String userName = request.getParameter("user_name"); // (a) Required validation rule if (!Validator.validateRequired(userName)) { errors.addError("user_name", new Error(ErrorKeys.ERROR_USERNAME_REQUIRED)); } // (b) Alpha-numeric validation rule else if (!Validator.matchPattern(userName, "{a-zA-Z0-9}*") { errors.addError("user_name", new Error(ErrorKeys.ERROR_USERNAME_ALPHANUMERIC)); } else { // (c) Duplicate check validation rule // We assume that there is an existing UserValidationEJB session bean that implements // a checkIfDuplicate() method to verify if the user already exists in the database. try { ... if (UserValidationEJB.checkIfDuplicate(userName)) { errors.addError("user_name", new Error(ErrorKeys.ERROR_USERNAME_DUPLICATE)); } } catch (RemoteException e) { // log the error logger.error("Could not validate user for specified userName: " + userName); errors.addError("user_name", new Error(ErrorKeys.ERROR_USERNAME_DUPLICATE)); } } // set the errors object in a request attribute called "errors" request.setAttribute("errors", errors); ...
```

[2] 报告错误

有两种方法可报告 web 层应用程序错误:

(a) Servlet 错误机制

(b) JSP 错误机制

[2-a] Servlet 错误机制

Servlet 可通过以下方式报告错误:

- 转发给输入 JSP (已将错误存储在请求属性中), 或

- 使用 HTTP 错误代码参数来调用 response.sendError, 或

- 抛出异常

好的做法是处理所有已知应用程序错误 (如 [1] 部分所述), 将这些错误存储在请求属性中, 然后转发给输入 JSP。输入 JSP 应显示错误消息, 并提示用户重新输入数据。以下示例阐明转发给输入 JSP (userInput.jsp) 的方式:

```
// Example to forward to the userInput.jsp following user validation errors RequestDispatcher rd = getServletContext().getRequestDispatcher("/user/userInput.jsp"); if (rd != null) { rd.forward(request, response); }
```

如果 Servlet 无法转发给已知的 JSP 页面, 那么第二个选项是使用 response.sendError 方法, 将 HttpServletResponse.SC_INTERNAL_SERVER_ERROR (状态码 500) 作为参数, 来报告错误。请参阅 javax.servlet.http.HttpServletResponse 的 Javadoc, 以获取有关各种 HTTP 状态码的更多详细信息。返回 HTTP 错误的示例:

```
// Example to return a HTTP error code RequestDispatcher rd = getServletContext().getRequestDispatcher("/user/userInput.jsp"); if (rd == null) { // messages is a resource bundle
```

with all message keys and values response.sendError(HttpServletResponse.SC_INTERNAL_SERVER_ERROR, messages.getMessage(ErrorKeys.ERROR_USERNAME_INVALID));}
作为最后的手段，Servlet 可以抛出异常，且该异常必须是以下其中一类的子类：

- RuntimeException
- ServletException
- IOException

[2-b] JSP 错误机制

JSP 页面通过定义 `errorPage` 伪指令来提供机制，以处理运行时异常，如下示例所示：

```
<%@ page errorPage="/errors/userValidation.jsp" %>
```

未捕获的 JSP 异常被转发给指定的 `errorPage`，并且原始异常设置在名称为 `javax.servlet.jsp.jspException` 的请求参数中。错误页面必须包括 `isErrorPage` 伪指令，如下所示：

```
<%@ page isErrorPage="true" %>
```

`isErrorPage` 伪指令导致“`exception`”变量初始化为所抛出的异常对象。

[3] 呈现错误

J2SE Internationalization API 提供使应用程序资源外部化以及将消息格式化的实用程序类，其中包括：

- (a) 资源束
- (b) 消息格式化

[3-a] 资源束

资源束通过将本地化数据从使用该数据的源代码中分离来支持国际化。每一资源束都会为特定的语言环境存储键/值的映射。

`java.util.PropertyResourceBundle` 将内容存储在外部属性文件中，对其进行使用或扩展都很常见，如下示例所示：

```
##### # ErrorMessages.properties ##### # required user name
error message error.username.required=User name field is required # invalid user name format error.username.alphanumeric=User name must be alphanumeric # duplicate
user name error message error.username.duplicate=User name {0} already exists, please choose another one ...
```

可定义多种资源，以支持不同的语言环境（因此名为资源束）。例如，可定义 `ErrorMessages_fr.properties` 以支持该束系列的法语成员。如果请求的语言环境的资源成员不存在，那么会使用缺省成员。在以上示例中，缺省资源是 `ErrorMessages.properties`。应用程序（JSP 或 Servlet）会根据用户的语言环境从适当的资源检索内容。

[3-b] 消息格式化

J2SE 标准类 `java.util.MessageFormat` 提供使用替换占位符来创建消息的常规方法。`MessageFormat` 对象包含嵌入了格式说明符的模式字符串，如下所示：

```
// Example to show how to format a message using placeholder parameters String pattern = "User name {0} already exists, please choose another one"; String userName =
request.getParameter("user_name"); Object[] args = new Object[1]; args[0] = userName; String message = MessageFormat.format(pattern, args);
```

以下是使用 `ResourceBundle` 和 `MessageFormat` 来呈现错误消息的更加全面的示例：

```
// Example to render an error message from a localized ErrorMessages resource (properties file) // Utility class to retrieve locale-specific error messages public Class
ErrorMessageResource { // Returns the error message for the specified error key in the environment locale public String getErrorMessage(String errorKey) { return
getErrorMessage(errorKey, defaultLocale); } // Returns the error message for the specified error key in the specified locale public String getErrorMessage(String errorKey, Locale
locale) { return getErrorMessage(errorKey, null, locale); } // Returns a formatted error message for the specified error key in the specified locale public String
getErrorMessage(String errorKey, Object[] args, Locale locale) { // Get localized ErrorMessageResource ResourceBundle ErrorMessageResource =
ResourceBundle.getBundle("ErrorMessages", locale); // Get localized error message String errorMessage = ErrorMessageResource.getString(errorKey); if (args != null) { // Format
the message using the specified placeholders args return MessageFormat.format(errorMessage, args); } else { return errorMessage; } } // default environment locale private
Locale defaultLocale = Locale.getDefaultLocale(); } ... // Get the user's locale Locale userLocale = request.getLocale(); // Check if there were any validation errors Errors errors =
(Errors)request.getAttribute("errors"); if (errors != null && errors.hasErrors()) { // iterate through errors and output error messages corresponding to the "user_name" property
ArrayList userNameErrors = errors.getErrors("user_name"); ListIterator iterator = userNameErrors.iterator(); while (iterator.hasNext()) { // Get the next error object Error error =
(Error)iterator.next(); String errorMessage = ErrorMessageResource.getErrorMessage(error.getKey(), userLocale); output.write(errorMessage + "\n"); } }
```

建议定义定制 JSP 标记（如 `displayErrors`），以迭代处理并呈现错误消息，如以上示例所示。

[4] 错误映射

通常情况下，“Servlet 容器”会返回与响应状态码或异常相对应的缺省错误页面。可以使用定制错误页面来指定状态码或异常与 Web 资源之间的映射。好的做法是开发不会泄露内部错误状态的静态错误页面（缺省情况下，大部分 Servlet 容器都会报告内部错误消息）。该映射配置在“Web 部署描述符（`web.xml`）”中，如下示例所指定：

```
<!-- Mapping of HTTP error codes and application exceptions to error pages --> <error-page> <exception-type>UserValidationException</exception-type>
<location>/errors/validationError.html</error-page> </error-page> <error-page> <error-code>500</exception-type> <location>/errors/internalError.html</error-page>
</error-page> ... </error-page> ...
```

推荐使用的 JAVA 工具用于服务器端验证的两个主要 Java 框架是：

[1] Jakarta Commons Validator（与 Struts 1.1 集成）Jakarta Commons Validator 是 Java 框架，定义如上所述的错误处理机制。Jakarta Commons Validator 是 Java 框架，定义如上所述的错误处理机制。验证规则配置在 XML 文件中，该文件定义了表单字段的输入验证规则以及对应的验证错误密钥。Struts 提供国际化支持以使用资源束和消息格式化来构建本地化应用程序。

```
<form-validation> <global> ... <validator name="required" classname="org.apache.struts.validator.FieldChecks" method="validateRequired" msg="errors.required"> </validator>
<validator name="mask" classname="org.apache.struts.validator.FieldChecks" method="validateMask" msg="errors.invalid"> </validator> ... </global> <formset> <form
name="loginForm"> <!-- userName is required and is alpha-numeric case insensitive --> <field property="userName" depends="required,mask"> <!-- message resource key to
display if validation fails --> <msg name="mask" key="login.userName.maskmsg"/> <arg0 key="login.userName.displayName"/> <var> <var-name>mask</var-name> <var-
value>{a-zA-Z0-9}*$</var-value> </var> </field> ... </form> ... </formset> </form-validation>
```

Struts JSP 标记库定义了有条件地显示一组累计错误消息的“`errors`”标记，如下示例所示：

```
<%@ page language="java" %> <%@ taglib uri="/WEB-INF/struts-html.tld" prefix="html" %> <%@ taglib uri="/WEB-INF/struts-bean.tld" prefix="bean" %> <html:html> <head>
<body> <html:form action="/login.do"> <table border="0" width="100%"> <tr> <th align="right"> <html:errors property="username"/> <bean:message key="prompt.username"/>
</th> <td align="left"> <html:text property="username" size="16"/> </td> </tr> <tr> <td align="right"> <html:submit><bean:message key="button.submit"/></html:submit> </td> <td
align="right"> <html:reset><bean:message key="button.reset"/></html:reset> </td> </tr> </table> </html:form> </body> </html:html>
```

[2] JavaServer Faces 技术

“JavaServer Faces 技术”是一组代表 UI 组件、管理组件状态、处理事件、验证输入和支持国际化的 Java API（JSR 127）。

JavaServer Faces API 定义“`output_errors`”UIOutput 处理器，该处理器显示整个页面的错误消息，或与指定的客户端标识相关联的错误消息。

```
<%@ taglib uri="https://docs.oracle.com/javaee/6/tutorial/doc/glxce.html" prefix="h" %> <%@ taglib uri="http://mrbool.com/how-to-create-a-login-validation-with-jsf-java-server-
faces/27046" prefix="f" %> ... <jsp:useBean id="UserBean" class="myApplication.UserBean" scope="session" /> <f:use_faces> <h:form formName="loginForm"> <h:input_text
id="userName" size="20" modelReference="UserBean.userName"> <f:validate_required/> <f:validate_length minimum="8" maximum="20"/> </h:input_text> <!-- display errors if
present --> <h:output_errors id="loginErrors" clientId="userName"/> <h:command_button id="submit" label="Submit" commandName="submit"/></p> </h:form> </f:use_faces>
```

参考资料

Java API 1.3 -

链接：<https://www.oracle.com/java/technologies/java-archive-13docs-downloads.html>

Java API 1.4 -

链接：<https://www.oracle.com/java/technologies/java-archive-142docs-downloads.html>

Java Servlet API 2.3 -

链接：<https://mvnrepository.com/artifact/javax.servlet/javax.servlet-api>

Java 正则表达式包 —
链接: <http://jakarta.apache.org/regex/>
Jakarta 验证器 —
链接: <http://jakarta.apache.org/commons/validator/>
JavaServer Faces 技术 —
链接: <http://www.java-serverfaces.org/>
** 过滤用户输入
将任何数据传给 SQL 查询之前, 应始终先使用筛选技术来适当过滤。这无论如何强调都不为过。过滤用户输入可让许多注入缺陷在到达数据库之前便得到更正。
** 对用户输入加引号
不论任何数据类型, 只要数据库允许, 便用单引号括住所有用户数据, 始终是好的观念。MySQL 允许此格式化技术。
** 转义数据值
如果使用 MySQL 4.3.0 或更新的版本, 您应该用 `mysql_real_escape_string()` 来转义所有字符串。如果使用旧版的 MySQL, 便应该使用 `mysql_escape_string()` 函数。如果未使用 MySQL, 您可以选择使用特定数据库的特定换码功能。如果不知道换码功能, 您可以选择使用较一般的换码功能, 例如, `addslashes()`。
如果使用 PEAR DB 数据库抽象层, 您可以使用 `DB::quote()` 方法或使用 `?` 之类的查询占位符, 它会自动转义替换占位符的值。
参考资料
http://ca3.php.net/mysql_real_escape_string
http://ca.php.net/mysql_escape_string
<http://ca.php.net/addslashes>
<http://pear.php.net/package-info.php?package=DB>
** 输入数据验证: 虽然为方便用户而在客户端层上提供数据验证, 但仍必须始终在服务器层上执行数据验证。客户端验证本身就不安全, 因为这些验证可轻易绕过, 例如, 通过禁用 Javascript。
一份好的设计通常需要 Web 应用程序框架, 以提供服务器端实用程序例程, 从而验证以下内容: [1] 必需字段[2] 字段数据类型 (缺省情况下, 所有 HTTP 请求参数都是“字符串”) [3] 字段长度[4] 字段范围[5] 字段选项[6] 字段模式[7] cookie 值[8] HTTP 响应好的做法是实现一个或多个验证每个应用程序参数的函数。以下部分描述一些检查的示例。
// PHP example to validate required fields
function validateRequired(\$input) { ... \$pass = false; if (strlen(trim(\$input))>0) { \$pass = true; } return \$pass; ... }
if (validateRequired(\$fieldName)) { // fieldName is valid, continue processing request ... }
[2] 输入的 Web 应用程序中的字段数据类型和输入参数欠佳。例如, 所有 HTTP 请求参数或 cookie 值的类型都是“字符串”。开发者负责验证输入的数据类型是否正确。[3] 字段长度“始终”确保输入参数 (HTTP 请求参数或 cookie 值) 有最小长度和/或最大长度的限制。[4] 字段范围
始终确保输入参数是在由功能需求定义的范围內。
[5] 字段选项 Web 应用程序通常会为用户显示一组可供选择的选项 (例如, 使用 SELECT HTML 标记), 但不能执行服务器端验证以确保选定的值是其中一个允许的选项。请记住, 恶意用户能够轻易修改任何选项值。始终针对由功能需求定义的受允许的选项来验证选定的用户值。[6] 字段模式
始终检查用户输入与由功能需求定义的模式是否匹配。例如, 如果 `userName` 字段应仅允许字母数字字符, 且不区分大小写, 那么请使用以下正则表达式: `^[a-zA-Z0-9]+$`
[7] cookie 值
适用于 cookie 值的相同的验证规则 (如上所述) 取决于应用程序需求 (如验证必需值、验证长度等)。
[8] HTTP 响应[8-1] 过滤用户输入要保护应用程序免遭跨站点脚本编制的攻击, 开发者应通过将敏感字符转换为其对应的字符实体来清理 HTML。这些是 HTML 敏感字符: `<>"'%;)( & +`
PHP 包含一些自动化清理实用程序函数, 如 `htmlentities()`:
`$input = htmlentities($input, ENT_QUOTES, 'UTF-8');`
此外, 为了避免“跨站点脚本编制”的 UTF-7 变体, 您应该显式定义响应的 Content-Type 头, 例如:
`<?php header('Content-Type: text/html; charset=UTF-8'); ?>`
[8-2] 保护 cookie
在 cookie 中存储敏感数据且通过 SSL 来传输时, 请确保先在 HTTP 响应中设置 cookie 的安全标志。这将会指示浏览器仅通过 SSL 连接来使用该 cookie。
为了保护 cookie, 您可以使用以下代码示例:
`<$php $value = "some_value"; $time = time()+3600; $path = "/application/"; $domain = ".example.com"; $secure = 1; setcookie("CookieName", $value, $time, $path, $domain, $secure, TRUE); ?>`
此外, 我们建议您使用 `HttpOnly` 标志。当 `HttpOnly` 标志设置为 `TRUE` 时, 将只能通过 HTTP 协议来访问 cookie。这意味着无法用脚本语言 (如 JavaScript) 来访问 cookie。该设置可有效地帮助减少通过 XSS 攻击盗用身份的情况 (虽然并非所有浏览器都支持该设置)。
在 PHP 5.2.0 中添加了 `HttpOnly` 标志。
引用[1] 使用 HTTP 专用 cookie 来减轻“跨站点脚本编制”的影响:
<http://msdn2.microsoft.com/en-us/library/ms533046.aspx>
[2] PHP 安全协会:
<http://phpsec.org/>
[3] PHP 和 Web 应用程序安全博客 (Chris Shiflett):
<http://shiflett.org/>

CWE:
209
200
497

外部引用:
“Web Application Disassembly with ODBC Error Messages” (作者: David Litchfield)

跨站点请求伪造

TOC

原因：

- 之所以出现此漏洞，是因为应用程序允许用户在不验证请求是否是有意发送的情况下执行某些敏感操作。
- 攻击者可能导致受害者的浏览器向应用程序中的任意 URL 发出 HTTP 请求。从经过认证的受害者的浏览器发送此请求时，它将包括受害者的会话 Cookie 或认证标头。应用程序将接受此请求作为来自经过认证的用户的有效请求。
- 如果将 Web 服务器设计为接收来自客户端的请求，但缺乏用于验证该请求是否有有意发送的机制，则攻击者可能会欺骗客户端从另一个站点发出无意请求，而应用程序会将该请求视为可信请求。可以通过提交表单、加载图像、在 JavaScript 中发送 XMLHttpRequest 等执行此操作。
- 例如，此 IMG 标签可以嵌入到攻击者的网页中，并且受害者的浏览器将提交请求检索该图像。此有效请求将由应用程序处理，并且浏览器不会显示损坏的图像。“”。由此带来的结果是，使用受害者的会话将受害者账户中的资金转移到攻击者的账户中。

风险：

攻击者可利用此漏洞在另一个用户的帐户中执行敏感操作，或使用其特权执行敏感操作。

可能会强制最终用户在当前其已通过认证的 Web 应用程序上执行不必要的操作。这将允许攻击者更改用户记录并以该用户身份执行事务。

如果用户当前登录到受害者站点，则请求将自动使用该用户的凭证，例如会话 Cookie、IP 地址及其他浏览器认证方法。攻击者使用此方法来伪造受害者的身份，并代表他们提交操作。

此漏洞的严重程度取决于应用程序中受影响的功能。例如，对搜索页面的 CSRF 攻击不如对转账或个人资料更新页面的 CSRF 攻击严重。

修订建议：

常规

设置所有会话和认证 Cookie，以包括“SameSite”属性，将“SameSite”属性设置为“Strict”或“Lax”。根据 HTTP 标准，将此属性设置为“Lax”时，确保无法通过“GET”请求执行任何敏感操作。

使用平台或框架提供的内置 CSRF 保护，并确保正确地激活该保护（无论是在配置中还是在代码中）。

如果平台不提供内置的 CSRF 防御机制，请考虑集成经过充分审查的库以实施保护，例如 OWASP CSRFGuard。

避免构建自定义的 CSRF 防御实施方式，因为在不允许轻易绕过的情况下，很难正确实现此目标。如果由于缺乏标准库支持而导致您必须这么做，则应该在服务器上生成安全、随机且不可预测的令牌（例如 GUID v4），并将该令牌嵌入到每个 HTML 表单中，同时将其与用户会话绑定。收到提交的表单后，验证包含的表单令牌是否与先前绑定至该用户的令牌相匹配。也可以将 CSRF 令牌嵌入到指定的 Cookie（“重复提交的 Cookie”）中，或者当服务器收到这些请求以及提交的表单令牌时，最好使用自定义请求标头，这样可以轻松验证它们是否匹配（而不是存储在用户的会话中）。

另一种方法是要求用户针对特定操作重新进行认证，以确保用户的有效确认。请注意，这会严重影响用户体验，因此应有节制地使用此方法，并且仅将其用于特别敏感的操作。

通过验证“来源”标头（如有），或至少验证“引用站点”标头来验证请求的来源。请丢弃从其他站点发出的敏感请求。

CWE：

352
693
345
346

外部引用：

OWASP CSRF 速查表
OWASP CSRFGuard

“X-Content-Type-Options”头缺失或不安全

TOC

原因：

Web 应用程序编程或配置不安全

风险：

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置

可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息。

“X-Content-Type-Options”头（具有“nosniff”值）防止 IE 和 Chrome 忽略响应的内容类型。

此操作可能防止不可信内容（例如，用户上传内容）在用户浏览器上执行（例如，在恶意命名之后）。

受影响产品：

此问题可能影响不同类型的产品

修订建议：

常规

将服务器配置为针对所有外发请求发送具有值“nosniff”的“X-Content-Type-Options”头。

关于 Apache，请参阅：
http://httpd.apache.org/docs/2.2/mod/mod_headers.html

关于 IIS，请参阅：
<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>

关于 nginx，请参阅：
http://nginx.org/en/docs/http/nginx_http_headers_module.html

CWE:

200
693

外部引用：

有用 HTTP 头列表
减少 MIME 类型安全风险

会话 cookie 中缺少 HttpOnly 属性

TOC

原因：

Web 应用程序设置了缺少 HttpOnly 属性的会话 cookie

风险：

可能会窃取或操纵客户会话和 cookie，它们可能用于模仿合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务

在应用程序测试过程中，检测到所测试的 Web 应用程序设置了不含“HttpOnly”属性的会话 cookie。由于此会话 cookie 不包含“HttpOnly”属性，因此植入站点的恶意脚本可能访问此 cookie，并窃取它的值。任何存储在会话令牌中的信息都可能被窃取，并在稍后用于身份盗窃或用户伪装。

受影响产品：

该问题可能会影响各种类型的产品

修订建议：

常规

基本上，cookie 的唯一必需属性是“name”字段。常见的可选属性如下：“comment”、“domain”、“path”，等等。必须相应地设置“HttpOnly”属性，才能防止会话 cookie 被脚本访问。

CWE:

653
693
1004

发现 Web 应用程序源代码泄露模式

TOC

原因：

- 未安装第三方产品的最新补丁或最新修订程序
- 在生产环境中留下临时文件
- 程序员在 Web 页面上留下调试信息

风险:

可能会检索服务器端脚本的源代码，这可能会泄露应用程序逻辑及其他诸如用户名和密码之类的敏感信息
AppScan 检测到含有应用程序源代码片段的响应。Web 用户不应具有访问应用程序源代码的能力，因为它可能含有敏感的应用程序信息及后端逻辑。
虽然这类泄漏不一定代表安全的违规，但它为攻击者提供了有用的指导，以进行进一步利用。
泄漏敏感信息可能带来不同级别的风险，应该尽可能加以限制。

受影响产品:

该问题可能会影响各种类型的产品。

修订建议:

常规

许多方式可以诱使 Web 应用程序显示其源代码。
要确保应用程序不允许 Web 用户访问源代码，请执行下列操作：
[1] 检查已安装与源代码泄露相关的所有系统补丁。
[2] 检查未将应用程序源代码留在 HTML 注释中。
[3] 检查已从生产环境中除去所有源代码文件。

CWE:

540
200

发现可高速缓存的 SSL 页面

TOC

原因:

浏览器可能已将敏感信息高速缓存

风险:

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
缺省情况下，大部分 Web 浏览器都配置成会在使用期间高速缓存用户的页面。这表示也会高速缓存 SSL 页面。不建议让 Web 浏览器保存任何 SSL 信息，因为当有漏洞存在时，可能会危及这个信息。

受影响产品:

该问题可能会影响各种类型的产品。

修订建议:

常规

在所有 SSL 页面及含有敏感数据的所有页面上，禁用高速缓存。
通过使用你您 SSL 页面标题中的"Cache-Control: no-store"和"Pragma: no-cache"或"Cache-Control: no-cache"响应伪指令来实现此操作。
Cache-Control: private - 此伪指令可向代理指示某个页面中包含私有信息，因此不能由共享高速缓存进行高速缓存。但是，它不会指示浏览器阻止高速缓存此页面。
Cache-Control: no-cache - 此伪指令也可向代理指示某个页面中包含私有信息，因此不能高速缓存。它还会指示浏览器重新验证服务器以检查是否有新的版本可用。这意味着浏览器可能会存储敏感页面或要在重新验证中使用的信息。某些浏览器不一定会跟踪 RFC，因此可能会将 no-cache 视为 no-store。
Cache-Control: no-store - 这是最安全的伪指令。它同时指示代理和浏览器不要高速缓存此页面或将其存储为它们的高速缓存文件夹。
Pragma: no-cache - 对于不支持高速缓存控制标题的较旧浏览器，该伪指令是必需的。

CWE:

525
524
668
200

在CSP中未强制执行脚本中的可信类型

TOC

原因：
不安全的网页应用程序编程或配置

风险：
"Content-Security-Policy"头部设计用于修改浏览器渲染页面的方式，从而保护免受各种跨站注入，包括跨站脚本。正确设置头部值非常重要，以免阻止网站的正常运行。不使用可信类型可能会让攻击者注入脚本，因此，这增加了XSS漏洞的风险。

受影响产品：
这个问题可能会影响不同类型的产品。

修订建议：

常规

实施可信类型以执行安全的DOM操作实践。

CWE:
1032
79
693
830
1021

外部引用：
MDN 网络文档 - 内容安全策略

永久 Cookie 包含敏感的会话信息

TOC

原因：
Web 应用程序将敏感的会话信息存储在永久 Cookie 中（磁盘上）

风险：
可能会窃取保存在磁盘上作为永久 Cookie 的会话信息（Cookie）
在应用程序测试期间，检测到用户凭证或会话令牌之类的敏感会话信息存储在了客户端计算机上的永久 Cookie 中。
[1] 由于其他用户可能使用该计算机，因此这些信息可能会被泄露或用于身份盗用或用户冒充。
[2] 如果该计算机受到威胁，则帐户信息可能会被窃取并在之后被恶意用户所用。
此外，一些隐私法规要求在访问敏感信息之前必须唯一识别用户的身份。由于永久 Cookie 可能允许其他用户在不进行身份认证的情况下登录 Web 应用程序，因此这可能不符合一些隐私法规。

受影响产品：
此问题可能影响不同类型的产品

修订建议：

常规

确保始终只将用户凭证或会话令牌之类的敏感会话信息保存在非永久 cookie（RAM cookie）中。不在 cookie 中设置“Expires”字段，便可以做到这一点。如果缺少“Expires”属性，浏览器会自动将其视为会话 cookie。

CWE:
539
284
664
200

外部引用:

- Set-Cookie 标头“Expires”属性描述
- 金融隐私权: 《格拉姆-里奇-布莱利法案》
- 《健康保险携带和责任法案》(HIPAA)
- 《萨班斯-奥克斯利法案》
- California SB1386
- HTTP 状态管理机制 (RFC 2109)

跨帧脚本编制防御缺失或不安全

TOC

原因:

Web 应用程序编程或配置不安全

风险:

- 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
- 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息。
- 跨帧脚本编制是一种攻击技术, 攻击者利用这种技术在其恶意网站上的 iFrame 中加载易受攻击的应用程序。
- 然后, 攻击者可以发起 Clickjacking 攻击, 这可能导致网络钓鱼、跨网站请求伪造、敏感信息泄露等。
- 为实现最佳保护, 建议将报头值设置为 DENY 或 SAMEORIGIN。
- 示例攻击:
- 在恶意网站中, 可以嵌入易受攻击的网页:
- <frame src="http://vulnerable.com/login.html">

受影响产品:

此问题可能影响不同类型的产品。

修订建议:

常规

使用 X-Frame-Options 可防止 (或限制) 页面嵌入 iFrame 中。对于较旧版本的浏览器, 请在每个页面中包含一个不应成帧的“框架破坏程序”脚本。

CWE:

1021

外部引用:

- 跨帧脚本编制
- Clickjacking

过度许可的 CORS 访问测试

TOC

原因:

Web 应用程序编程或配置不安全

风险:

- 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
- 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
- 跨源资源共享 (CORS) 是允许 web 站点从外部站点请求资源的机制, 从而避免复制资源。向外部站点授予访问权时, 它们可对授予权限的站点执行各种操作, 以及在这些站点上面执行 脚本。因此, 除了可信站点之外, 不向任何其他站点授予访问权则非常重要。

受影响产品:

该问题可能会影响各种类型的产品。

修订建议：

常规

准备可信站点的列表，并将它们设置为“Access-Control-Allow-Origin”头的值。如果外部访问权不需要该值，请完全地除去该头。

CWE:

200
668
664

外部引用：

启用跨源资源共享